

Comunicazione Organizzativa di Gruppo n. 65/GCASC/DPO del 9 aprile 2021

“Attuazione del modello di gestione per la protezione dei dati personali”

In applicazione della DdG in materia di “Modello di gestione per la protezione dei dati personali”, con la presente Comunicazione Organizzativa di Gruppo, il DPO di FS SpA, nell’ambito delle proprie attività di indirizzo e coordinamento e con il supporto delle strutture specialistiche di cui alla citata DdG, definisce il *Framework di Data Protection* inteso come “l’insieme di regole e metodi definiti dal sistema delle norme organizzative, i ruoli e le responsabilità delle strutture coinvolte, i processi e i sistemi informativi, l’insieme dei trattamenti di dati personali per le esigenze di business e operative, il sistema dei controlli rivolto alla gestione e mitigazione dei rischi per i diritti e le libertà delle persone fisiche legati al trattamento di dati personali”.

Tale sistema di norme si integra coerentemente con l’impianto normativo esistente e, in particolare, con le norme interne relative alla protezione della confidenzialità dell’informazione, di cui alla Disposizione di Gruppo in materia di “Linee di indirizzo per la classificazione delle informazioni in termini di riservatezza” e con le norme interne relative alle informazioni privilegiate, di cui alla Disposizione di Gruppo “Regolamento per la gestione interna e comunicazione all’esterno delle informazioni privilegiate e per il trattamento delle informazioni riservate e Procedura per la gestione interna del registro delle persone che hanno accesso alle informazioni privilegiate”.

Il primo periodo di applicazione del Regolamento UE 2016/679 ha visto l’impegno del Gruppo per la creazione di un modello di gestione per la protezione dei dati, con riflessi importanti sull’operatività delle Società. Trascorso questo primo periodo di applicazione, si è resa necessaria una revisione complessiva del *Framework* finalizzata a (i) recepire gli approcci interpretativi del Garante per la protezione dei dati personali e dell’*European Data Protection Board*, (ii) semplificare i processi di gestione e protezione dei dati personali, (iii) applicare *best practice* di settore, (iv) recepire le variazioni organizzative avvenute nel Gruppo.

La presente Comunicazione Organizzativa di Gruppo è direttamente applicabile nelle Società che hanno nominato un *Data Protection Officer*. Le Società del Gruppo per le quali la nomina del *Data Protection Officer* non è obbligatoria, sono tenute a recepire nel proprio sistema normativo interno i contenuti della presente Comunicazione Organizzativa di Gruppo provvedendo a declinarli nella rispettiva realtà aziendale, identificando le attività di competenza del Referente *Data Protection* (come definito dalla DdG in materia di “Modello di Gestione per la Protezione dei Dati Personali”) e adottando proprie Comunicazioni Organizzative societarie in materia.

Ciascuna Società garantisce la corretta e costante applicazione di quanto definito e ne assicura la massima diffusione al proprio interno ed il relativo controllo attuativo anche presso le proprie controllate, nel rispetto degli obblighi di riservatezza e delle prerogative di autonomia e indipendenza di ciascuna Società con particolare riferimento al Gestore dell’infrastruttura ferroviaria nazionale, così come previsto dalla normativa comunitaria e nazionale. Per le Società estere del Gruppo, direttamente o indirettamente controllate, il recepimento della presente Comunicazione Organizzativa di Gruppo è a discrezione del Titolare che valuta, insieme al DPO di FS SpA, l’applicabilità della stessa rispetto al contesto normativo del Paese in cui opera.

A seguito di eventuali modifiche all'assetto societario di Gruppo (acquisizione, fusione, scorporo etc.), le “nuove” entità legali che risultino controllate, direttamente o indirettamente, da FS SpA, sono soggette al recepimento della presente e ad avviare tutte le attività necessarie per un pronto adeguamento.

La presente Comunicazione Organizzativa di Gruppo aggiorna e sostituisce le seguenti CO/G:

- CO/G n. 6-CRO-DPO del 25 giugno 2018 – *Linee di indirizzo per la gestione delle terze parti con riferimento alla protezione dei dati personali*;
- CO/G n. 8-CRO-DPO del 24 luglio 2018 – *Linee di indirizzo per la gestione dei diritti degli interessati*;
- CO/G n. 11-CRO-DPO del 26 settembre 2018 – *Linee di indirizzo per l'identificazione dei trattamenti a potenziale rischio elevato e Data Protection Impact Assessment*;
- CO/G n. 12-CRO-DPO del 26 settembre 2018 – *Linee di indirizzo per la Data Protection by Design e by Default*;
- CO/G n. 20-CRO-DPO del 29 gennaio 2019 – *Linee di indirizzo per la Gestione dei Data Breach*;
- CO/G n. 40-CRO-DPO del 7 gennaio 2020 – *Linee di indirizzo sul periodo di conservazione dei dati personali*.

Il sistema delle norme che definiscono il *framework* viene quindi riorganizzato all'interno di un unico documento, riportato in allegato e che costituisce parte integrante della presente CO/G, che consta delle seguenti **Sezioni**:

- **Sezione A – Data Protection by Design & by Default**: la procedura disciplina le regole per l'applicazione preventiva dei principi di *data protection* nel disegno e nell'esecuzione di qualsiasi attività che comporti il trattamento di dati personali (*by design* e *by default*). Rispetto alla precedente versione, sono stati chiariti e aggiornati: **(i)** il processo di applicazione delle regole di *data protection by design* e *by default*, **(ii)** gli elementi utili ad accertare la conformità al Regolamento UE 2016/679.
- **Sezione B – Trattamenti a Potenziale Rischio Elevato e Data Protection Impact Assessment**: la procedura disciplina la metodologia e il processo con cui vengono identificati i trattamenti a potenziale rischio elevato e viene effettuata la valutazione di impatto. Rispetto alla precedente versione, sono stati chiariti e aggiornati: **(i)** il perimetro di applicazione e gli scopi dell'attività di *Data Protection Impact Assessment*, **(ii)** le note metodologiche del processo di identificazione dei trattamenti a potenziale rischio elevato e *Data Protection Impact Assessment*.
- **Sezione C – Gestione dei Diritti degli Interessati**: la procedura disciplina le modalità con cui è garantito agli interessati l'esercizio dei diritti previsti dal Regolamento e i processi aziendali volti ad assicurare un pronto e completo riscontro alle richieste degli stessi. Rispetto alla precedente versione, è stato chiarito e aggiornato il processo di gestione delle richieste degli interessati.
- **Sezione D – Gestione delle Terze Parti**: la procedura disciplina le modalità per tutelare i diritti degli interessati in tutte le attività svolte da terze parti che comportano un trattamento di dati personali, definendo i vincoli contrattuali necessari. Rispetto alla precedente versione, sono stati chiariti e aggiornati: **(i)** il processo per la determinazione del ruolo della terza parte, **(ii)** le modalità operative di stesura degli accordi con le terze parti.
- **Sezione E – Gestione delle violazioni di dati personali (“Data Breach”)**: la procedura disciplina le regole e le indicazioni operative per individuare le violazioni dei dati personali e per

garantire il governo e l'attuazione del processo di gestione delle violazioni dei dati personali. Rispetto alla precedente versione, è stato chiarito e aggiornato il processo di gestione e risposta ai *data breach*, inclusa la notifica al Garante per la Protezione dei Dati Personali.

- **Sezione F – Definizione e Applicazione del Periodo di Conservazione dei dati personali:** la procedura disciplina le modalità e i criteri per l'individuazione del periodo di conservazione dei dati personali. Vengono inoltre dettagliate le attività necessarie a garantire l'effettiva cancellazione, l'anonimizzazione o la conservazione ai fini di archiviazione nel pubblico interesse, di ricerca scientifica o storica o a fini statistici del dato personale una volta raggiunto il termine del periodo di conservazione. Rispetto alla precedente versione, è stato chiarito e aggiornato il processo di individuazione e attuazione del periodo o del criterio di conservazione del dato personale.

Si specifica che nelle suddette procedure, il *Data Manager* è la figura, identificata dalla DdG in materia di “Modello di gestione per la protezione dei dati personali”, che agisce su delega del Titolare del trattamento, rappresentato dall'Amministratore Delegato (o dall'Amministratore Unico) delle Società del Gruppo FS Italiane.

Il *framework* così definito potrà essere integrato o aggiornato a seguito di evoluzioni normative o sostanziali cambiamenti organizzativi, nonché del consolidarsi di *best practice*.

Si rammenta, infine, che la mancata applicazione del *framework* può comportare l'irrogazione di sanzioni ai sensi degli Artt. 83 e 84 del Regolamento (cui si rimanda integralmente per il dettaglio delle condizioni) fino al 4% del fatturato dell'anno precedente. Il D.Lgs. n. 101 prevede inoltre, per alcuni illeciti, sanzioni penali fino a sei anni di reclusione.

Firmato
Giorgio Aprile

Visto

Firmato
Guglielmo Bove



Allegato alla CO/G n. 65/GCASC/DPO del 9 aprile 2021

ATTUAZIONE DEL MODELLO DI GESTIONE PER LA PROTEZIONE DEI DATI PERSONALI



INDICE DEI CONTENUTI

SEZIONE A – DATA PROTECTION BY DESIGN E BY DEFAULT	6
SEZIONE B – TRATTAMENTI A RISCHIO ELEVATO E DATA PROTECTION IMPACT ASSESSMENT	19
SEZIONE C – GESTIONE DEI DIRITTI DEGLI INTERESSATI.....	38
SEZIONE D – GESTIONE DELLE TERZE PARTI	53
SEZIONE E – GESTIONE DELLE VIOLAZIONI DI DATI PERSONALI (“DATA BREACH”)	67
SEZIONE F – DEFINIZIONE E APPLICAZIONE DEL PERIODO DI CONSERVAZIONE DEI DATI PERSONALI	76
 INDICE DELLE FIGURE.....	 88
INDICE DELLE TABELLE	88
GLOSSARIO	89



SEZIONE A

DATA PROTECTION BY DESIGN E BY DEFAULT



SEZIONE A.....	6
1. DATA PROTECTION BY DESIGN E BY DEFAULT.....	8
1.1 PREMESSA E DEFINIZIONI.....	8
2. LIVELLI DI APPLICAZIONE DELLA DATA PROTECTION BY DESIGN E BY DEFAULT	9
2.1 LIVELLO STRATEGICO	9
2.2 LIVELLO PROGETTUALE.....	10
2.3 LIVELLO OPERATIVO	11
3. LA PROTEZIONE DEI DATI PERSONALI BY DEFAULT	12
3.1 REGOLA GENERALE.....	12
3.2 REGOLE SPECIFICHE	12
4. LE REGOLE PER LA DATA PROTECTION BY DESIGN	14
4.1 REGOLA GENERALE.....	14
4.2 REGOLE SPECIFICHE	14
INDICE DELLE FIGURE	88
INDICE DELLE TABELLE	88
GLOSSARIO	89



1. Data Protection by Design e by Default

1.1 Premessa e definizioni

Il Regolamento UE 679/2016 (anche “GDPR”) introduce all’Art. 25 il concetto di “Protezione dei dati fin dalla progettazione e protezione per impostazione predefinita” (*Data Protection by Design e By Default*). Il Regolamento specifica che il Titolare del trattamento mette in atto misure tecniche ed organizzative adeguate volte ad attuare in modo efficace i principi di protezione dei dati e a integrare nel trattamento le necessarie garanzie al fine di soddisfare i requisiti normativi e tutelare i diritti degli interessati.

All’interno del Gruppo FS Italiane:

- Per *data protection by design* si intende l’insieme delle regole di progettazione del trattamento che consentono nativamente il rispetto dei principi del Regolamento senza la necessità di interventi successivi (ad esempio, progettare un sistema con il livello di misure di sicurezza tecnico-organizzative adeguate al rischio potenziale del trattamento, oppure progettare un sistema che preveda la possibilità di estrarre un formato standard per garantire la portabilità dei dati personali).
- Per *data protection by default* si intende l’insieme delle regole di progettazione del trattamento che circoscrivono e limitano l’utilizzo dei dati personali per impostazione predefinita, sia nelle finalità sia nel tempo di *retention* (ad esempio, l’utilizzo dei dati personali strettamente necessari alla finalità del trattamento, la limitazione del trattamento alle sole finalità per le quali è stata fornita informativa e, ove necessario, raccolti i consensi, la limitazione del periodo di *retention* dei dati).



2. Livelli di applicazione della Data Protection by Design e by Default

La protezione dei dati personali si configura in maniera differente in funzione dei diversi livelli di maturità dell'iniziativa aziendale che comporti il trattamento di dati personali. Tali livelli sono schematizzati in:

- Livello Strategico
- Livello Progettuale
- Livello Operativo



Figura 1 - Livelli di applicazione “Data Protection By Default e By Design”

I principi della *data protection by design* e *by default* sono quindi applicati a livello di:

- scelte di carattere strategico connesse al Piano Industriale che prevedano un trattamento di dati personali;
- iniziative progettuale, di innovazione e di trasformazione che prevedano il trattamento di dati personali;
- attività operative quotidiane di trattamento dei dati personali.

2.1 Livello strategico

Alcune scelte strategiche effettuate a livello di Piano Industriale possono implicare, nella loro implementazione, nuovi trattamenti di dati personali o la modifica profonda di trattamenti in essere. Ad esempio, la scelta di sviluppare servizi digitali per la dematerializzazione dei titoli di viaggio, la scelta di puntare su servizi ancillari per la Clientela tramite accordi di *partnership* con terze parti o un investimento pluriennale per la migrazione dei servizi IT su piattaforme in *cloud*, rivestono tutti grande importanza rispetto alla tutela dei diritti e delle libertà delle persone fisiche in materia di dati personali.

Ai sensi dell'Art. 38 del Regolamento, il Titolare del trattamento assicura che il DPO sia “*tempestivamente e adeguatamente coinvolto in tutte le questioni riguardanti la protezione dei dati personali*”. Rispetto alle scelte strategiche effettuate a livello di Piano Industriale, tale disposizione si applica mediante la partecipazione del DPO alle



riunioni della prima linea del *management* e ai Comitati direttivi nelle occasioni in cui sono discusse iniziative strategiche che possono implicare il trattamento di dati personali¹.

Il DPO fornisce consulenza al Titolare e alla prima linea del management rispetto alle possibili implicazioni delle iniziative strategiche sui diritti e le libertà delle persone fisiche. Si attiva affinché nella valutazione delle iniziative tali problematiche vengano prese in considerazione, sia in termini di rischio dei trattamenti, sia in termini di costo delle misure tecnico-organizzative adeguate al livello di rischio. Inoltre, tale coinvolgimento garantisce un seguimiento puntuale e coerente sin dalla fase di ideazione delle iniziative aziendali.

Nella definizione delle iniziative strategiche, il Titolare tiene conto delle indicazioni del DPO rispetto alle regole di *data protection by design* e *by default* definite nel seguito del documento.

2.2 Livello progettuale

Le iniziative progettuali di innovazione e di trasformazione, intraprese a livello di ciascuna struttura organizzativa, possono implicare nuovi trattamenti di dati personali o la modifica profonda di trattamenti in essere. Ad esempio, la scelta di utilizzare tecniche innovative di videosorveglianza o di *machine learning* e intelligenza artificiale per il monitoraggio dei flussi di persone all'interno delle stazioni, nonché l'attivazione di attività di *marketing* e profilazione su nuovi segmenti di clientela, possono comportare rischi rispetto alla tutela dei diritti e delle libertà delle persone fisiche in materia di dati personali.

Il *Data Manager* e tutte le strutture organizzative coinvolte nelle attività progettuali, con l'eventuale supporto del Data Protection Officer, tengono conto delle regole di *data protection by design* e *by default* definite nel seguito del documento. Al fine di dimostrare l'applicazione di tali regole, il *Data Manager* è tenuto a seguire un processo rigoroso e documentabile, sintetizzato in **Figura 2** e descritto di seguito:

- **Fase 1:** il *Data Manager* rileva l'esigenza di *business*/operativa che comporta il trattamento (o di modifica al trattamento) di dati personali ed è in grado di dimostrare che l'utilizzo dei dati personali è imprescindibile per le finalità previste.
- **Fase 2:** il *Data Manager* sottopone l'iniziativa al DPO e, se necessario, alle strutture specialistiche preposte per la progettazione e/o per le verifiche di competenza (IT, *Cyber Security*, etc.). Con riferimento alle verifiche di specifica competenza del DPO, il trattamento è soggetto ad una valutazione preliminare, o *Pre-Assessment* ².
- **Fase 3 [eventuale]:** il *Data Manager* verifica il livello di rischio del trattamento e le misure di sicurezza mediante *Data Protection Impact Assessment* ³; il DPO supporta il *Data Manager* ed esprime un parere conclusivo sulla possibilità di procedere con il trattamento. La fase è eventuale, in funzione degli esiti dell'analisi condotta in Fase 2).

¹ Come chiarito all'interno del documento WP243 rev.01 – *Working Party 29* – Linee Guida sui Responsabili della Protezione dei Dati (RPD)

² Si vedano le linee di indirizzo per l'identificazione dei trattamenti a potenziale rischio elevato e *data protection impact assessment* (**Sezione B** del presente documento)

³ Si vedano le linee di indirizzo per l'identificazione dei trattamenti a potenziale rischio elevato e *data protection impact assessment* (**Sezione B** del presente documento)



- **Fase 4:** il *Data Manager*, sempre con il supporto delle strutture specialistiche e del DPO, formalizza nella documentazione di progetto, la conclusione dell'analisi, nonché le modalità con le quali si intende garantire il rispetto dei principi di *data protection by design* e *by default*, nonché le misure di sicurezza tecniche ed organizzative previste.
- **Fase 5:** il *Data Manager* conclude la progettazione del trattamento redigendo/aggiornando l'apposita Scheda sul Registro dei Trattamenti⁴, specificando – se il trattamento richiede l'utilizzo di una soluzione informatica a supporto – il dettaglio della soluzione identificata e delle misure di sicurezza implementate.

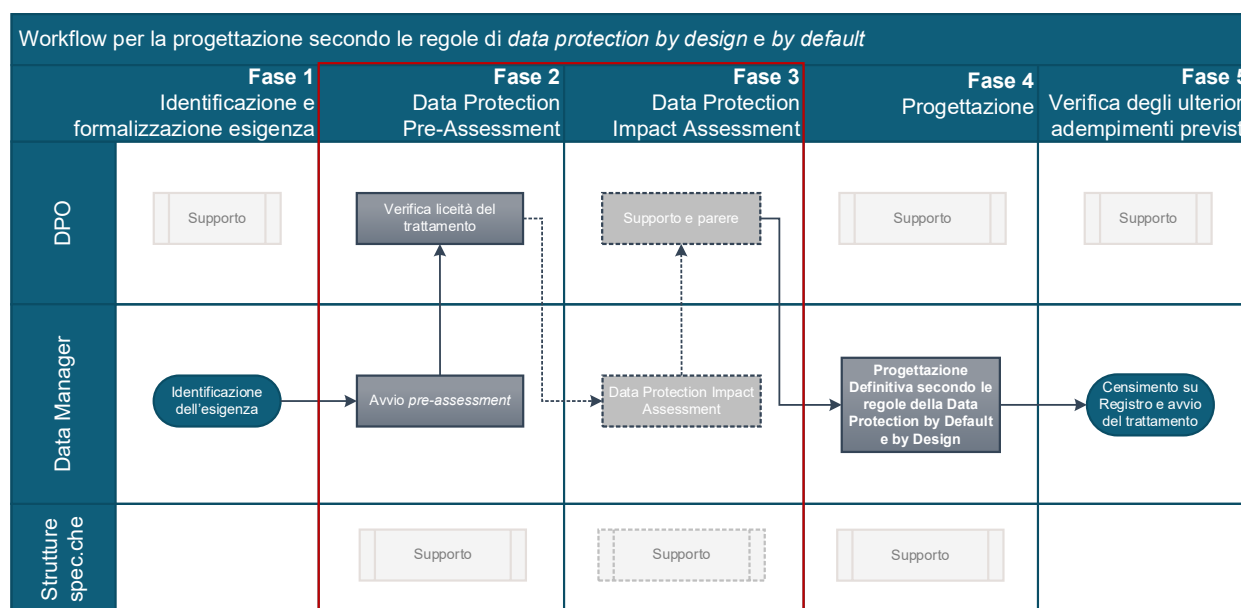


Figura 2 – Progettazione secondo le regole di *data protection by design* e *by default*

Si specifica che i passaggi logici sottostanti la [Fase 2 – Data Protection pre-assessment](#) e la [Fase 3 – Data Protection Impact Assessment](#) sono descritti più accuratamente nelle linee di indirizzo per l'Identificazione dei Trattamenti a Potenziale Rischio Elevato e *Data Protection Impact Assessment* ([Sezione B](#) del presente documento).

2.3 Livello operativo

Nelle attività quotidiane di trattamento dei dati personali, il *Data Manager* verifica il rispetto costante di quanto definito in fase di progettazione e l'applicazione delle regole di *data protection by design* e *by default* definite nel seguito del documento.

Il DPO effettua un controllo indipendente rispetto all'applicazione di tali regole.

⁴ Si veda il [Glossario](#) per la definizione di “Registro dei Trattamenti”.



3. La Protezione dei Dati Personali by Default

3.1 Regola generale

Il *Data Manager*, con il supporto del DPO, mette in atto misure tecniche e organizzative adeguate a garantire che siano trattati, per impostazione predefinita, solo i dati personali necessari per ogni specifica finalità del trattamento. Tale obbligo vale per la quantità dei dati personali raccolti, la portata del trattamento, il periodo di conservazione e l'accessibilità.

3.2 Regole specifiche

Regola n.1: Individuazione e limitazione della finalità del trattamento	
a)	Deve essere espressa con chiarezza l'esigenza di <i>business</i> /operativa che comporta 'il trattamento di dati personali (contesto)
b)	Rispetto all'esigenza di <i>business</i> /operativa identificata devono essere espresse con chiarezza le finalità (scopo) per le quali è necessario il trattamento di dati personali.
c)	Per ogni finalità deve essere individuata la base giuridica, tra quelle identificate nell'Art. 6 del Regolamento " <i>Liceità del trattamento</i> ": (i) Consenso dell'interessato; (ii) Esecuzione di un contratto o di misure precontrattuali; (iii) Adempimento di un obbligo legale; (iv) Salvaguardia degli interessi vitali dell'interessato; (v) Compito di interesse pubblico o connesso all'esercizio di pubblici poteri; (vi) Perseguimento del legittimo interesse del Titolare o di terzi.
d)	Per quanto attiene la base giuridica " <i>perseguimento del legittimo interesse del Titolare o di terzi</i> " è necessario effettuare un'analisi specifica e formalizzata sul bilanciamento degli interessi ⁵ . Il Regolamento, infatti, qualifica come presupposto di legittimità del trattamento la sua necessità al fine di consentire il perseguimento del legittimo interesse del Titolare o di terzi purché su questo non prevalgano i diritti e le libertà fondamentali dell'interessato in particolare in caso di minori.
e)	Non devono essere eseguiti trattamenti non compatibili con le finalità e le basi giuridiche di cui sopra. A tale scopo si dovrà tener conto di: (i) Nesso tra le finalità per cui i dati personali sono stati raccolti e le finalità dei trattamenti che si intende avviare; (ii) Contesto in cui i dati personali sono stati raccolti, in particolare relativamente alla relazione tra l'interessato e il Titolare; (iii) Natura dei dati personali, con indicazione delle categorie particolari di dati personali ⁶ oppure dei dati relativi a condanne penali e a reati; (iv) Possibili conseguenze dell'ulteriore trattamento previsto per gli interessati; (v) Esistenza di garanzie adeguate.
f)	Il Gruppo FS Italiane adotta le misure necessarie per assicurare che i sistemi di Intelligenza Artificiale rispettino i diritti fondamentali, affinché lo sviluppo e l'uso degli stessi nel ricorso a trattamenti automatizzati sia conforme alle esigenze attese.

⁵ In linea di principio, è possibile affermare che il legittimo interesse può costituire una base giuridica per il trattamento di dati personali se e nella misura in cui siano soddisfatte determinate condizioni. La valutazione di tali condizioni richiede l'esecuzione, da parte del *Data Manager* con il supporto del DPO, di un test comparativo che può sommariamente riassumersi in tre operazioni principali: 1. l'identificazione del legittimo interesse del titolare/terzo; 2. l'individuazione dell'impatto sui diritti degli interessati; 3. raffronto tra l'interesse del Titolare e i diritti e l'interesse della persona interessata e adozione di eventuali "garanzie ulteriori" in grado di ridurre l'impatto nei confronti degli interessati, anche tenendo conto delle eventuali conseguenze positive del trattamento sui medesimi soggetti.

⁶ Si veda il [Glossario](#) per la definizione di "Categorie particolari di dati personali".



Regola n.2: Minimizzazione dei dati e delle operazioni di trattamento

- a) Deve essere analizzata la possibilità di utilizzare dati non identificabili, ad esempio anonimi⁷, o pseudonimi⁸ o aggregati, in sostituzione dell'utilizzo di dati personali.
- b) Ove non sia possibile procedere con l'utilizzo di dati anonimi o pseudonimi, deve essere esclusa l'acquisizione di dati non strettamente necessari al raggiungimento della finalità prevista dal trattamento (c.d. principio di "pertinenza").
- c) Devono essere limitate al minimo indispensabile le operazioni di trattamento in modo da mantenere un controllo diretto ed efficace sui dati e sulla loro custodia, ad esempio evitando la trasmissione ove non strettamente necessaria e privilegiando la trasmissione verso organizzazioni all'interno dell'UE.
- d) Le persone autorizzate al trattamento devono essere limitate al numero strettamente necessario e istruite rispetto alle operazioni di trattamento.
- e) Devono essere individuati i tempi di conservazione del dato. Tali tempi devono essere ridotti al minimo indispensabile per garantire gli obblighi di legge e le necessità operative/di *business*, compatibilmente con le indicazioni fornite dall'Autorità Garante⁹.
- f) Devono essere distinte le necessità di accesso continuo al dato (*database* gestionali) e le necessità di accesso saltuario a fronte di specifiche richieste (*database* di archiviazione). In quest'ultimo caso, dovrà essere valutato, caso per caso, il processo di accesso e autorizzazione, nonché di relativa tracciatura. I tempi di conservazione sui sistemi gestionali e di *archiving* devono essere distinti.
- g) Nel caso in cui si rilevi l'esigenza di mantenere una base dati per finalità statistiche, andrà valutata la possibilità di rendere i dati personali non identificabili (ad esempio rendendoli anonimi o aggregandoli).
- h) Deve essere evitato, per quanto possibile, l'utilizzo di informatica individuale (ad esempio, fogli di lavoro) per trattamenti che presentino rischi (anche minimi) per i diritti e le libertà delle persone fisiche.
- i) Deve essere evitato, per quanto possibile, l'utilizzo di supporti cartacei per il trattamento di dati personali, preferendo le attività di trattamento e l'archiviazione di dati in formato elettronico.

⁷ Dati privi di elementi identificativi dell'interessato.

⁸ Dati nei quali gli elementi identificativi sono sostituiti da elementi diversi (ad esempio, l'utilizzo di *nickname*) che rendono estremamente difficoltosa l'identificazione.

⁹ Si vedano le linee di indirizzo per la determinazione del periodo di conservazione dei dati personali ([Sezione F](#) del presente documento)



4. Le Regole per la Data Protection By Design

4.1 Regola generale

Tenendo conto dello stato dell'arte e dei costi di attuazione, nonché della natura, dell'ambito di applicazione, del contesto e delle finalità del trattamento, come anche dei rischi aventi probabilità e gravità diverse per i diritti e le libertà delle persone fisiche costituiti dal trattamento, sia al momento di determinare i mezzi del trattamento sia all'atto del trattamento stesso, il *Data Manager*, supportato dal DPO, mette in atto misure tecniche e organizzative adeguate volte ad attuare in modo efficace i principi di protezione dei dati e a integrare nel trattamento le necessarie garanzie al fine di soddisfare i requisiti del Regolamento e tutelare i diritti degli interessati.

4.2 Regole specifiche

Regola n.3: Accountability	
a) Il <i>Data Manager</i> è responsabile di tutte le attività di trattamento svolte dalla propria struttura organizzativa. Tale responsabilità si esercita per il tramite di deleghe a persone autorizzate al trattamento¹⁰. Tale processo necessita di una tracciatura al fine di garantire il rispetto dei ruoli e delle responsabilità assegnate su ciascun trattamento¹¹. b) Nel caso in cui le attività di trattamento siano effettuate da fornitori, il <i>Data Manager</i> ricorre unicamente a fornitori che presentino garanzie sufficienti per mettere in atto misure tecniche e organizzative adeguate in modo tale che il trattamento soddisfi i requisiti del Regolamento e garantisca la tutela dei diritti degli interessati. Al fine di garantire tali requisiti e laddove necessario, il Titolare stipula con i fornitori appositi Accordi di Data Protection¹². c) Per ogni persona autorizzata al trattamento, il <i>Data Manager</i> deve garantire che siano fornite istruzioni in merito al trattamento di dati personali e alle relative responsabilità attribuite. d) Il <i>Data Manager</i>, al fine di rafforzare il principio di “accountability” informa periodicamente le persone autorizzate al trattamento rispetto agli obblighi e alle responsabilità derivanti dai trattamenti ad essi attribuiti.	
Elementi per la progettazione	▪ Definizione dei ruoli delle persone autorizzate al trattamento ▪ Definizione dei ruoli degli Amministratori di Sistema (se applicabile) ▪ Definizione del ruolo di eventuali fornitori che trattano dati personali
Elementi per dimostrare la conformità	▪ Elenco delle persone autorizzate al trattamento ▪ Elenco degli Amministratori di Sistema (se applicabile) ▪ Elenco dei fornitori che trattano dati personali ▪ Documento di <i>pre-assessment</i> e <i>data protection impact assessment</i>

¹⁰ *Data Manager*, Incaricati, Amministratori di Sistema.

¹¹ Si vedano le linee di indirizzo in materia di protezione dei dati personali (DdG in materia di “Modello di Gestione per la Protezione dei Dati Personali”)

¹² Si vedano le linee di indirizzo per la gestione delle terze parti ([Sezione D](#) del presente documento).



Regola n.4: Definizione dell'intero ciclo di vita del dato

- a) Il processo di trattamento deve essere definito lungo l'intero ciclo di vita del dato, descrivendo puntualmente come viene realizzata ogni singola fase (dall'acquisizione alla cancellazione/anonimizzazione).
- b) Le modalità di acquisizione del dato devono essere chiaramente definite e deve essere identificata la fonte (direttamente dall'interessato, da data *provider* interno/esterno, da *device*, etc), ponendo particolare attenzione alla liceità della stessa, ad esempio chiedendo una verifica dell'informativa fornita all'interessato. Il processo di acquisizione del dato deve essere formalizzato.
- c) Nel caso in cui l'acquisizione venga effettuata mediante supporti cartacei (ad esempio con la compilazione di moduli), deve essere definito formalmente il processo per la registrazione, archiviazione e distruzione degli stessi. In ogni caso sono preferibili sistemi elettronici di acquisizione.
- d) Le modalità di consultazione ed estrazione del dato devono essere chiaramente definite. Particolare cautela deve essere rivolta nell'implementare processi organizzativi idonei ad evitare consultazioni ed estrazioni non autorizzate o involontarie (c.d. *data breach*)¹³. L'accesso agli archivi cartacei deve essere disciplinato mediante un apposito processo.
- e) Le modalità di modifica del dato devono essere chiaramente definite. Particolare cautela deve essere rivolta nell'implementare processi organizzativi idonei ad evitare errori e modifiche non autorizzate (c.d. *data breach*), ad esempio implementando, ove possibile, un livello di controllo indipendente sulle modifiche effettuate.
- f) Le modalità di organizzazione, strutturazione e adattamento¹⁴ dei dati (inclusi i dati raccolti su formati cartacei) devono essere chiaramente definite al fine di evitare, per quanto possibile, errori, ridondanze, copie superflue, etc.
- g) Per quanto attiene le operazioni complesse di raffronto e di interconnessione tra basi di dati, devono essere chiaramente definite e devono essere adottate tutte le precauzioni per evitare errori che possano avere ripercussioni sui diritti e sulle libertà degli interessati. Occorre, inoltre, verificare la correttezza del trattamento e la congruenza con le finalità comunicate all'interessato in fase di acquisizione dei dati.
- h) Le modalità di trasmissione dei dati personali devono essere chiaramente definite, così come deve essere chiaramente definito l'utilizzo di tali dati personali da parte dei destinatari.
- i) Le operazioni di conservazione, limitazione¹⁵ e dismissione del dato devono essere chiaramente definite e devono essere stabiliti i processi organizzativi al fine di evitarne la diffusione accidentale o volontaria.
- j) Per ogni operazione di trattamento sopra descritta, deve essere specificata l'esistenza di profili "privilegiati" e "comuni" e le modalità organizzative con le quali tali profili vengono identificati e monitorati.

¹³ Si vedano le linee di indirizzo per la gestione delle violazioni dei dati personali ([Sezione E](#) del presente documento).

¹⁴ Per "Organizzazione" si intende la classificazione di dati secondo un metodo prescelto (ad esempio, organizzazione di una lista per Data di Nascita invece che per Ordine Alfabetico); per "Strutturazione" si intende la ripartizione di dati secondo schemi precisi (ad esempio, definizione di una lista di clienti di Emilia Romagna, Lazio e Toscana all'interno di una nuova classe "Centro Italia"); per "Adattamento" si intende la possibilità di ricavare dati personali da altri dati personali (ad esempio creazione del Codice Fiscale sulla base di Dati identificativi, Data e Luogo di Nascita).

¹⁵ Per "Limitazione" si intende il contrassegno dei dati personali conservati con l'obiettivo di limitarne il trattamento in futuro.



Regola n.4: Definizione dell'intero ciclo di vita del dato

k) Ogni operazione di trattamento sopra descritta, deve essere chiaramente circoscritta all'interno delle istruzioni fornite ai fornitori e alle persone autorizzate al trattamento all'interno dell'organizzazione.

Elementi per la progettazione	▪ Requisiti funzionali della soluzione informatica per ogni fase del ciclo di vita del dato oppure definizione del processo di gestione dei supporti cartacei ▪ Termini e criteri di <i>retention</i> del dato
Elementi per dimostrare la conformità	▪ Istruzioni fornite alle persone autorizzate al trattamento ▪ Istruzioni fornite ai fornitori (Accordi di <i>Data Protection</i>) ▪ Elenco dei destinatari dei dati personali (se applicabile) ▪ Elenco dei paesi extra-UE verso i quali i dati sono trasferiti (se applicabile) ▪ Elenco degli strumenti IT utilizzati (ad esempio: PC, laptop, etc.)

Regola n.5: Trasparenza nei confronti dell'interessato¹⁶

- a)** Nel caso in cui sia effettuato un trattamento di dati personali, all'atto della progettazione del trattamento devono essere identificate le modalità con le quali informare in maniera chiara e comprensibile l'interessato circa le finalità e le caratteristiche del trattamento, nonché sulle modalità di esercizio dei propri diritti. Particolare attenzione deve essere riservata alle informative da fornire in fase di acquisizione di dati personali tramite sistemi video e *device* (ad esempio, *cookies*) e sui trattamenti per i quali l'acquisizione avvenga mediante nuove tecnologie.
- b)** Nel caso in cui il trattamento sia effettuato su dati già acquisiti, deve essere verificato che l'informativa fornita all'interessato sia congruente con le finalità del nuovo trattamento.
- c)** Le informative fornite all'interessato devono essere redatte secondo i *template* di Gruppo, al fine di riportare tutte le informazioni obbligatorie ai sensi del Regolamento. Bisogna verificare inoltre il funzionamento, l'aggiornamento e il presidio delle modalità di contatto indicate in informativa.
- d)** Le informative devono essere fornite in maniera chiara, semplice, esplicita e facilmente accessibile (font adeguati, illuminazione sufficiente, percorsi lineari sui siti internet, sezioni dedicate, etc.). Nel caso in cui, per motivi di spazio e leggibilità, l'informativa sia articolata su un livello sintetico che rimanda ad un livello esteso, le modalità di accesso a quest'ultimo devono essere chiaramente descritte.
- e)** Nel caso in cui il trattamento preveda ragionevolmente l'acquisizione di dati personali da parte di interessati non italiani, deve essere prevista una traduzione dell'informativa (almeno in lingua inglese).
- f)** Oltre alle informative redatte ai sensi degli artt. 13 e 14 del Regolamento, devono essere valutate le ulteriori occasioni di contatto in cui è possibile rafforzare la presa di coscienza da parte dell'interessato in merito al trattamento dei suoi dati personali (ad es. si può valutare la possibilità di realizzare un breve video per spiegare al dipendente come vengono gestiti i suoi dati rispetto al processo di valutazione delle *performance*).
- g)** Per i trattamenti basati sul consenso dell'interessato, il consenso deve essere espresso mediante un atto positivo inequivocabile con il quale l'interessato manifesta l'intenzione di accettare il trattamento dei dati personali che lo riguardano.

¹⁶ Si vedano le linee di indirizzo per la gestione dei diritti degli interessati ([Sezione C](#) del presente documento).



h) Devono essere previsti processi organizzativi idonei a dimostrare che l'interessato ha preso visione dell'informativa ed ha, eventualmente, prestato il consenso al trattamento. Nel caso di informativa cartacea, devono essere stabilite le modalità di archiviazione e recupero.	
Elementi per la progettazione	▪ Se richiesta in progettazione, definizione delle modalità con cui è resa disponibile l'informativa e archivia la presa visione (ove possibile, in digitale) ▪ Se richiesto in progettazione, definizione delle esigenze di raccolta dei consensi e <i>Consent Management Life Cycle</i>. Per la raccolta in digitale previsione di: (i) registrazione con <i>timestamp</i>; (ii) conservazione per il tempo di validità richiesto; (iii) modalità di estrazione dei consensi; (iv) conservazione della cronologia completa dei log di modifica dei consensi
Elementi per dimostrare la conformità	Testo dell'informativa e modalità di archiviazione se previsto supporto cartaceo

Regola n.6: Correttezza dei dati

a) Devono essere previsti, ove possibile, controlli automatici rispetto alla qualità e congruità dei dati acquisiti (ad es. devono essere preferiti campi controllati rispetto a campi di solo testo, ove possibile le anagrafiche devono essere confrontate con elenchi certificati). b) Devono essere previste misure adeguate (es. monitoraggio periodico) per la cancellazione e la rettifica tempestiva di eventuali dati personali inesatti. c) Nel caso in cui i dati vengano registrati su supporti informatici partendo da acquisizione audio o da moduli in cartaceo, devono essere previsti, ove possibile, sistemi a tutela della correttezza della registrazione.	
Elementi per la progettazione	Definizione dei controlli di tipo tecnico o procedurale per assicurare la correttezza del dato
Elementi per dimostrare la conformità	Da determinare caso per caso con il supporto del DPO

Regola n.7: Garantire l'esercizio dei diritti da parte dell'interessato

a) Deve essere individuato un processo interno alla struttura che effettua il trattamento per la gestione delle richieste di esercizio dei diritti da parte degli interessati¹⁷. b) Nel caso di richieste complesse e numerose, occorre predisporre soluzioni informatiche che garantiscano la corretta gestione delle stesse.	
Elementi per la progettazione	Definizione delle caratteristiche tecniche della soluzione informatica per la gestione delle richieste di esercizio dei diritti: (i) tracciato record dei dati personali oggetto del trattamento; (ii) tabelle dei database in cui sono memorizzati i dati personali oggetto del trattamento; (iii) istruzioni da eseguire operativamente sulla soluzione informatica (ad esempio: <i>script</i> per l'accesso o la cancellazione); (iv) <i>template</i> per l'estrazione dei dati in formato elettronico di uso comune (ad esempio, <i>excel</i>)

¹⁷ Si vedano le linee di indirizzo sulla gestione dei diritti degli interessati ([Sezione C](#) del presente documento).



Elementi per dimostrare la conformità	Elenco dei canali predisposti e degli eventuali <i>template</i> per l'esercizio dei diritti esercitabili dagli interessati
---------------------------------------	--

Regola n.8: Security by design

- a) La progettazione delle attività di trattamento può prevedere l'utilizzo di *tool* o supporti informatici. Tali *tool* vengono identificati in maniera preliminare sulla base di alcuni parametri quali, ad esempio: numero di interessati, profondità dei dati associati a ciascun interessato, complessità delle operazioni di trattamento, necessità di interconnessione tra sistemi, frequenza dei trattamenti, acquisizione dei dati direttamente dall'interessato e gestione dei consensi.
- b) Gli elementi di cui sopra determinano una scelta di massima sul supporto informatico da utilizzare per il trattamento, ad esempio file *excel* per il mantenimento di una rubrica, un sistema in *cloud* per la gestione delle buste paga, etc.
- c) I supporti utilizzati per le attività di trattamento devono essere predisposti in modo da garantire nativamente i principi di *data protection by default e by design*, per come definiti nel presente documento. Ad esempio, se vengono acquisiti dei consensi, la soluzione informatica deve essere in grado di registrare correttamente il consenso, di garantirne la non alterabilità e permettere all'interessato la rettifica del medesimo; la soluzione informatica deve, inoltre, essere in grado nativamente di consentire l'esercizio dei diritti da parte degli interessati, ad esempio prevedendo l'estrazione dei dati in un formato portabile.
- d) L'attività di *pre-assessment* e l'eventuale *Data Protection Impact Assessment*¹⁸ determinano le misure di sicurezza tecnico-organizzative da applicare al supporto informatico. Possono determinare, inoltre, anche un cambiamento rispetto alla tipologia di supporto o l'aggiunta di misure protettive ad un supporto informatico esistente.
- e) Le misure tecnico-organizzative applicabili ai supporti informatici, declinate per tipologia di supporto e per livello di protezione, sono definite per il Gruppo e disponibili sulla *intranet* aziendale.
- f) Le determinazioni dei passaggi precedenti devono costituire parte integrante della documentazione di progetto della soluzione informatica.

Elementi per la progettazione	▪ Se la progettazione è relativa ad una nuova soluzione informatica, set di misure di sicurezza da adottare in funzione del livello di rischio del trattamento a livello infrastrutturale ed applicativo ▪ Eventuali misure non implementabili e relativi <i>workaround</i>
Elementi per dimostrare la conformità	▪ Set di misure di sicurezza adottate in funzione del livello di rischio del trattamento a livello infrastrutturale ed applicativo ▪ Documento di <i>pre-assessment</i> e <i>data protection impact assessment</i> ▪ Eventuali misure non implementabili e relativi <i>workaround</i>

¹⁸ Si vedano le linee di indirizzo per l'identificazione dei trattamenti a potenziale rischio elevato e *data protection impact assessment* ([Sezione B](#) del presente documento).



SEZIONE B

TRATTAMENTI A RISCHIO ELEVATO E DATA PROTECTION IMPACT ASSESSMENT



SEZIONE B.....	19
1. TRATTAMENTI A RISCHIO ELEVATO E DATA PROTECTION IMPACT ASSESSMENT.....	21
1.1 PREMessa E DEFINIZIONI.....	21
1.2 LA DPIA COME STRUMENTO DI CONTROLLO SULL'OSSERVANZA DEL REGOLAMENTO.....	22
1.3 AMBITO DI APPLICAZIONE DELLA DPIA ED ECCEZIONI	22
2. IL PROCESSO DI IDENTIFICAZIONE DEI TRATTAMENTI A RISCHIO ELEVATO E DPIA.....	24
2.1 FASE A – DATA PROTECTION PRE-ASSESSMENT	24
2.2 FASE B – DATA PROTECTION IMPACT ASSESSMENT.....	27
3. LA METODOLOGIA PER L'IDENTIFICAZIONE DEI TRATTAMENTI A RISCHIO ELEVATO E DPIA	29
3.1 NOTA METODOLOGICA PER L'ESECUZIONE DEL DATA PROTECTION PRE-ASSESSMENT	29
3.1.1 VERIFICHE IN MERITO AL RISPETTO DEI PRINCIPI BASE DEL REGOLAMENTO	29
3.1.2 CRITERI PER LA DETERMINAZIONE DEI TRATTAMENTI A RISCHIO ELEVATO	30
3.1.3 PRESENZA DI EVENTUALI ECCEZIONI	32
3.2 NOTA METODOLOGICA PER L'ESECUZIONE DEL DATA PROTECTION IMPACT ASSESSMENT	33
3.2.1 VALUTAZIONE DI ADEGUATEZZA DELLE MISURE DI SICUREZZA TECNICHE ED ORGANIZZATIVE	33
3.2.2 RISK ASSESSMENT.....	33
3.2.3 DETERMINAZIONE DELLE MISURE DI SICUREZZA ADEGUATE AL RISCHIO E PIANO DI MITIGAZIONE	36
INDICE DELLE FIGURE	88
INDICE DELLE TABELLE	88
GLOSSARIO	89



1. Trattamenti a rischio elevato e Data Protection Impact Assessment

1.1 Premessa e definizioni

Il Regolamento UE 679/2016 (anche “GDPR”) introduce all’Art. 35 l’obbligatorietà per il Titolare di condurre “una valutazione dell’impatto dei trattamenti previsti sulla protezione dei dati personali” (*Data Protection Impact Assessment* o DPIA nel seguito del presente documento) per i trattamenti che presentano “un rischio elevato per i diritti e le libertà delle persone fisiche”¹⁹.

Nel dettaglio, è opportuno che il Titolare del trattamento effettui una valutazione d’impatto sulla protezione dei dati **prima dell’avvio del trattamento di dati personali** “per valutare la particolare probabilità e gravità del rischio, tenuto conto della natura, dell’ambito di applicazione, del contesto e delle finalità del trattamento e delle fonti di rischio. La valutazione di impatto dovrebbe vertere, in particolare, anche sulle misure, sulle garanzie e sui meccanismi previsti per attenuare tale rischio assicurando la protezione dei dati personali e dimostrando la conformità al regolamento” (Considerando 90 del Regolamento).

I titolari sono quindi tenuti non soltanto a garantire l’osservanza delle disposizioni del Regolamento, ma anche a dimostrare adeguatamente in che modo garantiscono tale osservanza. La DPIA rappresenta uno degli adempimenti necessari per dimostrare la conformità al Regolamento e per garantire il rispetto del principio di *accountability*. Permette, infine, di realizzare concretamente un altro fondamentale principio fissato nel Regolamento, ossia la protezione dei dati *by design e by default* di qualsiasi trattamento. Per i nuovi trattamenti, infatti, sono le regole stabilite nelle linee di indirizzo per la *Data Protection by Design e by Default*²⁰ a rappresentare lo strumento prevalente di mitigazione del rischio, demandando alle attività di DPIA un ruolo di controllo e di documentabilità del processo.

Oltre che sulle nuove operazioni di trattamento, l’obbligo di svolgere una DPIA si applica anche alle **operazioni di trattamento esistenti** per le quali vi è stata una **variazione delle modalità di trattamento**²¹ che possono presentare un rischio elevato per i diritti e le libertà delle persone fisiche.

¹⁹ Con “diritti e libertà” degli interessati si fa riferimento principalmente ai diritti alla protezione dei dati e alla vita privata, ma anche altri diritti fondamentali quali la libertà di parola, la libertà di pensiero, la libertà di circolazione, il divieto di discriminazione, il diritto alla libertà di coscienza e di religione.

²⁰ Si vedano le linee di indirizzo per la *data protection by design e by default* ([Sezione A](#) del presente documento).

²¹ Ciò significa che qualsiasi trattamento di dati le cui condizioni di attuazione (ambito di applicazione, finalità, dati personali raccolti, identità dei titolari del trattamento o dei destinatari, periodo di conservazione dei dati, misure tecniche e organizzative, ecc.) sono mutate rispetto alla prima verifica effettuata dall’Autorità di controllo o dal DPO e che possono presentare un rischio elevato devono essere soggette a DPIA. Devono essere inoltre soggetti a DPIA i trattamenti di dati personali che hanno subito una variazione dei rischi, ad esempio perché è entrata in uso una nuova tecnologia, perché i dati personali vengono utilizzati per una finalità diversa, perché il contesto organizzativo o sociale per l’attività di trattamento è mutato, perché gli effetti di determinate decisioni automatizzate sono diventati più significativi oppure perché nuove categorie di interessati sono diventati vulnerabili a specifiche discriminazioni.



Le presenti linee di indirizzo disciplinano le informazioni, le modalità operative di individuazione dei trattamenti sui quali condurre una DPIA e la metodologia da applicare²², nonché i ruoli e responsabilità delle figure organizzative coinvolte.²³

1.2 La DPIA come strumento di controllo sull'osservanza del Regolamento

La DPIA è uno strumento fondamentale ai fini del miglioramento continuo e per mantenere costantemente adeguato il livello di protezione dei dati. È per tale motivazione che, all'interno del Gruppo FS Italiane, **la DPIA è utilizzata anche quale strumento di controllo di secondo livello e consente ai DPO del Gruppo il riesame continuo e regolare delle attività di trattamento in corso**. Di conseguenza, anche se una valutazione d'impatto sulla protezione dei dati non è strettamente obbligatoria ai sensi del Regolamento, al momento opportuno, il Titolare del trattamento sarà tenuto a svolgere tale valutazione nel contesto dei suoi obblighi generali di *accountability*. Per i trattamenti già esistenti, è il DPO – nell'ambito delle sue attività di sorveglianza – a richiedere ai *Data Manager* l'avvio delle attività di *assessment* in un'ottica di monitoraggio continuo.

1.3 Ambito di applicazione della DPIA ed eccezioni

Un'attività di Data Protection Impact Assessment riguarda generalmente un unico trattamento dei dati. Tuttavia, l'articolo 35, Par. 1, indica che *"una singola valutazione può esaminare un insieme di trattamenti simili che presentano rischi elevati analoghi"*. **Si può quindi ricorrere ad una singola valutazione d'impatto sulla protezione dei dati nel caso di trattamenti simili tra loro** in termini di natura, ambito di applicazione, contesto, finalità e rischi. Ad esempio, un gestore ferroviario (un Titolare del trattamento) potrebbe esaminare la videosorveglianza in tutte le sue stazioni ferroviarie realizzando una singola DPIA. Ciò può essere applicabile anche a trattamenti simili attuati da vari titolari. In questi casi, è necessario fornire una giustificazione per la realizzazione di una singola DPIA²⁴.

Qualora il trattamento coinvolga contitolari del trattamento, questi ultimi devono definire con precisione le rispettive competenze. La loro DPIA deve stabilire quale parte sia competente per le varie misure volte a trattare i rischi e a proteggere i diritti e le libertà degli interessati. Ciascun Titolare del trattamento deve esprimere le proprie esigenze e condividere informazioni utili senza compromettere eventuali segreti aziendali, proprietà intellettuale, informazioni aziendali riservate etc. o divulgare vulnerabilità.

²² In linea con i criteri suggeriti dall'ex *Article 29 Working Party* e con gli standard internazionali sulla gestione del rischio (ISO 31000 e COSO *Framework*), il Gruppo FS Italiane adotta una metodologia di tipo *risk-based* volto ad assicurare la minimizzazione dei rischi per i diritti e le libertà delle persone fisiche, garantendo al contempo la compliance al Regolamento sulla base di controlli distribuiti fra linea (controlli di primo livello effettuati dalle strutture di Business/Operative) e funzioni di controllo (controlli di secondo livello effettuati dal DPO e di terzo livello effettuati dall'Internal Audit).

²³ A norma del Regolamento, l'inosservanza dei requisiti stabiliti per la DPIA può portare a sanzioni pecuniarie imposte dall'Autorità di controllo competente. La mancata esecuzione di una DPIA nei casi in cui il trattamento è soggetto alla stessa (Art. 35, Par. 1, 3 e 4), l'esecuzione in maniera errata di detta valutazione (Art. 35, Par. 2 e da 7 a 9) oppure la mancata consultazione dell'autorità di controllo laddove richiesto (Art. 36, Par. 3, lettera e), possono comportare una sanzione amministrativa pecuniaria fino al 2% del fatturato annuo globale dell'anno precedente.

²⁴ Si veda WP248 – *Working Party 29 – Guidelines on Data Protection Impact Assessment (DPIA) and determining whether processing is "likely to result in a high risk" for the purposes of Regulation 2016/679*



Una DPIA può essere altresì utile per valutare l'impatto sulla protezione dei dati di un prodotto tecnologico, ad esempio un dispositivo *hardware* o un *software*, qualora sia probabile che lo stesso venga utilizzato da titolari del trattamento distinti per svolgere tipologie diverse di trattamento. Ovviamente, il Titolare che utilizza detto prodotto resta soggetto all'obbligo di svolgere la propria DPIA in relazione all'attuazione specifica, tuttavia tale valutazione del Titolare può essere basata sulle informazioni fornite da una valutazione analoga preparata dal fornitore del prodotto (Responsabile del trattamento), se opportuno.

L'ex *Article 29 Working Party* (ora *European Data Protection Board*), all'interno delle proprie linee guida in materia di valutazione d'impatto sulla protezione dei dati²⁵ ritiene **non necessaria la DPIA nei seguenti casi** (nel seguito del documento anche "**eccezioni**"):

1. quando il trattamento non è tale da "*presentare un rischio elevato per i diritti e le libertà delle persone fisiche*" (Art. 35, Par. 1);
2. quando la natura, l'ambito di applicazione, il contesto e le finalità del trattamento sono molto simili a un trattamento per il quale è stata svolta una valutazione d'impatto sulla protezione dei dati. In tali casi, si possono utilizzare i risultati della valutazione d'impatto sulla protezione dei dati per un trattamento analogo (Art. 35, Par. 1);
3. quando le tipologie di trattamento sono state verificate da un'autorità di controllo prima del maggio 2018 in condizioni specifiche che non sono cambiate²⁶;
4. qualora un trattamento, effettuato a norma dell'Art. 6, Par. 1, lettere c) o e), trovi una base giuridica nel diritto dell'Unione o nel diritto dello Stato membro, tale diritto disciplini il trattamento specifico o sia già stata effettuata una valutazione d'impatto sulla protezione dei dati nel contesto dell'adozione di tale base giuridica (Art. 35, Par. 10), a meno che uno Stato membro non abbia dichiarato che è necessario effettuare tale valutazione prima di procedere alle attività di trattamento;
5. qualora il trattamento sia incluso nell'elenco *facoltativo* (stabilito dall'Autorità di controllo) delle tipologie di trattamento per le quali non è richiesta alcuna valutazione d'impatto sulla protezione dei dati (Art. 35, Par. 5)²⁷.

Le Autorità di controllo sono tenute a stabilire e rendere pubblico un elenco delle tipologie di trattamento che richiedono una DPIA (Art. 35, Par. 4). L'elenco è disponibile sul sito del Garante per la Protezione dei Dati Personali.

²⁵ https://ec.europa.eu/newsroom/article29/item-detail.cfm?item_id=611236

²⁶ "le decisioni della Commissione e le autorizzazioni delle autorità di controllo basate sulla direttiva 95/46/CE rimangono in vigore fino a quando non vengono modificate, sostituite o abrogate" (considerando 171).

²⁷ Tale elenco può contenere attività di trattamento conformi alle condizioni specificate da detta autorità, in particolare attraverso linee guida, decisioni o autorizzazioni specifiche, norme di conformità, ecc. (ad esempio in Francia, autorizzazioni, esenzioni, norme semplificate, pacchetti di conformità, ecc.). In tali casi e a condizione che venga eseguita una nuova valutazione da parte dell'autorità di controllo competente, non è richiesta una valutazione d'impatto sulla protezione dei dati, ma soltanto se il trattamento rientra a tutti gli effetti nel campo di applicazione della procedura pertinente menzionata nell'elenco e continua a rispettare pienamente tutti i requisiti pertinenti del regolamento generale sulla protezione dei dati.



2. Il processo di identificazione dei trattamenti a rischio elevato e DPIA

Il processo di identificazione dei trattamenti a rischio elevato e DPIA prevede due macro-fasi, sintetizzate in **Figura 3** e descritte nel seguito del documento:

- **Fase A – Data Protection pre-assessment**
- **Fase B – Data Protection Impact Assessment**

La responsabilità dell'intero processo di *assessment* resta in carico al Titolare che la esercita affidandone le attività al *Data Manager*, con il necessario supporto del DPO. Il DPO, d'accordo con il *Data Manager*, potrà valutare la necessità di costituire un Gruppo di Lavoro composto da strutture specialistiche e generalmente costituito dal soggetto tecnico di riferimento per i sistemi informativi e dal soggetto tecnico di riferimento per la *Cyber Security*²⁸.

Nel caso di trattamenti che vengano effettuati con l'ausilio di/in accordo con una Terza Parte (ad esempio, un *outsourcer*) il Gruppo di Lavoro viene integrato con un rappresentante della Terza Parte.

2.1 **Fase A – Data Protection pre-assessment**

Obiettivo della Fase A è verificare se il trattamento *“può presentare un rischio elevato per i diritti e le libertà delle persone fisiche”*. In questa fase è valutata, inoltre, la *compliance* del trattamento rispetto ai principi fondamentali stabiliti dal Regolamento e dal nuovo Codice Privacy. In funzione degli esiti di tali verifiche, si stabilisce se sul trattamento deve essere condotta o meno una DPIA (**Fase B – Data Protection Impact Assessment**).

In questa fase, il *Data Manager*, rilevata l'esigenza di *business*/operativa che comporta il trattamento (o di modifica al trattamento) di dati personali, sottopone l'iniziativa al DPO. Quest'ultimo, con l'eventuale ausilio del Gruppo di Lavoro, verifica **(i)** il rispetto dei principi base del Regolamento, **(ii)** i criteri per la determinazione dei trattamenti a rischio elevato, **(iii)** la presenza di eventuali “eccezioni” (si veda **Par. 3.1 - Nota metodologica per l'esecuzione del Data Protection pre-assessment** per le note metodologiche).

A seguito delle suddette verifiche:

- qualora il trattamento non risulti conforme al Regolamento, il *Data Manager* dovrà procedere con la revisione del trattamento e/o l'adozione di misure idonee a garantire il rispetto dei principi base del Regolamento, prima di sottoporre nuovamente l'iniziativa al DPO;
- qualora il trattamento risulti conforme al Regolamento e non si ravvisi la presenza di rischi elevati, il *Data Manager* potrà procedere con l'avvio del trattamento, previa l'adozione delle eventuali indicazioni fornite dal DPO e il censimento sul Registro dei Trattamenti;
- qualora il trattamento non rientri tra le “eccezioni” stabilite dal Regolamento (si veda **Par. 1.3 - Ambito di applicazione della DPIA ed eccezioni**) e presenti rischi elevati, il *Data Manager* dovrà procedere con la **Fase B – Data Protection Impact Assessment**.

In tutti i casi, le indicazioni del DPO, le proposte di revisione del trattamento e/o delle misure di sicurezza ed eventuali ulteriori opportunità di miglioramento sono formalizzate all'interno di un piano di mitigazione, la cui attuazione sarà periodicamente monitorata dal DPO.

²⁸ Se necessario, il DPO può estendere la composizione del Gruppo di Lavoro ad altre strutture organizzative in funzione del trattamento oggetto di analisi.



Tutte le suddette evidenze sono riportate nel documento di “*Data Protection Pre-Assessment*”, compilato dal DPO e approvato dal *Data Manager*, secondo il *template* riportato sulla intranet aziendale nella sezione *Data Protection*. Ove necessario, il documento dovrà riportare specificamente le eventuali indicazioni di *compliance* fornite dal DPO e disattese, e le motivazioni per cui il *Data Manager* ha ritenuto di non conformarsi a tali indicazioni. Il documento di *pre-assessment* è conservato a cura del DPO e del *Data Manager*²⁹.

²⁹ Nei casi in cui il trattamento risulti palesemente privo di rischi per i diritti e le libertà degli interessati, non è necessaria la formalizzazione secondo il *template* fornito ma è sufficiente tenere traccia della decisione assunta (ad es. e-mail o altra documentazione aziendale)

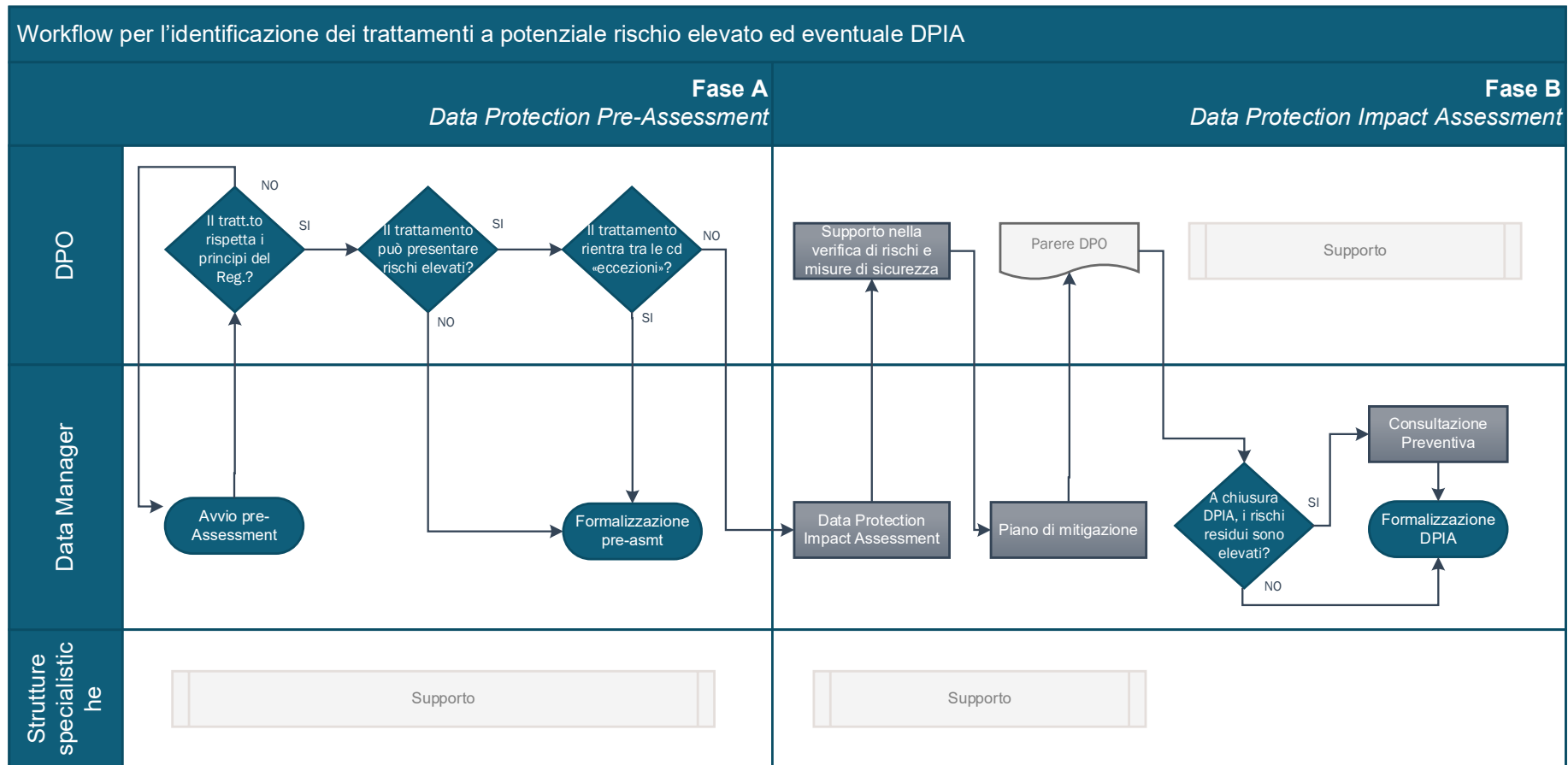


Figura 3 – Workflow per l'identificazione dei trattamenti a potenziale rischio elevato ed eventuale DPIA



2.2 Fase B – Data Protection Impact Assessment

Obiettivo della fase di *Data Protection Impact Assessment* è verificare, per i trattamenti che si ritiene possano presentare “rischi elevati” sulla base delle valutazioni emerse in **Fase A – Data Protection pre-assessment**, la *compliance* rispetto a due pilastri cardine fissati dal Regolamento:

- i diritti e le libertà degli interessati sono “non negoziabili”, sono stabiliti dalla legge e devono essere rispettati, indipendentemente dalla natura, dalla gravità e dalla probabilità di accadimento dei rischi;
- la gestione dei rischi connessi all'utilizzo dei dati personali necessita dell'individuazione e valutazione di idonee misure tecniche ed organizzative di *data protection*, tali da consentire di ridurre i rischi per l'interessato.

Al fine di assicurare la conformità a tali principi, il DPO, con l'eventuale ausilio del Gruppo di Lavoro, supporta il *Data Manager* nella valutazione: **(i)** dell'adeguatezza delle misure di sicurezza tecniche ed organizzative previste nella progettazione; **(ii)** della probabilità e dell'impatto dei rischi (*risk assessment*) in termini di riservatezza, integrità e disponibilità dei dati personali trattati (si veda **Par. 3.2 - Nota metodologica per l'esecuzione del Data Protection Impact Assessment** per le note metodologiche).

Tali valutazioni tengono conto di eventuali attività di *assessment* condotte da altre strutture di controllo (ad esempio, attività di *Information Impact Assessment*) e, a loro volta, contribuiscono ad ulteriori attività di controllo che dovessero essere attivate sugli stessi temi.

A seguito delle suddette valutazioni, se le misure di sicurezza tecnico-organizzative non risultano adeguate ai rischi del trattamento, il *Data Manager* individuerà – con il supporto del DPO e del Gruppo di Lavoro – le misure adeguate a ridurre i rischi del trattamento e formalizzerà un piano di mitigazione. Il piano di mitigazione potrà prevedere, tra le altre misure:

- il riesame del trattamento e/o delle misure di sicurezza tecniche ed organizzative;
- la raccolta dell'opinione degli interessati o dei loro rappresentanti sul trattamento previsto (ad es. organizzazioni sindacali).

A seguito della formalizzazione del piano di mitigazione, il DPO esprime un parere sulle attività di trattamento. Ove necessario, il parere del DPO dovrà riportare specificamente le eventuali indicazioni di *compliance* fornite e disattese, e le motivazioni per cui il *Data Manager* ha ritenuto di non conformarsi a tali indicazioni.

Se la DPIA e/o il conseguente piano di mitigazione non consentono di identificare o attenuare sufficientemente i rischi per i diritti e le libertà delle persone fisiche, il Titolare, prima dell'avvio del trattamento, è tenuto a rinunciare al trattamento oppure a consultare l'Autorità di controllo (c.d. “Consultazione Preventiva” ai sensi dell'Art. 36 del Regolamento). La consultazione è effettuata a cura del DPO³⁰.

Tutte le evidenze emerse in fase di DPIA e dell'eventuale Consultazione Preventiva³¹ sono riportate nel documento di “*Data Protection Impact Assessment*”, compilato dal DPO e approvato dal *Data Manager*, secondo il *template* riportato sulla intranet aziendale nella sezione *Data Protection*. Il documento di DPIA è conservato a cura del DPO e del *Data Manager*. Alla chiusura della DPIA, devono essere attivate dal *Data Manager* le

³⁰ Come da indicazioni della DdG in materia di “Modello di Gestione per la Protezione dei Dati Personali”, il DPO societario consulta preventivamente il DPO di FS SpA in tutte le occasioni di contatto con l'Autorità Garante.

³¹ Si specifica che potrebbero essere necessarie delle iterazioni delle fasi descritte, al fine di ottenere un trattamento con livelli di sicurezza tali da consentire il raggiungimento di un livello di rischio accettabile



progettualità necessarie per rendere operativo il trattamento e le eventuali indicazioni emerse (Piano di Mitigazione). Dovrà comunque essere garantito un monitoraggio costante delle azioni previste nel Piano di Mitigazione a cura del DPO.

Il *Data Manager* monitora tutte le eventuali modifiche intervenute sul trattamento (rispetto al contesto, alle misure di controllo, ai rischi, etc.). In caso di cambiamenti significativi al trattamento, il *Data Manager* valuta se procedere alla revisione della DPIA con il supporto del DPO.



3. La metodologia per l'identificazione dei trattamenti a rischio elevato e DPIA

3.1 Nota metodologica per l'esecuzione del Data Protection pre-assessment

Nei paragrafi successivi sono riassunti gli elementi che sono oggetto di verifica e valutazione in fase di *Data Protection Pre-Assessment* (**Fase A – Data Protection pre-assessment**):

- (i) verifiche sul rispetto dei principi base del Regolamento
- (ii) analisi dei criteri per la determinazione dei trattamenti a rischio elevato
- (iii) presenza di eventuali “eccezioni”

3.1.1 Verifiche in merito al rispetto dei principi base del Regolamento

In questa fase vengono effettuate verifiche su criteri di necessità e proporzionalità del trattamento e sulle cautele adottate a tutela dei diritti e delle libertà degli interessati. In particolare, sono verificate tutte le regole di *Data Protection by Design e by Default* previste dalle linee di indirizzo in materia ([Sezione A](#)) e sintetizzate di seguito:

- [Regola n. 1: Limitazione delle finalità di trattamento](#)
- [Regola n. 2: Minimizzazione dei dati e delle operazioni di trattamento](#)
- [Regola n. 3: Accountability](#)
- [Regola n. 4: Definizione dell'intero ciclo di vita del dato](#)
- [Regola n. 5: Trasparenza nei confronti dell'interessato](#)
- [Regola n. 6: Correttezza dei dati](#)
- [Regola n. 7: Garantire l'esercizio dei diritti da parte dell'interessato](#)
- [Regola n. 8: Security by design](#)

In questa fase vengono inoltre verificati: gli adempimenti rispetto a persone autorizzate al trattamento e rapporti con le terze parti (responsabili, contitolari e titolari autonomi), la presenza di trasferimenti di dati extra-UE e, se del caso, l'adeguatezza dei destinatari e il rispetto degli obblighi introdotti dal Regolamento in materia (Capo V, Artt. dal 44 al 50 del Regolamento), la necessità di attività formative/*awareness*.

Rispetto a ciascuno dei suddetti elementi, che dovranno essere chiariti e descritti dal *Data Manager*, il DPO esprime una valutazione di conformità al Regolamento, nelle seguenti formule:

- Conformità
- Conformità con opportunità di miglioramento
- Conformità parziale
- Non conformità

Le opportunità di miglioramento e le azioni di *remediation* rispetto alle conformità parziali e alle non conformità sono formalizzate all'interno del piano di mitigazione presente nei documenti di *pre-assessment* e/o DPIA.



3.1.2 Criteri per la determinazione dei trattamenti a rischio elevato

In questa fase sono valutate le condizioni che rendono un trattamento di dati personali potenzialmente “a rischio elevato” stabilendo pertanto, se sul trattamento debba essere condotto un *Data Protection Impact Assessment*. La valutazione di tali condizioni è effettuata a partire dai 9 criteri stabiliti dalle Linee Guida dell’*Article 29 Working Party*³² sintetizzate nella **Tabella 1**. Il DPO di FS SpA mette inoltre a disposizione una *checklist* esemplificativa a supporto di tale analisi, disponibile sulla intranet aziendale nella sezione *Data Protection*.

I 9 criteri dovranno essere valutati come **(i)** non attivo, **(ii)** attivo, **(iii)** potenzialmente attivabile. In quest’ultimo caso, si fa riferimento alle situazioni in cui solo occasionalmente si verificano le condizioni per l’attivazione del criterio.

L’*Article 29 Working Party* specifica che quanto maggiore è il numero dei criteri soddisfatti da un determinato trattamento, tanto maggiore è la probabilità che esso presenti rischi elevati per i diritti e le libertà degli interessati e, quindi, che si renda necessaria una DPIA indipendentemente dalle misure che il *Data Manager* intende adottare.

La DPIA deve essere effettuata obbligatoriamente nel caso di attivazione di almeno due criteri. Tuttavia, in taluni casi (novità del trattamento, sensibilità dei dati trattati, numerosità dei dati trattati, frequenza del trattamento e, più in generale, su indicazione del DPO) il *Data Manager* può ritenere opportuno effettuare una DPIA anche nei casi in cui sia attivato un solo criterio o non ne sia attivato alcuno.

Tabella 1 – *Criteri per la determinazione dei trattamenti a rischio elevato*

Criterio n.1: Trattamento valutativo o di <i>scoring</i>
Trattamenti valutativi o di <i>scoring</i>, compresa la profilazione e le attività predittive, in particolare a partire da “<i>aspetti riguardanti il rendimento professionale, la situazione economica, la salute, le preferenze o gli interessi personali, l’affidabilità o il comportamento, l’ubicazione o gli spostamenti dell’interessato</i>”. <u>Esempi/Chiarimenti 29WP</u>: istituto finanziario che effettui lo <i>screening</i> dei propri clienti utilizzando un database di rischio creditizio ovvero un database per la lotta alle frodi o al riciclaggio e al finanziamento del terrorismo [...]. Una società che crei profili comportamentali o di <i>marketing</i> a partire dalle operazioni o dalla navigazione compiute sul proprio sito <i>web</i>. <u>Altri esempi</u>: una Società che crei profili comportamentali in funzione dei tragitti effettuati nel corso dell’ultimo anno per finalità di marketing.
Criterio n.2: Decisioni automatizzate
Decisioni automatizzate che producono significativi effetti giuridici o di analoga natura: trattamenti finalizzati ad assumere decisioni su interessati che producano “<i>effetti giuridici sulla persona fisica</i>” ovvero che “<i>incidono in modo analogo significativamente su dette persone fisiche</i>”. <u>Esempi/Chiarimenti 29WP</u>: Il trattamento può comportare l’esclusione di una persona fisica da determinati benefici ovvero la sua discriminazione. Il trattamento che produce effetti minimi o nulli su un interessato non soddisfa questo specifico criterio.

³² Si veda WP248 – *Working Party 29 – Guidelines on Data Protection Impact Assessment (DPIA) and determining whether processing is “likely to result in a high risk” for the purposes of Regulation 2016/679*



Criterio n.3: Monitoraggio sistematico

Trattamenti utilizzati per osservare, monitorare o controllare gli interessati, compresa la raccolta di dati attraverso reti o *“la sorveglianza sistematica di un’area accessibile al pubblico”*.

Esempi/Chiarimenti 29WP: Questa tipologia di monitoraggio costituisce un criterio, ai fini della DPIA, in quanto la raccolta di dati personali può avvenire in circostanze tali da non consentire agli interessati di comprendere chi vi stia procedendo e per quali finalità. È talora impossibile per gli interessati sottrarsi a questa tipologia di trattamenti in aree pubbliche (o pubblicamente accessibili).

Criterio n.4: Categorie particolari di dati personali e dati relativi a condanne e reati

Si tratta delle categorie particolari di dati personali di cui all’art. 9 (es. informazioni sulle opinioni politiche di una persona fisica) oltre ai dati personali relativi a condanne penali o reati di cui all’art. 10. Vi sono, inoltre, talune categorie di dati che possono aumentare i rischi eventuali per i diritti e le libertà delle persone fisiche. Si tratta di dati personali considerati sensibili (nell’accezione comune del termine), in quanto connessi alla vita familiare o privata ovvero in quanto incidono sull’esercizio di un diritto fondamentale ovvero in quanto una loro violazione comporta evidentemente un grave impatto sulla vita quotidiana dell’interessato.

Esempi/Chiarimenti 29WP: (i) Un ospedale che conserva le cartelle cliniche dei pazienti. (ii) Un investigatore privato che conserva informazioni su soggetti responsabili di reati.

Il criterio si riferisce ad es. a: dati relativi alle comunicazioni elettroniche, ubicazione (la cui raccolta mette in gioco la libertà di circolazione), dati finanziari che potrebbero essere utilizzati per commettere frodi in materia di pagamenti. Il criterio in oggetto può riferirsi anche a dati quali documenti personali, e-mail, agende, appunti tratti da lettori elettronici dotati di dispositivi per la presa di appunti, e informazioni molto personali contenute in applicazioni che consentono di tenere traccia del proprio stile di vita.

Criterio n.5: Trattamenti di dati su larga scala

Fattori quali **(i)** numero di soggetti interessati dal trattamento, **(ii)** volume di dati, **(iii)** durata, o persistenza, dell’attività del Trattamento e **(iv)** trasferimento dei dati, potrebbero essere presi in considerazione al fine di stabilire se un trattamento sia svolto su «larga scala».

Criterio n.6: Combinazione o raffronto di dati

Combinazione o raffronto di insiemi di dati, per esempio derivanti da due o più trattamenti svolti per diverse finalità e/o da titolari distinti, secondo modalità che esulano dalle ragionevoli aspettative dell’interessato.

Criterio n.7: Interessati vulnerabili

Il trattamento di questa tipologia di informazioni rappresenta un criterio ai fini della DPIA in quanto è più accentuato lo squilibrio di poteri fra interessato e Titolare del trattamento, nel senso che il singolo può non disporre del potere di acconsentire, o di opporsi, con facilità al trattamento dei propri dati, né può talora con facilità esercitare i propri diritti.

Esempi/Chiarimenti 29WP: Il criterio fa riferimento a: minori, dipendenti, segmenti di popolazione particolarmente vulnerabile e meritevole di specifica tutela (soggetti con patologie psichiatriche, richiedenti asilo, anziani, pazienti); ogni interessato per il quale si possa identificare una situazione di disequilibrio nel rapporto con il rispettivo Titolare del trattamento.



Criterio n.8: Nuove tecnologie

Utilizzi innovativi o applicazione di nuove soluzioni tecnologiche o organizzative (ad esempio, l'associazione fra tecniche dattiloscopiche e riconoscimento del volto per migliorare il controllo degli accessi fisici). Il regolamento chiarisce che l'utilizzo di una nuova tecnologia, definito "in conformità con il grado di conoscenze tecnologiche raggiunto", può comportare l'obbligo di condurre una DPIA, in quanto il ricorso a una nuova tecnologia può generare forme innovative di raccolta e utilizzo dei dati cui può associarsi un rischio elevato per i diritti e le libertà delle persone. Nei fatti, le conseguenze sul piano individuale e sociale del ricorso a una nuova tecnologia sono talora ignote. La DPIA aiuterà il Titolare a comprendere e gestire tali rischi. Per esempio, alcune applicazioni legate all' "Internet delle cose" potrebbero avere impatti significativi sulla vita privata e le abitudini delle persone, e, quindi, necessitano di una DPIA.

Criterio n.9: Esercizio diritti

Tutti quei trattamenti che, di per sé, *"impediscono [agli interessati] di esercitare un diritto o di avvalersi di un servizio o di un contratto"*. Ciò comprende i trattamenti finalizzati a consentire, modificare o negare l'accesso degli interessati a un servizio o la stipulazione di un contratto.

Esempi/Chiarimenti 29WP: Screening dei clienti di una banca attraverso i dati registrati in una centrale rischi al fine di stabilire se ammetterli o meno a un finanziamento.

3.1.3 Presenza di eventuali eccezioni

In questa fase il DPO valuta la presenza di eventuali eccezioni rispetto alla conduzione di una DPIA, secondo i criteri già forniti al **Par. 1.3 - Ambito di applicazione della DPIA ed eccezioni**. Nel caso in cui sia ritenuta necessaria la conduzione di una DPIA ma non vi fossero le condizioni per condurla in maniera completa e corretta (ad es. nel caso di cambiamenti organizzativi in corso), può essere previsto il rinvio della stessa, purché le motivazioni siano adeguatamente formalizzate all'interno del *pre-assessment* e sia indicata la data di conduzione della medesima.

3.2 Nota metodologica per l'esecuzione del Data Protection Impact Assessment

Nei paragrafi successivi sono riassunti gli elementi che sono oggetto di verifica e valutazione in fase di *Data Protection Impact Assessment* (**Fase B – Data Protection Impact Assessment**):

- (i) adeguatezza delle misure di sicurezza tecniche ed organizzative previste nella progettazione
- (ii) probabilità e dell'impatto dei rischi (*risk assessment*) in termini di riservatezza, integrità e disponibilità dei dati personali trattati
- (iii) eventuale identificazione di misure ulteriori (piano di mitigazione) da implementare prima dell'avvio del trattamento

3.2.1 Valutazione di adeguatezza delle misure di sicurezza tecniche ed organizzative

Le misure di sicurezza possono essere relative ai dati (ad esempio: crittografia, anonimizzazione), ai supporti cartacei/digitali (ad esempio: archiviazione sicura, protezione di rete) oppure di natura organizzativa (ad esempio: policy di controllo degli accessi e tracciabilità, policy per la gestione degli incidenti di sicurezza, rapporti con i fornitori). Tali misure, applicate in diverse combinazioni, definiscono diversi livelli di protezione dei dati, agendo a mitigazione della possibilità che si verifichi un evento di *data breach*.

La metodologia di DPIA prevede una valutazione delle misure tecniche ed organizzative basata su un giusto compromesso tra efficienza/costo del trattamento e limitazione del livello di rischio. La valutazione di "adeguatezza" di tali misure avviene sulla base delle **misure di sicurezza effettivamente implementate o per cui è prevista l'implementazione prima dell'avvio del trattamento (livello di sicurezza "as-is")**.

Focus metodologico per l'identificazione del livello di sicurezza nei sistemi informativi

Con particolare riferimento ai trattamenti di dati personali effettuati con sistemi informativi, il Gruppo FS Italiane ha elaborato una libreria delle misure di sicurezza tecniche e organizzative potenzialmente applicabili, distinta su tre livelli di sicurezza in funzione del livello di rischio del trattamento.

- **Livello 1:** il trattamento di dati personali presuppone *by default* l'utilizzo di alcune misure base (*baseline*).
- **Livello 2:** il trattamento di dati personali prevede l'utilizzo di un livello di sicurezza medio aggiuntivo rispetto alla *baseline*.
- **Livello 3:** il trattamento di dati personali prevede l'utilizzo del livello di sicurezza massimo disponibile rispetto alla *baseline*.

La libreria delle misure di sicurezza (costantemente aggiornata) e la relativa corrispondenza con i livelli precedentemente riportati è disponibile sulla intranet aziendale nella sezione *Data Protection*.

3.2.2 Risk Assessment

In coerenza con la definizione di "rischio" adottata dal Gruppo FS Italiane, un rischio connesso alla gestione dei dati personali è definito come **la possibilità che il manifestarsi di un evento avverso possa compromettere il rispetto dei diritti e delle libertà delle persone fisiche**.

Nelle attività di *Data Protection Impact Assessment* la valutazione del rischio avviene mediante applicazione della seguente metodologia:

1. Identificazione delle possibili minacce per il rispetto dei diritti e delle libertà degli interessati e definizione di un set di possibili eventi rappresentativi (non esaustivi) di (i) **Riservatezza - Accesso Illegittimo ai Dati**, (ii) **Integrità - Modifica Indesiderata ai Dati**, (iii) **Disponibilità - Perdita di Dati** (c.d. “Data Breach”)³³

Ad esempio, per la minaccia “Accesso non autorizzato alle credenziali di autenticazione”, un possibile scenario può essere espresso come segue: “Un dipendente, utilizza le credenziali di accesso di un collega, lasciate su post-it all’interno di un cassetto non chiuso a chiave, sottraendo file contenenti dati personali di natura sensibile e divulgandone il contenuto sul web”. In questo esempio, la minaccia è legata alla combinazione di fattore di rischio (un comportamento intenzionale) e di una o più vulnerabilità (*password* riportata su *post-it* e cassetto non chiuso a chiave).

Focus metodologico sul concetto di “rischio”

La piena comprensione del concetto di rischio passa dall’analisi delle seguenti componenti:

- **Fattori di Rischio:** elementi di incertezza che, sfruttando le vulnerabilità tecnologiche e organizzative, possono dare luogo all’evento avverso. Tali elementi possono essere di natura interna o esterna, intenzionale o accidentale, legate a persone o a sistemi. Ad esempio, la motivazione economica alla base di un attacco *cyber*, un errore umano, etc.
- **Vulnerabilità:** elementi di natura tecnologica o organizzativa che, se non correttamente presidiati, permettono al fattore di rischio di generare un evento avverso. Ad esempio, un sistema operativo non aggiornato, una chiavetta non criptata, etc.
- **Minacce:** la combinazione tra fattori di rischio e vulnerabilità. Ad esempio, la possibilità che un attaccante esterno sfrutti una *password* debole per accedere a dati personali.
- **Evento:** il manifestarsi di una minaccia che causa una perdita di riservatezza, integrità o disponibilità dei dati personali. Ad esempio, un attacco esterno che si concretizzi in un furto di dati personali.

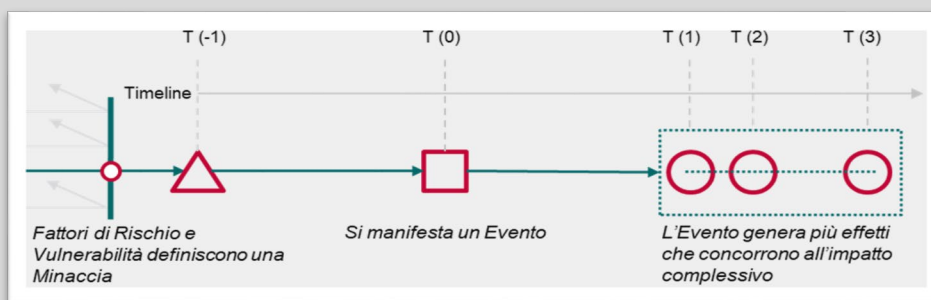


Figura 4 – Componenti del rischio

2. Determinazione della probabilità e dell’impatto di accadimento per ciascun evento rappresentativo identificato

³³ Si vedano le linee di indirizzo per la gestione delle violazioni di dati personali ([Sezione E](#))

Gli eventi possono infatti avere rilevanza diversa in funzione della tipologia dei dati, del loro volume e degli effetti sulle persone. Di conseguenza, è necessario stimare **in maniera indipendente (i)** la probabilità e **(ii)** l'impatto degli eventi.

Focus metodologico sulla stima della “probabilità” in DPIA

Nel contesto delle attività di *Data Protection Impact Assessment*, la probabilità è la stima della frequenza con cui una minaccia si può concretizzare in un evento. La stima di probabilità è effettuata sulla base di quattro classi, definite come segue:

- **(1) Bassa:** l'evento si verifica “meno di una volta ogni 20 anni”.
- **(2) Media:** l'evento si verifica fra “una volta ogni 10 anni” e “una volta ogni 20 anni”.
- **(3) Alta:** l'evento si verifica fra “una volta ogni 5 anni” e “una volta ogni 10 anni”.
- **(4) Molto alta:** l'evento si verifica “almeno una volta ogni 5 anni”.

La stima della probabilità tiene conto implicitamente di diversi parametri, tra i quali:

- il contesto in cui viene effettuato il trattamento (numerosità dei dati, numerosità delle persone autorizzate al trattamento, diffusione o trasmissione del dato, etc.)
- l'appetibilità del dato, in funzione dell'attrattività che il dato riveste per un potenziale attaccante
- le misure di sicurezza tecnico-organizzative implementate, in funzione degli strumenti a supporto del trattamento, considerando le misure di sicurezza definite in fase di progettazione o rispetto alle misure di sicurezza ereditate dal sistema esistente.

Ad esempio, un dipendente infedele, a parità di misure tecnico-organizzative implementate, sarà più motivato a violare dati personali che possono comportare beneficio economico, rispetto a dati personali di tipo anagrafico. Nel primo caso la probabilità potrebbe risultare più alta, nonostante le medesime misure di sicurezza adottate.

Focus metodologico sulla stima dell'“impatto” in DPIA

Nel contesto delle attività di *Data Protection Impact Assessment*, l'impatto è la stima degli effetti generati dall'evento sull'interessato, ad esempio problemi di natura personale o professionale. La stima degli impatti³⁴ è effettuata sulla base di quattro classi, definite come segue:

- **(1) Bassa:** gli interessati incorrono in piccoli inconvenienti e fastidi, ad esempio devono fornire nuovamente i propri dati.
- **(2) Media:** gli interessati incorrono in inconvenienti significativi che riescono a risolvere con qualche difficoltà, ad esempio extra-costi, mancato accesso per tempi contenuti ai servizi, paura, stress, etc.
- **(3) Alta:** gli interessati incorrono in conseguenze significative che riescono a superare con notevoli difficoltà, ad esempio furto di beni dell'interessato, introduzione in *black-list*, licenziamento, peggioramento stato di salute, etc.

³⁴ Fonte: *Handbook on Security of Personal Data Processing*, Dicembre 2017, *European Union Agency for Network and Information Security* (ENISA)

- **(4) Molto alta:** Gli interessati incorrono in conseguenze molto significative o irreversibili, ad esempio peggioramento significativo della posizione debitoria, incapacità a lavorare, danni psicologici e fisici di lungo termine, etc.

Per quanto attiene l'impatto, la valutazione è effettuata tenendo conto degli effetti per la salute, gli effetti economici e quelli sulla sfera individuale e sociale. Di seguito si riportano alcuni esempi:

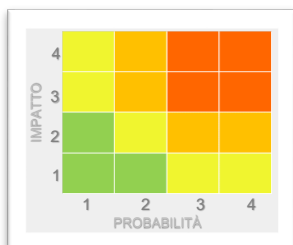
- tra gli impatti per la salute, di natura sia fisica sia psicologica, possono rientrare: danno fisico, sofferenza emotiva, apprensione, ansia, peggioramento della qualità della vita, paura sociale;
- tra gli impatti economici possono rientrare quelli per mancata opportunità (mancato guadagno) e per quelli per maggiori costi (perdita economica diretta);
- tra gli impatti sulla sfera individuale possono rientrare la perdita della libertà di circolazione, la perdita della libertà di parola, la perdita di autodeterminazione, l'intrusione nella vita privata;
- tra gli impatti sulla sfera sociale possono rientrare la discriminazione, l'esclusione, l'imbarazzo, il danno reputazionale.

3. Determinazione del livello di rischio del trattamento

La combinazione di probabilità e impatto applicata agli eventi rappresentativi consente di identificare il livello di rischio del trattamento.

Nel contesto delle attività di *Data Protection Impact Assessment*, il livello di rischio del trattamento è determinato dall'evento che presenta la combinazione di probabilità e impatto con valore più

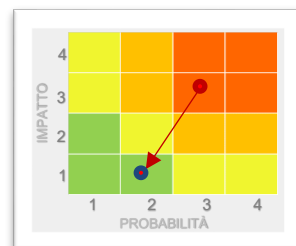
alto in quanto il rispetto dei diritti e delle libertà degli interessati rappresenta un valore "non negoziabile". La stima del livello di rischio del trattamento è effettuata sulla base di quattro classi, definite come segue:



- **Rischio basso:** area verde del quadrante (1:1; 1:2; 2:1)
- **Rischio medio:** area gialla del quadrante (1:3; 1:4; 2:2; 3:1; 4:1)
- **Rischio alto:** area arancione del quadrante (2:3; 2:4; 3:2; 4:2)
- **Rischio molto alto:** area rossa del quadrante (3:3; 3:4; 4:3; 4:4)

3.2.3 Determinazione delle misure di sicurezza adeguate al rischio e piano di mitigazione

Una volta determinati il livello delle misure di sicurezza ed il livello di rischio del trattamento, è possibile definire se si rende necessaria la previsione di un piano di mitigazione e, quindi, l'adozione di misure di mitigazione aggiuntive rispetto a quelle attuali/previste³⁵. Tale processo, iterato se necessario, deve



³⁵ Come descritto nel **Capitolo 2 - Il processo di identificazione dei trattamenti a rischio elevato e DPIA**, tra le misure di mitigazione, oltre all'adozione di misure di sicurezza tecniche ed organizzative, rientrano il riesame del



consentire di ridurre i rischi per i diritti e le libertà degli interessati ad un livello considerato accettabile (tendenzialmente corrispondente alle aree verde e gialla del quadrante).

Nei casi in cui il livello di rischio residuo dovesse essere considerato non accettabile (tendenzialmente area rossa del quadrante) anche a seguito dell'adozione di tutte le misure di mitigazione disponibili, si potrà procedere con la rinuncia al trattamento oppure con la Consultazione Preventiva presso l'Autorità di controllo.

Focus metodologico per la determinazione di adeguatezza delle misure nei sistemi informativi

Nel contesto delle attività di Data Protection Impact Assessment:

- Per trattamenti considerati a **rischio basso** sono considerate “adeguate” le misure di sicurezza di **Livello 1 (o inferiore)**.
- Per trattamenti considerati a **rischio medio/alto** sono considerate “adeguate” le misure di sicurezza di **Livello 1** o di **Livello 2**. L'adozione di tali misure di sicurezza deve consentire il raggiungimento di un livello di rischio accettabile.
- Per trattamenti considerati a **rischio molto alto** sono considerate “adeguate” le misure di sicurezza di **Livello 2** o di **Livello 3**. L'adozione di tali misure di sicurezza deve consentire il raggiungimento di un livello di rischio accettabile.

trattamento e la raccolta dell'opinione degli interessati o dei loro rappresentanti sul trattamento previsto (ad es. organizzazioni sindacali).



SEZIONE C

GESTIONE DEI DIRITTI DEGLI INTERESSATI



SEZIONE C.....	38
1. LA GESTIONE DEI DIRITTI DEGLI INTERESSATI.....	40
1.1 PREMessa E DEFINIZIONI.....	40
2. INFORMAZIONI DA FORNIRE ALL'INTERESSATO	41
3. DIRITTI DEGLI INTERESSATI	43
3.1 DIRITTO DI ACCESSO	43
3.2 DIRITTO DI RETTIFICA.....	43
3.3 DIRITTO ALLA CANCELLAZIONE (“DIRITTO ALL’OBLIO”).....	44
3.4 DIRITTO DI LIMITAZIONE DI TRATTAMENTO.....	44
3.5 DIRITTO ALLA PORTABILITÀ DEI DATI.....	45
3.6 DIRITTO DI OPPOSIZIONE	45
3.7 REVOCA DEL CONSENSO	46
4. GESTIONE DELLE RICHIESTE DEGLI INTERESSATI.....	47
4.1 FASE 1 – RICEZIONE DELLA RICHIESTA E PRESA IN CARICO	47
4.1.1 CLASSIFICAZIONE DELLA RICHIESTA.....	48
4.1.2 IDENTIFICAZIONE DELL'INTERESSATO.....	48
4.1.3 PRESA IN CARICO DELLA RICHIESTA	49
4.2 FASE 2 – ISTRUTTORIA ED ESECUZIONE DELLA RICHIESTA	50
4.2.1 RACCOLTA DELLE INFORMAZIONI PER L'ELABORAZIONE DELLA RICHIESTA	50
4.2.2 ELABORAZIONE O RIGETTO DELLA RICHIESTA.....	50
4.3 FASE 3 – RISCONTRO ALL'INTERESSATO.....	50
4.4 ULTERIORI PRECISAZIONI	51
INDICE DELLE FIGURE	88
INDICE DELLE TABELLE	88
GLOSSARIO	89



1. La gestione dei diritti degli interessati

1.1 Premessa e definizioni

Uno dei temi più rilevanti e delicati del Regolamento UE 2016/679 (GDPR), che riveste primaria rilevanza per il Gruppo FS Italiane, è rappresentato dalla gestione dei “*diritti degli interessati*”. Tra questi, alcuni rappresentano delle novità introdotte dal GDPR (portabilità e limitazione), mentre altri costituiscono delle conferme di quanto già disciplinato dalla normativa nazionale preesistente (D.Lgs. 196/2003 modificato con D.Lgs. 101/2018), per quanto siano stati ulteriormente enfatizzati e rafforzati dal GDPR (accesso, rettifica, cancellazione, “diritto all’oblio”, opposizione).

Il Regolamento stabilisce, all’Art. 12, che il Titolare “*adotta misure appropriate per fornire all’interessato tutte le informazioni di cui agli articoli 13 e 14 e le comunicazioni di cui agli articoli da 15 a 22 e all’articolo 34 relative al trattamento in forma concisa, trasparente, intelligibile e facilmente accessibile, con un linguaggio semplice e chiaro, in particolare nel caso di informazioni destinate specificamente ai minori [...]*”.

Il Titolare, pertanto, è tenuto a fornire agli interessati tutte le informazioni di maggior rilievo riguardanti i trattamenti cui verranno sottoposti i loro dati, sia nel caso di raccolta di dati personali direttamente presso l’interessato (Art. 13 del Regolamento), sia nel caso in cui i dati non siano stati ottenuti direttamente presso l’interessato, specificando le fonti da cui hanno origine i dati (Art. 14 del Regolamento).

Inoltre, il Titolare è tenuto ad agevolare l’esercizio dei diritti dell’interessato (Artt. da 15 a 22 del Regolamento) fornendo allo stesso le informazioni richieste senza ingiustificato ritardo e comunque al più tardi entro un mese dal ricevimento della richiesta stessa. Tale termine può essere prorogato di due mesi, se necessario, tenuto conto della complessità e del numero delle richieste; in questo caso il Titolare deve informare l’interessato di tale proroga, e dei motivi del ritardo, entro un mese dal ricevimento della richiesta. Infine, ai sensi dell’Art. 28 del Regolamento, il soggetto terzo – Responsabile del trattamento – che tratta dati personali per conto del Titolare³⁶ è tenuto ad assisterlo con misure tecniche e organizzative adeguate, comunicando ogni informazione utile al fine di dar seguito alle richieste di esercizio dei diritti.

Le presenti linee di indirizzo sono state redatte sulla base delle definizioni, disposizioni e obblighi di cui al citato Regolamento e disciplina i due principali processi legati alla gestione dei diritti degli interessati di cui al Capo III del Regolamento:

- **Informazioni da fornire all’interessato:** l’adozione di appropriate misure per fornire all’interessato tutte le informazioni connesse al trattamento dei suoi dati personali.
- **Gestione delle richieste di esercizio dei diritti degli interessati:** la gestione completa delle richieste degli interessati, dalla ricezione all’elaborazione fino al riscontro.

³⁶ Si tratta di soggetti terzi, ivi comprese altre Società del Gruppo, che svolgono attività di trattamento di dati personali per conto della Società Titolare.



2. Informazioni da fornire all'interessato

Il mezzo a disposizione del Titolare per risultare conforme al principio di trasparenza è l'**informativa per la protezione dei dati personali** (nel seguito "*informativa*"). L'*informativa* deve essere concisa, trasparente, intellegibile, facilmente accessibile, formulata con un linguaggio semplice e chiaro.

Gli elementi che devono essere inseriti obbligatoriamente nell'*informativa* sono indicati negli Artt. 13 e 14 del Regolamento. Il DPO di FS SpA ha prodotto una serie di *template* standard di *informativa*, in versione sia estesa sia sintetica, disponibili sulla intranet aziendale (sezione *Data Protection*). È compito del *Data Manager* compilare i *template* standard secondo le seguenti indicazioni generali:

- i *template* possono essere modificati in funzione della *brand identity* (logo, *look & feel*) o in funzione di specifiche esigenze di lettura (ad esempio lettura da *mobile*), tuttavia dovranno sempre riportare gli elementi previsti dagli Artt.13-14;
- le sezioni dell'*informativa* non applicabili allo specifico trattamento devono essere eliminate, ponendo attenzione alla numerazione dei paragrafi (ad esempio, deve essere eliminata la sezione *Trasferimento dati extra-UE* se non è previsto trasferimento di dati all'esterno dell'UE);
- per i riferimenti del Titolare si può utilizzare la sede legale della Società e/o un indirizzo di posta elettronica con la nomenclatura titolaretrattamento@dominiosocietario.it. Il monitoraggio della casella di posta del Titolare deve essere affidato al rappresentante legale della Società e/o a persona da essa designata (ad es. staff o segreteria). È sempre previsto un *redirect* verso la casella di posta del DPO;
- per i riferimenti del DPO è necessario utilizzare l'e-mail di contatto del DPO con la nomenclatura protezionedati@dominiosocietario.it;
- nella sezione *Diritti degli Interessati*, deve essere riportato l'indirizzo di posta elettronica del DPO oppure quello del *Data Manager*; in quest'ultimo caso può essere utilizzata una casella di struttura, purché monitorata nel continuo;
- nella sezione *Conservazione dei Dati* deve essere indicato il tempo di *retention* facendo riferimento alle linee di indirizzo in materia.

Nella redazione delle informative deve essere posta particolare attenzione all'identificazione delle **finalità del trattamento**, distinguendo il caso in cui il conferimento dei dati ha natura:

- "**Obbligatoria**", individuando di conseguenza la base giuridica tra le seguenti opzioni:
 - *contrattuale*: esecuzione di un contratto di cui l'interessato è parte o di misure precontrattuali adottate su richiesta dell'interessato. Ad esempio, acquisto biglietto del treno, erogazione servizi tramite portale web, iscrizione ad un corso di formazione, etc.;
 - *legale*: adempimenti di obblighi derivanti da legge, regolamento o normativa comunitaria. Ad esempio, iscrizione soci al Registro delle Imprese, gestione Libro Unico del Lavoro, etc.;
 - *interesse legittimo*: perseguimento dei legittimi interessi del Titolare del trattamento o di terzi, a condizione che non prevalgano gli interessi o i diritti e le libertà fondamentali dell'interessato che richiedono la protezione dei dati personali, in particolare se l'interessato è un minore. Ad esempio, videosorveglianza, attività di internal audit, controllo prevenzione frodi, etc.;



- *interesse pubblico*: esecuzione di un compito di interesse pubblico o connesso all'esercizio di pubblici poteri; è la tipica base giuridica utilizzata prevalentemente nei trattamenti del settore pubblico;
 - *interesse vitale*: salvaguardia degli interessi vitali dell'interessato. Ad esempio, trattamenti per fini umanitari.
- “**Facoltativa**”, con base giuridica “*consenso dell'interessato*”³⁷. Ad esempio invio *newsletter*, invio comunicazioni commerciali, servizi “aggiuntivi” rispetto a quelli contrattuali, profilazione etc. In quest'ultimo caso, l'informativa prevedrà una sezione apposita dedicata alla raccolta dei consensi.

Le informative possono fare riferimento a più trattamenti anche con *Data Manager* diversi. In tali casi, il DPO societario, sentiti i *Data Manager*, predispone l'informativa e la concorda con i medesimi. Inoltre, il DPO societario verifica l'aggiornamento della *privacy policy* raggiungibile dal sito internet, ove presente, nella sezione “Protezione dati personali” riportata nel *footer* della pagina *web* e l'informativa relativa ai *cookies*.

Per alcuni trattamenti a carattere “trasversale”, il DPO di FS SpA predispone informative specifiche valide per l'intero Gruppo FS (ad esempio l'informativa resa ai dipendenti in fase di assunzione, informativa per segnalare le aree videosorvegliate, etc.) e le rende disponibili ai *Data Manager* interessati.

Particolare attenzione andrà riposta alle informative accessibili al pubblico (in formato sia digitale sia cartaceo) e ai trattamenti che per loro natura possono avere impatti su un numero elevato di interessati.

³⁷ Per “*consenso dell'interessato*” si intende qualsiasi manifestazione di volontà libera, specifica, informata e inequivocabile dell'interessato, con la quale lo stesso manifesta il proprio assenso, mediante dichiarazione o azione positiva inequivocabile, che i dati personali che lo riguardano siano oggetto di trattamento.



3. Diritti degli interessati

Gli artt. da 15 a 22 del Regolamento assegnano all'interessato specifici diritti. È opportuno quindi che il Titolare adotti tutte le misure organizzative e tecniche necessarie per riconoscere i diritti esercitabili e ottemperare alle richieste presentate dagli interessati laddove le condizioni lo consentano.

Al fine di agevolare la comprensione delle possibili richieste che possono pervenire al Titolare, nel presente Capitolo si riporta una descrizione dei diritti previsti dal Regolamento UE 2016/679, corredata da esempi e dai riferimenti normativi.

3.1 Diritto di accesso

L'Interessato ha il diritto di ottenere dal Titolare la conferma che sia o meno in corso un trattamento di dati personali che lo riguardano e, in tal caso, di ottenere l'accesso ai dati personali e alle informazioni di cui all'Art. 15 del Regolamento. Il Titolare è tenuto a fornire una copia dei dati personali oggetto di trattamento in formato elettronico di uso comune, salvo indicazione diversa dell'interessato. Nel processo di riscontro a tale richiesta si deve tener conto di eventuali vincoli normativi, oltre alla potenziale lesione di diritti e libertà altrui.

Di seguito un possibile esempio di richiesta:

Spett.le Società,
desidero sapere se avete, nei vostri database, dati personali a me riferibili (Mario Rossi, nato a Roma il 4/5/1970, CF. MRSSL4470G236Y) e, in tal caso, richiedo copia degli stessi.
Fatemi anche sapere da quanto tempo li state conservando e per quanto li conserverete, per quali scopi precisi sono stati da voi utilizzati, come sono stati acquisiti e se sono stati trasferiti a Terze Parti.
Attendo vostro riscontro.
Cordiali saluti

3.2 Diritto di rettifica

Ai sensi dell'Art. 16 del Regolamento, l'interessato ha il diritto di ottenere dal Titolare **(i)** la rettifica dei dati personali inesatti che lo riguardano, **(ii)** l'integrazione dei Dati Personali incompleti, anche tramite apposita dichiarazione integrativa.

Di seguito un possibile esempio di richiesta:

Spett.le Società,
sono Mario Rossi (nato a Roma il 4/5/1970, CF. MRSSL4470G236Y) e vorrei aggiornare il mio indirizzo di posta elettronica in mario.rossi@gmail.it; sui vostri sistemi ero registrato come mario.rossi@fastweb.it.
Vi chiedo di provvedere all'aggiornamento.
Attendo vostro riscontro.
Cordiali saluti



3.3 Diritto alla cancellazione (“diritto all’oblio”)

Ai sensi dell’Art. 17 del Regolamento, l’interessato ha diritto alla cancellazione dei propri dati personali e il Titolare del Trattamento ha l’obbligo di cancellarli senza ritardo, **(i)** per esaurimento delle finalità per i quali sono stati raccolti o trattati, **(ii)** se vi sono obblighi di legge relativi alla cancellazione dei dati, **(iii)** se i dati personali sono trattati illecitamente, **(iv)** se i dati sono raccolti relativamente all’offerta di servizi della società dell’informazione di cui all’Art. 8 del Regolamento³⁸, oppure se l’interessato **(v)** revoca il consenso su cui si basa il trattamento e non sussiste altro fondamento giuridico per il trattamento, **(vi)** se l’interessato si oppone al trattamento, e non sussiste altro fondamento giuridico per il trattamento o motivi legittimi prevalenti del Titolare.

Se il Titolare ha reso pubblici i dati ed è obbligato a cancellarli, tenendo conto della tecnologia disponibile e dei costi di attuazione, adotta le misure ragionevoli, anche tecniche, per informare i titolari che stanno trattando tali dati pubblici, della richiesta dell’interessato di cancellare qualsiasi *link*, copia o riproduzione dei suoi dati personali.

L’esercizio del diritto di cancellazione è limitato nei casi in cui il trattamento sia necessario **(i)** per l’esercizio del diritto alla libertà di espressione e di informazione, **(ii)** per l’adempimento di un obbligo legale, **(iii)** per motivi di interesse pubblico nel settore della sanità pubblica, **(iv)** ai fini di archiviazione nel pubblico interesse, di ricerca scientifica o storica, o a fini statistici, **(v)** per l’accertamento, l’esercizio o la difesa di un diritto in sede giudiziaria.

Di seguito un possibile esempio di richiesta:

Spettabile Società,
sono Mario Rossi e vi chiedo di cancellare tutti i miei dati personali.
Attendo vostro riscontro.
Cordiali saluti

3.4 Diritto di limitazione di trattamento

Ai sensi dell’Art. 18 del Regolamento, l’interessato può richiedere la limitazione del trattamento, al verificarsi delle seguenti ipotesi: **(i)** l’interessato contesta l’esattezza dei dati personali, **(ii)** il trattamento è illecito e l’interessato si oppone alla cancellazione, chiedendone invece la limitazione, **(iii)** i dati sono necessari all’interessato per l’accertamento, l’esercizio o la difesa di un diritto in sede giudiziaria, **(iv)** l’interessato si è opposto al trattamento in attesa della verifica sull’eventuale prevalenza di motivi legittimi del Titolare rispetto a quelli dell’interessato.

Se il trattamento è limitato, il Titolare può solo “conservare” i dati senza utilizzarli per finalità differenti, a meno che non ci sia un consenso esplicito dell’interessato, o i dati siano necessari per l’accertamento, l’esercizio o la difesa di un diritto in sede giudiziaria, o per tutelare i diritti di un’altra persona fisica (o giuridica) o per motivi di interesse pubblico.

Di seguito un possibile esempio di richiesta:

Spettabile Società,

³⁸ Condizioni applicabili al consenso dei minori in relazione ai servizi della società dell’informazione.



sto riscontrando dei problemi a modificare il mio account, in quanto il mio nome è Mario (Mario Rossi, nato a Roma il 4/5/1970, CF. MRSSLA470G236Y) e non Luigi Rossi.

Vi chiedo di provvedere all'aggiornamento.

Finché i problemi non saranno risolti, vi chiedo di non trattare i miei dati personali attualmente inesatti fino alla relativa rettifica.

Attendo vostro riscontro.

Cordiali saluti

3.5 Diritto alla portabilità dei dati

L'interessato, sulla base di quanto previsto dall'Art. 20 del Regolamento, ha diritto di ricevere, in un formato strutturato, di uso comune e leggibile da dispositivo automatico, i propri dati personali forniti al Titolare e ha diritto di richiedere, se tecnicamente fattibile, la trasmissione di tali dati a un altro Titolare. Tale trasmissione deve avvenire senza impedimenti da parte del Titolare qualora **(i)** il trattamento si basi sul consenso o su un contratto, **(ii)** il trattamento è effettuato con mezzi automatizzati. Nel processo di riscontro a tale richiesta, si deve tener conto della potenziale lesione di diritti e libertà altrui.

La portabilità dei dati può avvenire anche nei confronti di un soggetto esterno al settore merceologico della Società e può riguardare sia i dati forniti attivamente dall'interessato (nome e cognome, indirizzo postale, età, etc.) sia i dati generati e raccolti attraverso le attività svolte dall'utente o attraverso la fruizione di un servizio o l'utilizzo di un dispositivo (es. punti accumulati nell'ambito dell'adesione a programmi fedeltà, dati di viaggio effettuati, destinazioni preferite, etc.).

Di seguito un possibile esempio di richiesta:

Spett.le Società,

desidero trasferire tutti i dati a me riferibili (Mario Rossi, nato a Roma il 4/5/1970, CF. MRSSLA470G236Y) in vostro possesso al servizio di conservazione online ABC Corporate.

Questo è il mio identificativo unico della richiesta che ABC Corporate mi ha detto di comunicarvi per procedere con la trasmissione: XIFROSLEJ243DLFSGF.

I dati trasmetteteli anche alla mia e-mail: mario.rossi@gmail.com

Attendo vostro riscontro.

Cordiali saluti

3.6 Diritto di opposizione

Ai sensi dell'Art. 21 del Regolamento, l'interessato ha il diritto di opporsi in qualsiasi momento, per motivi connessi alla sua situazione particolare, al trattamento dei dati personali che lo riguardano, compresa la profilazione. L'effetto dell'esercizio di questo diritto è quello di far cessare definitivamente un determinato trattamento di dati personali, salvo che il Titolare dimostri l'esistenza di un legittimo interesse (prevalente rispetto agli interessi, diritti e libertà dell'interessato) oppure la necessità del trattamento per l'accertamento, l'esercizio o la difesa in sede giudiziaria.

Tale diritto è esercitabile anche in caso di trattamento per finalità di ricerca scientifica o storica o a fini statistici, salvo che il trattamento sia necessario per l'esecuzione di un compito di interesse pubblico.



Tale diritto, inoltre, deve essere esplicitamente riportato in informativa in maniera chiara e separata da qualsiasi altra informazione.

Di seguito un possibile esempio di richiesta:

Spett.le Società,
non voglio più ricevere le vostre mail promozionali e vi chiedo di interrompere qualsiasi attività stiate effettuando sui miei dati personali (Mario Rossi, nato a Roma il 4/5/1970, CF. MRSSLA470G236Y).
Attendo vostro riscontro.
Cordiali saluti

3.7 Revoca del consenso

L'interessato ha il diritto di revocare il proprio consenso in qualsiasi momento. La revoca del consenso non pregiudica la liceità del trattamento basata sul consenso prima della revoca. Prima di esprimere il proprio consenso, l'interessato è informato di ciò. Il consenso è revocato con la stessa facilità con cui è accordato (Art. 7, Par. 3 del Regolamento). La revoca del consenso deve essere riconosciuta agli interessati per qualsiasi tipo di trattamento basato sul consenso, svolto dal Titolare.

Per i trattamenti che abbiano ad oggetto finalità di *marketing* e profilazione, l'interessato può esercitare il diritto di revoca del consenso parziale o totale.

Di seguito un possibile esempio di richiesta:

Spett.le Società,
non voglio più ricevere le vostre e-mail promozionali e vi chiedo di interrompere qualsiasi attività promozionale o di profilazione stiate effettuando sui miei dati personali (Mario Rossi, nato a Roma il 4/5/1970, CF. MRSSLA470G236Y).
Attendo vostro riscontro.
Cordiali saluti

4. Gestione delle richieste degli interessati

Al fine di agevolare il riscontro alle richieste di esercizio dei diritti descritti nel precedente Capitolo, il Gruppo FS Italiane ha improntato un processo di gestione in tre fasi, sintetizzate in **Figura 5** e descritte dettagliatamente nel seguito del documento.

- **Fase 1 – Ricezione della richiesta di esercizio del diritto da parte dell'interessato e presa in carico**
- **Fase 2 – Istruttoria ed esecuzione della richiesta**
- **Fase 3 – Riscontro all'interessato**

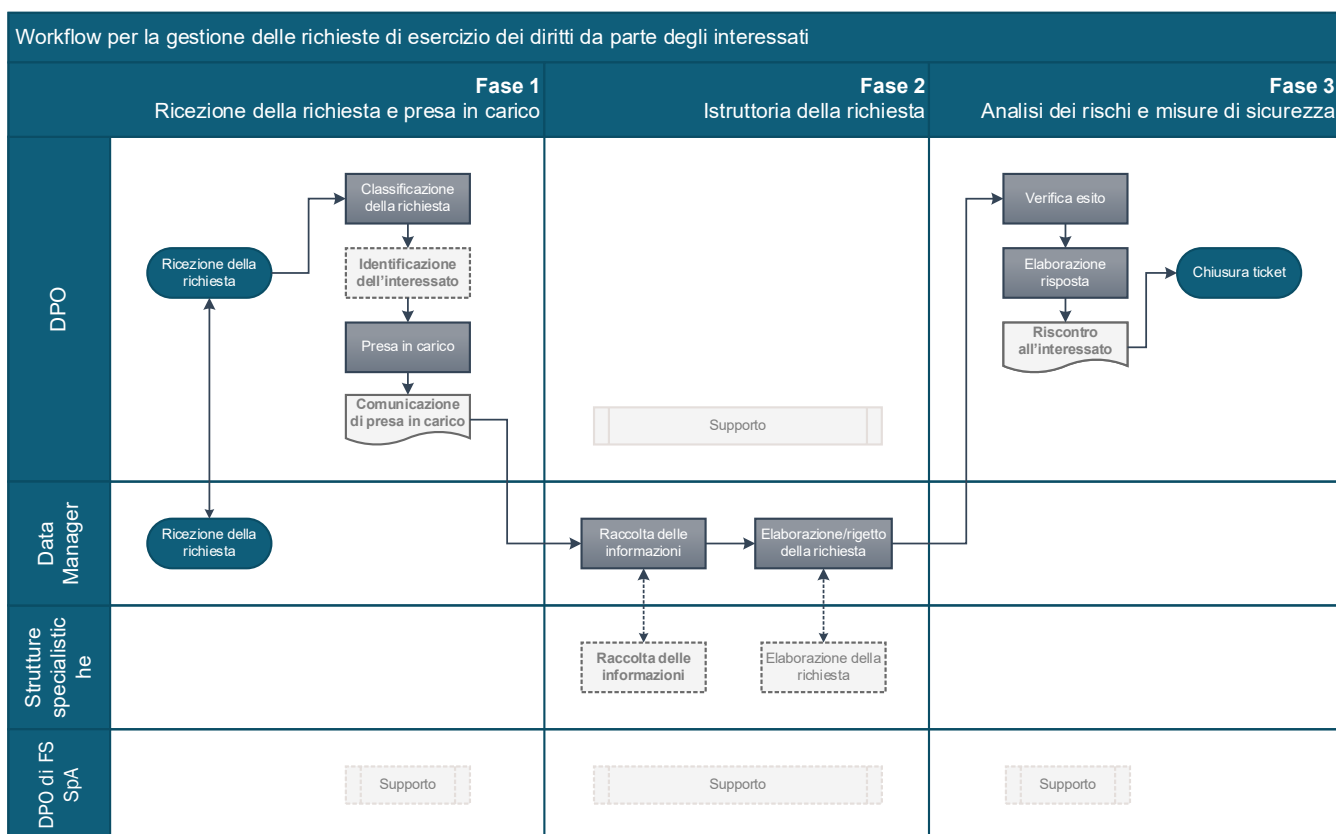


Figura 5 – Workflow per la gestione delle richieste di esercizio dei diritti da parte degli interessati

4.1 Fase 1 – Ricezione della richiesta e presa in carico

Gli interessati possono esercitare i propri diritti nei confronti di ogni Società del Gruppo in maniera totalmente gratuita³⁹, con qualsiasi modalità e senza formalità alcuna, purché per iscritto, anche tramite un terzo autorizzato dall'interessato, munito di apposita procura/delega/mandato debitamente sottoscritto ed accompagnato da copia di un documento di identità in corso di validità dell'interessato. Le forme più diffuse di invio delle comunicazioni da parte dell'interessato sono la posta ordinaria, la posta elettronica e la posta

³⁹ Si veda il **Par. 4.4 - Ulteriori precisazioni** per le possibili eccezioni.



elettronica certificata. Il Garante per la Protezione dei Dati Personali ha messo a disposizione sul proprio sito web (<https://www.garanteprivacy.it>) un modulo che può essere utilizzato dagli interessati per esercitare i propri diritti.

In coerenza con quanto stabilito dal Regolamento, la responsabilità per l'esercizio dei diritti dell'interessato è attribuita al Titolare, che delega al DPO il coordinamento del processo di gestione della richiesta. A tale processo partecipano, ognuno per le attività di propria competenza, il *Data Manager*, le strutture specialistiche di volta in volta interessate (ad esempio in ambito legale lavoro, sistemi informativi, etc) e le eventuali terze parti coinvolte.

È compito di ogni Società del Gruppo predisporre canali di raccolta che agevolino la gestione delle richieste degli interessati. In genere i canali utilizzati sono quelli riportati nelle informative⁴⁰. In ogni caso, tutte le figure che ricevono una richiesta di esercizio dei diritti sanciti dal Regolamento, **dovranno tempestivamente darne comunicazione al (i) DPO e al (ii) *Data Manager* e/o al proprio responsabile gerarchico**, fornendo adeguate informazioni ed eventuale documentazione a supporto, ai fini della presa in carico e gestione del processo di riscontro.

Di seguito si riportano i principali *step* di presa in carico.

4.1.1 Classificazione della richiesta

Il DPO, venuto a conoscenza della richiesta, è tenuto a classificarla in:

- Richiesta di accesso
- Richiesta di rettifica
- Richiesta di cancellazione
- Richiesta di limitazione
- Richiesta di portabilità
- Richiesta di opposizione
- Richiesta di revoca del consenso

Una categoria residuale è rappresentata da quelle richieste attraverso le quali l'interessato non intende esercitare propriamente un diritto, ma segnala o chiede chiarimenti su tematiche inerenti alla protezione dei dati personali (ad esempio, ricezione di una e-mail destinata ad altro cliente, comunicazione di un potenziale *data breach*, richiesta di indicazioni su come gestire autonomamente i consensi o procedere con la cancellazione dell'account e dei dati dall'area riservata, etc.). Tali richieste, di cui è opportuno tenere traccia, sono classificate come "Richiesta di chiarimenti".

Eventuali richieste diverse dall'esercizio dei diritti o da tematiche inerenti alla protezione dei dati personali, invece, (ad esempio, richieste di assistenza alla clientela) sono indirizzate verso le strutture competenti.

Nei casi in cui la richiesta si riveli particolarmente complessa o richieda l'intervento di strutture specialistiche di FS SpA, o riguardi trattamenti infragruppo, il DPO e/o il *Data Manager* dovranno tempestivamente informare il DPO di FS SpA, che supporterà il DPO e il *Data Manager*, per quanto di competenza, in tutte le fasi successive.

4.1.2 Identificazione dell'interessato

⁴⁰ Sede legale del titolare e indirizzi di posta elettronica di titolare, DPO e *Data Manager*.



Il DPO valuta l'identificabilità dell'interessato: se la richiesta proviene da un interessato identificabile (ad esempio, a fronte di una comunicazione o di un'iniziativa da parte di Trenitalia su clienti Cartafreccia), non è necessario prevedere la fase di identificazione dell'interessato e si passerà allo *step* successivo; in caso di richieste "spot" dove non sia possibile verificare direttamente l'identità dell'interessato, il DPO richiede copia di un documento d'identità valido (passaporto, carta d'identità, patente di guida), che può essere fornito dall'interessato anche via e-mail. Qualora l'interessato si avvalga di un soggetto terzo (ad es. un legale), occorre verificare che lo stesso sia munito di apposita procura/delega/mandato in materia di esercizio dei diritti ai sensi del Regolamento, accompagnato da copia di un documento di identità in corso di validità dell'interessato.

Tutte le comunicazioni relative alla fase di identificazione dell'interessato e la verifica della copia del documento di identità sono effettuate dal DPO o, se concordato diversamente, dal *Data Manager* di riferimento.

4.1.3 Presenza in carico della richiesta

Entro 5 giorni dal ricevimento della richiesta, il DPO provvede all'apertura di un *ticket* con codice di riconoscimento univoco e comunica all'interessato la presa in carico della richiesta. Si riportano di seguito alcuni esempi di possibile comunicazione di presa in carico.

Esempio 1 – Richiesta a seguito di nostra comunicazione o interazione

Gentile Cliente,

la informiamo che la Sua richiesta pervenuta in data gg/mm/yyyy è stata presa in carico con Codice ID [Società]_[Data]_[N° Progressivo .xls].

La informiamo, inoltre, che in osservanza a quanto previsto dall'Art. 12 del Regolamento UE 679/2016 Le risponderemo al più tardi entro 30 giorni dal ricevimento della richiesta (prorogabili di due mesi, tenuto conto della complessità e del numero di richieste).

In tale periodo non escludiamo la possibilità che Lei possa ricevere ulteriori comunicazioni od essere ricontattato per eventuali chiarimenti o per verificare eventuali casi di omonimia.

RingraziandoLa per la collaborazione, porgiamo cordiali saluti.

Esempio 2 – Richiesta "spot"

Gentile Cliente,

la informiamo che per procedere nella presa in carico della Sua richiesta, pervenuta in data gg/mm/yyyy e registrata con Codice ID [Società]_[Data]_[N° Progressivo .xls], è necessario provvedere alla Sua identificazione⁴¹.

A tale scopo Le chiediamo di inviarci copia elettronica di un Suo documento di identità o del codice fiscale; inoltre, al fine di procedere più velocemente nell'elaborazione della Sua richiesta, ha la possibilità di compilare il modulo di esercizio dei diritti degli interessati presente sul sito del Garante per la Protezione dei Dati Personali.

⁴¹Il documento di identità deve essere acquisito solo nei casi strettamente necessari all'identificazione dell'interessato. Nell'esempio 1, trattandosi di una "risposta" ad una nostra sollecitazione, siamo certi di avere cognizione dell'identità dell'interessato. Nell'esempio 2, è invece necessaria una identificazione certa. Tuttavia, bisogna tenere presente che il documento di identità deve essere acquisito un'unica volta come da indicazione del Garante al fine di "evitare di acquisire più volte copie di documenti già disponibili agli atti".



La informiamo, inoltre, che in osservanza a quanto previsto dall'Art. 12 del Regolamento UE 679/2016 Le risponderemo al più tardi entro 30 giorni dal ricevimento della richiesta completa dei documenti di identificazione (prorogabili di due mesi, tenuto conto della complessità e del numero di richieste).

In tale periodo non escludiamo la possibilità che Lei possa ricevere ulteriori comunicazioni od essere ricontattato per eventuali chiarimenti o la verifica di eventuali casi di omonimia.

RingraziandoLa per la collaborazione, porgiamo cordiali saluti.

4.2 Fase 2 – Istruttoria ed esecuzione della richiesta

In base al diritto esercitato, potrebbe essere richiesto un coinvolgimento più o meno incisivo delle varie strutture organizzative e delle terze parti coinvolte, con l'obiettivo di elaborare ed evadere la richiesta dell'interessato. Le strutture interessate sono comunque tenute a collaborare nel processo di istruttoria con tempi di elaborazione tali da rispettare i termini previsti da Regolamento⁴². Le strutture supportano il DPO nella formalizzazione di un riscontro all'interessato e si attivano per l'avvio delle conseguenti azioni previste (ad. es. cancellazione dei dati, rettifica etc.).

Di seguito si riportano i principali *step* di elaborazione della richiesta.

4.2.1 Raccolta delle informazioni per l'elaborazione della richiesta

Il DPO si attiva con il/i *Data Manager* di riferimento per la raccolta delle informazioni utili a fornire una risposta all'interessato. In funzione della complessità organizzativa della Società, tale raccolta potrà essere concordata con le strutture specialistiche (ad esempio in ambito legale lavoro, sistemi informativi, etc), con altri *Data Manager* e con eventuali terze parti coinvolte. Resta inteso che in questo caso ogni *Data Manager* ha la responsabilità di analizzare le informazioni in suo possesso al fine di limitare la possibilità di errore.

4.2.2 Elaborazione o rigetto della richiesta

Il *Data Manager*, con il supporto del DPO, verifica la presenza di eventuali impedimenti e, se del caso, procede con l'elaborazione della richiesta (cancellazione, accesso, etc.) oppure con il rigetto della stessa (per gli impedimenti che potrebbero comportare il rigetto della richiesta si veda il Capitolo precedente).

Nel caso in cui il trattamento dei dati personali dell'interessato coinvolga più strutture societarie/terze parti, il DPO coordina le attività di elaborazione della richiesta.

4.3 Fase 3 – Riscontro all'interessato

Una volta completate le attività di istruttoria, il DPO, con il supporto del/dei *Data Manager*, ne verifica l'esito ed elabora la risposta da fornire all'interessato. Il DPO o, se concordato diversamente, il *Data Manager* – per conto del Titolare – comunica l'esito all'interessato. Si riporta di seguito un esempio di possibile comunicazione.

Gentile Cliente,

La informiamo che la Sua richiesta, con Codice ID [Società]_[Data]_[N° Progressivo .xls], pervenuta in data gg/mm/yyyy è stata completata.

⁴² Si veda **Par. 4.4 - Ulteriori precisazioni** per il dettaglio sui tempi di risposta.



Abbiamo provveduto a [descrivere le attività condotte in funzione del diritto esercitato].

[Esempio] Tuttavia, La informiamo inoltre che, avendo un reclamo attivo presentato in data gg/mm/aaaa, non possiamo dar seguito alla Sua richiesta di cancellazione totale. I dati relativi al reclamo, ed eventuali informazioni correlate, verranno conservati per 10 anni dalla data di chiusura della pratica al fine di tutelare la società da eventuali futuri contenziosi [inserire riferimento normativo]. Trascorsi tali termini i dati verranno cancellati. Le garantiamo comunque che non riceverà comunicazioni commerciali o di servizio per cui non vi sia un obbligo di legge.

[Esempio] Tuttavia, La informiamo inoltre che la Società, avendo un'attività di recupero crediti in corso in data gg/mm/aaaa, non può dar seguito alla Sua richiesta di cancellazione totale. I dati relativi all'attività di recupero crediti, ed eventuali informazioni correlate, verranno conservati per 10 anni dalla data di chiusura al fine di rispettare i termini di conservazione previsti da legge [inserire riferimento normativo]. In questo caso i Suoi dati potranno essere trasferiti anche all'Agenzia delle Entrate. Trascorsi tali termini i dati verranno cancellati. Le garantiamo comunque che non riceverà comunicazioni commerciali o di servizio per cui non vi sia un obbligo di legge.

[Esempio] Tuttavia, La informiamo inoltre che, avendo acquistato un titolo di viaggio in data gg/mm/aaaa, non potremo procedere alla cancellazione di tali dati perché non sarebbe più in grado di effettuare eventuali cambi o presentare una richiesta di rimborso. Tali dati verranno conservati per 10 anni dalla data del viaggio e successivamente cancellati.

Cordiali saluti.

Infine, il DPO procede alla chiusura del *ticket*. Le richieste pervenute, corredate della relativa documentazione, dell'esito dell'istruttoria e della risposta all'interessato, dovranno essere conservate in digitale dal DPO per un periodo di tempo conforme a quanto definito nelle linee di indirizzo in materia di conservazione dei dati personali.

4.4 Ulteriori precisazioni

Come già riportato in premessa, il Titolare è tenuto ad agevolare l'esercizio dei diritti dell'interessato fornendo allo stesso le informazioni richieste **senza ingiustificato ritardo e comunque al più tardi entro un mese dal ricevimento della richiesta stessa**. Tale termine può essere prorogato di **due mesi**, se necessario, tenuto conto della complessità e del numero delle richieste; in questo caso il Titolare deve informare l'interessato di tale proroga, e dei motivi del ritardo, entro un mese dal ricevimento della richiesta.

Si specifica che alcuni processi di gestione delle richieste di esercizio dei diritti possono essere gestiti interamente dal *Data Manager* per competenza, in accordo con il DPO. In tali casi la presa in carico, il seguito dell'istruttoria e il riscontro all'interessato sono gestiti interamente dal *Data Manager*, che ne informa il DPO.

Si specifica inoltre che in taluni casi, come in parte anticipato nel paragrafo precedente, potrebbero presentarsi impedimenti rispetto a specifiche richieste da parte degli interessati, ad esempio:

- **Obblighi del Titolare che impediscono di ottemperare alla richiesta dell'interessato:** ad esempio, una richiesta di cancellazione totale dei dati personali potrebbe scontrarsi con la presenza di un reclamo attivo o la pendenza di un contenzioso stragiudiziale o giudiziale in atto'. In questi casi è possibile procedere al blocco/cancellazione/anonimizzazione parziale dei trattamenti non strettamente legati a processi che richiedono un obbligo di conservazione più lungo, rimandando la completa cancellazione ai termini di *data retention* previsti. In tali casi, gli impedimenti dovranno essere chiaramente descritti all'interessato nella comunicazione di riscontro.



- **Improcedibilità oggettiva della richiesta:** nel caso in cui non si riscontri la presenza dell'interessato all'interno dei sistemi IT e/o negli archivi cartacei aziendali, sarà sufficiente comunicare all'interessato l'assenza dei propri dati personali.
- **Impossibilità di identificare univocamente l'interessato:** il Titolare può non ottemperare alla richiesta avanzata dall'interessato, se dimostra di non essere stato in grado di identificare univocamente l'interessato.

In tutti i predetti casi, il DPO o, se concordato diversamente⁴³, il *Data Manager*, fornisce ugualmente riscontro all'interessato entro 1 mese dalla ricezione della richiesta indicando il motivo dell'impedimento.

Se le richieste dell'interessato sono manifestamente infondate o eccessive (es. per il loro carattere ripetitivo e pretestuoso), il *Data Manager*, sentito il DPO, potrà scegliere se:

- addebitare un contributo spese ragionevole all'interessato, tenendo conto dei costi amministrativi sostenuti per fornire le informazioni o intraprendere l'azione richiesta;
- rifiutare di evadere/soddisfare la richiesta dell'interessato, indicando i motivi dell'inottemperanza e della possibilità di proporre reclamo ad un'autorità di controllo o di proporre ricorso giurisdizionale.

Infine, si riportano di seguito alcuni esempi di richieste “**complesse**”:

- 2 o 3 diritti richiesti in contemporanea (es. accesso, portabilità e successiva cancellazione);
- richiesta di portabilità dei dati verso un numero elevato di soggetti terzi, potenzialmente con informazioni e formati diversi;
- richiesta congiunta da parte di uno o più soggetti rappresentanti da un unico soggetto (es. accesso ai dati e successiva cancellazione dei dati di 100 clienti rappresentanti da una Società specializzata nell'esercizio dei diritti).

In tal caso, la risposta è prorogabile di ulteriori due mesi. Il DPO o, se concordato diversamente, il *Data Manager*, informerà l'interessato entro un mese dal ricevimento della richiesta in merito alla necessità di proroga e dei motivi della stessa.

⁴³ Per le richieste di esercizio ricorrenti (richieste frequenti e simili, ad es. richieste di cancellazione dei CV dalla sezione “lavora con noi” del sito), il *Data Manager*, in accordo con il DPO può procedere in autonomia o implementare meccanismi automatici di risposta ed elaborazione della richiesta. In questi casi il DPO è comunque sempre informato e le modalità alternative sono formalizzate dal *Data Manager*.



SEZIONE D

GESTIONE DELLE TERZE PARTI



SEZIONE D	53
1. LA GESTIONE DELLE TERZE PARTI NELL'AMBITO DELLA PROTEZIONE DEI DATI PERSONALI	55
1.1 PREMessa E DEFINIZIONI.....	55
2. DETERMINAZIONE DEL RUOLO DELLA TERZA PARTE.....	56
3. ACCORDI CON LE TERZE PARTI.....	60
3.1 RESPONSABILE DEL TRATTAMENTO	60
3.2 ALTRO RESPONSABILE (O SUB-RESPONSABILE)	61
3.3 CONTITOLARI.....	62
3.4 TITOLARI AUTONOMI.....	62
 INDICE DELLE FIGURE	 88
 INDICE DELLE TABELLE	 88
 GLOSSARIO	 89



1. La gestione delle terze parti nell'ambito della protezione dei dati personali

1.1 Premessa e definizioni

Il Regolamento UE 679/2016 (anche “GDPR” o “Regolamento”) disciplina, al Capo IV (artt. 24, 26, 28, 29), i rapporti tra il Titolare del trattamento e le terze parti. Le *guidelines* in materia dell’*European Data Protection Board*⁴⁴ forniscono, inoltre, chiarimenti interpretativi sui ruoli di Titolare e terze parti coinvolte nella attività di trattamento. All’interno del *framework* di *data protection* adottato dal Gruppo FS Italiane, per “terza parte” si intende il fornitore di beni e/o servizi o partner commerciale/industriale o altro soggetto terzo, la persona fisica o giuridica - ivi incluse Società appartenenti al Gruppo FS Italiane – che, nello svolgimento di una prestazione oggetto di un contratto o di un altro atto avente natura negoziale con la Società (Titolare del trattamento), effettua un trattamento di dati personali.

Il Regolamento prevede due principali tipologie di “terza parte” distinte in funzione delle responsabilità attribuite dal Titolare nel trattamento di dati personali:

- **Responsabile del trattamento** (Art. 28 del Regolamento): la persona fisica o giuridica, l’autorità pubblica, il servizio o altro organismo che tratta dati personali **per conto** del Titolare; un Responsabile del trattamento, se autorizzato dal Titolare, può ricorrere ad un altro Responsabile (anche “sub-Responsabile”).
- **Contitolare** (Art. 26 del Regolamento): allorché due o più titolari del trattamento determinano **congiuntamente** le finalità e i mezzi del trattamento, essi sono contitolari del trattamento.

Si specifica che può configurarsi come “terza parte” anche una persona fisica o giuridica, autorità pubblica, servizio o altro organismo che abbia un rapporto di natura negoziale con una Società del Gruppo FS Italiane ma che agisca determinando **autonomamente** le proprie finalità e i mezzi del trattamento, in qualità di Titolare (anche “Titolare autonomo” nel seguito del documento).

In tutti i casi in cui il trattamento di dati personali necessita dell’intervento di una terza parte Responsabile o Contitolare⁴⁵, il Titolare è tenuto a disciplinare “*con un contratto o altro atto giuridico*” i reciproci obblighi rispetto alle finalità del trattamento e alla protezione dei dati personali. Tale contratto/atto giuridico è generalmente denominato “accordo di *data protection*” o “*data protection agreement*”.

Le Società del Gruppo FS Italiane, in funzione del ruolo esercitato nel trattamento di dati personali possono configurarsi rispettivamente: titolari, responsabili (o sub-responsabili) e contitolari del trattamento.

Nelle presenti Linee di Indirizzo si riportano: il processo utile a determinare i ruoli in ambito *data protection* (Titolare, Contitolare, Responsabile, sub-Responsabile) e le indicazioni per la stipula degli accordi di *data protection*.

⁴⁴ “*Guidelines 07/2020 on the concepts of controller and processor in the GDPR*” – *European Data Protection Board*

⁴⁵ Si specifica che per “Terza Parte” può intendersi anche Società appartenente al Gruppo FS Italiane.



2. Determinazione del ruolo della terza parte

Il *Data Manager* è la figura che stabilisce, sulla base delle finalità del trattamento, l'eventuale necessità di avvalersi di soggetti terzi rispetto alla Società. Al fine di individuare la tipologia di rapporto con la terza parte ai sensi del Regolamento e stabilire la necessità di prevedere un accordo di *data protection*, il *Data Manager* deve seguire alcuni passaggi logici sintetizzati in **Figura 6** e descritti di seguito.

- **Step 1 – Verifica della necessità di avvalersi di una terza parte.** In questa fase il *Data Manager* deve stabilire se l'esigenza di *business*/operativa richiede il coinvolgimento di una terza parte nel trattamento di dati personali⁴⁶. In tal senso, ove possibile, dovranno essere preferite modalità che non comportano il trattamento di dati personali da parte della terza parte, ad esempio mediante l'adozione di tecniche di anonimizzazione o pseudonimizzazione⁴⁷.

Nota bene: in tutti i contratti relativi alla fornitura di beni o servizi, accade che le parti si scambino dati personali relativi ai propri dipendenti (ad es. documentazione aziendale riportante il nome e cognome del soggetto firmatario, i contatti aziendali di un referente, i nominativi dei membri di un team per la convocazione di una riunione, etc.). In questi casi la terza parte non tratta dati personali per conto della Società del Gruppo FS Italiane e quindi non si configura come un Responsabile del trattamento. Pertanto, non occorre un accordo di *data protection* e i relativi ruoli sono disciplinati nella "Clausola sulla protezione dei dati personali" (anche "clausola standard") che è riportata obbligatoriamente in tutti i contratti con le terze parti.

- **Step 2 – Verifica del ruolo della terza parte.** In questa fase il *Data Manager* deve stabilire le modalità con cui la terza parte esegue il trattamento dei dati personali:
 - La terza parte si configura come **Responsabile** se le finalità e i mezzi del trattamento sono stabiliti dal Titolare (*Data Manager*); in tal caso il Responsabile agisce solo su istruzione documentata del *Data Manager* e non ha possibilità di trattare i dati personali oggetto del contratto in maniera autonoma. Rispetto alla totalità delle relazioni con le terze parti, questo caso è il più frequente.

Esempio #1: "La Società si avvale di una Società interna al Gruppo per l'elaborazione e l'emissione delle buste paga dei propri dipendenti."

In questo caso il Titolare, per il tramite del *Data Manager*, determina la finalità del trattamento (elaborazione ed emissione buste paga), formalizzando nell'accordo le responsabilità del Responsabile in materia di misure di sicurezza tecnico-organizzative, durata del trattamento, etc.

- La terza parte si configura come **Contitolare** se le finalità e i mezzi del trattamento sono stabiliti congiuntamente ed entrambe le parti hanno possibilità di trattare i dati personali

⁴⁶ Resta inteso che l'esigenza di *business*/operativa che comporta il trattamento dei dati personali dovrà essere sottoposta al processo di *pre-assessment* ed eventuale *data protection impact assessment* descritto nelle linee di indirizzo per l'identificazione dei trattamenti a potenziale rischio elevato e *data protection impact assessment* ([Sezione B](#) del presente documento)

⁴⁷ Si vedano le linee di indirizzo per la *data protection by design* e *by default* ([Sezione A](#) del presente documento).



per le finalità e con i mezzi condivisi. Rispetto alla totalità delle relazioni con le terze parti, questo caso ha carattere di marginalità.

Esempio #2: *“La Società predispone una iniziativa commerciale con un’altra società di trasporti, condividendo la base clienti.”*

In questo caso i partner determinano congiuntamente la finalità del trattamento (iniziativa commerciale), stabiliscono il sistema informatico di condivisione della base clienti, formalizzando nell’accordo i rispettivi ruoli e le responsabilità e i relativi obblighi in termini di misure di sicurezza. Nei casi di contitolarità viene rilasciata un’informativa comune ed indicato un unico punto di contatto.

- la terza parte si configura come **Titolare autonomo** se stabilisce autonomamente le finalità e i mezzi del trattamento e/o non accetta le istruzioni sulle finalità e i mezzi del trattamento da parte del *Data Manager*. Rispetto alla totalità delle relazioni con le terze parti, questo caso è relativamente frequente.

Esempio #3: *“Una Società del Gruppo decide di offrire una copertura assicurativa ai propri dipendenti, affidando l’incarico ad una compagnia assicurativa.”*

In questo caso la compagnia assicurativa agisce in completa autonomia rispetto alle finalità del Titolare, rilascia un’informativa autonoma ed è autonoma nella scelta dei mezzi e delle misure di sicurezza da impiegare nel trattamento.

- **Step 3 – Redazione documenti e avvio gara/affidamento.** Individuato il ruolo della terza parte, è possibile procedere con la stesura del capitolato di gara e/o con il contratto ovvero con la redazione di altro atto negoziale:
 - Se la terza parte si configura come **Responsabile** sarà necessario stipulare un accordo di *data protection* Titolare-Responsabile, secondo i *template* disponibili sulla intranet aziendale nella sezione *Data Protection*. Nella maggior parte dei casi, sarà inoltre necessario prevedere specifici requisiti nei capitolati di gara, nei contratti di affidamento nonché negli altri atti di natura negoziale, con particolare riferimento alle modalità di trattamento e alle misure di sicurezza tecnico-organizzative richieste al Responsabile, anche sulla base degli esiti dell’eventuale processo di *Data Protection Impact Assessment*⁴⁸.
 - Se la terza parte si configura come **Contitolare** sarà necessario stipulare un accordo di *data protection* di contitolarità, secondo i *template* disponibili sulla intranet aziendale nella sezione *Data Protection*.
 - Se la terza parte si configura come **Titolare autonomo** sarà necessario prevedere una clausola contrattuale che formalizza la titolarità autonoma delle parti, secondo i *template* disponibili sulla intranet aziendale nella sezione *Data Protection*.

L’identificazione dei ruoli in ambito *data protection* e la relativa stesura degli accordi non è sempre lineare e può comportare alcune difficoltà operative (ad esempio, talvolta vi è la necessità di stabilire accordi di tipo

⁴⁸ Si vedano linee di indirizzo per l’identificazione dei trattamenti a potenziale rischio elevato e *data protection impact assessment* ([Sezione B](#) del presente documento).



“misto”). Per tale motivazione, il DPO ha il compito di assistere il *Data Manager* in tutti i suddetti passaggi, con il supporto delle funzioni Legale/*Compliance*, ove necessario.

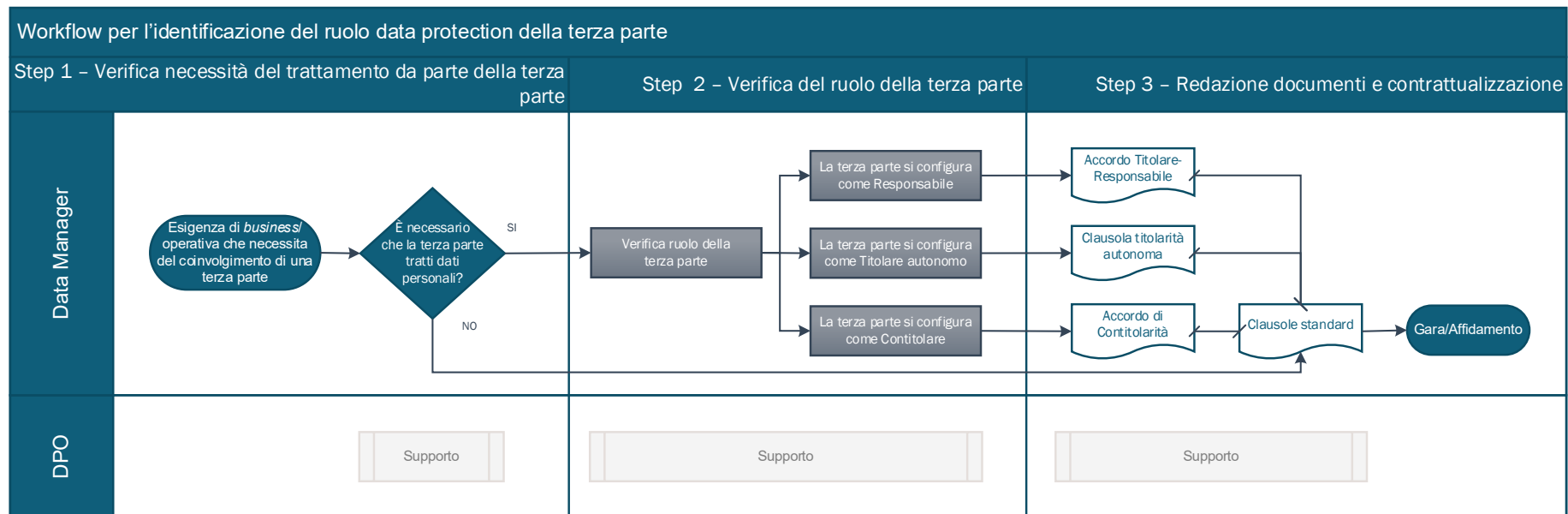


Figura 6 – Workflow per l'identificazione del ruolo data protection della terza parte



3. Accordi con le terze parti

Di seguito sono descritte le modalità operative di stesura degli accordi con le terze parti.

3.1 Responsabile del trattamento

Ai sensi dell'Art. 28 del Regolamento, il Titolare è tenuto a ricorrere unicamente a responsabili che presentino garanzie sufficienti per mettere in atto misure tecniche e organizzative adeguate in modo tale che il trattamento soddisfi i requisiti del Regolamento e garantisca la tutela dei diritti dell'interessato.

I trattamenti effettuati da parte di un Responsabile devono essere formalizzati all'interno di un accordo di *data protection* che vincoli il Responsabile al Titolare e che stipuli la materia disciplinata e la durata del trattamento, la natura e la finalità del trattamento, il tipo di dati personali e le categorie di interessati, gli obblighi e i diritti del Titolare. L'accordo di *data protection* tra Titolare e Responsabile prevede in particolare che il Responsabile:

- tratti i dati personali solo su istruzione documentata del Titolare;
- adotti le misure tecniche e organizzative idonee a garantire un livello di sicurezza adeguato al rischio e assista il Titolare nel garantire la sicurezza del trattamento;
- garantisca che le persone autorizzate al trattamento dei dati personali siano impegnate alla riservatezza o abbiano un adeguato obbligo legale di riservatezza;
- rispetti gli obblighi di collaborazione, informazione e notifica verso il Titolare con riferimento all'esercizio di diritti da parte degli interessati, alla gestione di eventuali *data breach* e delle eventuali comunicazioni all'Autorità di controllo e agli interessati, all'effettuazione di *data protection impact assessment* e al supporto in caso di consultazione preventiva;
- su scelta del Titolare, cancelli o restituisca tutti i dati personali al termine della prestazione dei servizi e cancelli le copie esistenti;
- metta a disposizione del Titolare tutte le informazioni necessarie per dimostrare il rispetto degli obblighi di cui all'Art. 28 e consenta e contribuisca alle attività di revisione, comprese le ispezioni, del Titolare;
- non ricorra ad altro Responsabile (o sub-Responsabile) senza previa autorizzazione da parte del Titolare (si veda **Par. 3.2 - Altro Responsabile**).

I requisiti di cui sopra rappresentano un obbligo legale prescritto dal Regolamento e, pertanto, sono disciplinati all'interno del *template* di accordo tra Titolare e Responsabile predisposto dal DPO di FS SpA e pubblicato sulla intranet aziendale nella sezione *Data Protection*. È compito del *Data Manager* selezionare responsabili che presentino garanzie sufficienti per mettere in atto misure tecniche e organizzative adeguate e procedere con la compilazione del *template* messo a disposizione, con l'eventuale supporto del DPO. In ragione degli obblighi previsti, eventuali modifiche rispetto ai contenuti del *template* dovranno essere condivise con il DPO.

In alcuni casi particolari, è ammessa la possibilità di utilizzare *template* proposti dalla terza parte. In questi casi, il *Data Manager* dovrà interessare preventivamente il DPO per valutare se i *template* proposti presentano tutti gli elementi previsti obbligatoriamente.

L'accordo di *data protection* dovrà essere stipulato contestualmente al **contratto/altro atto di natura negoziale** come parte integrante dello stesso e dovrà prevedere la sottoscrizione da parte di soggetto



esplicitamente procurato per la firma degli accordi di *data protection*. In alcuni casi particolari è possibile la sottoscrizione di un accordo di *data protection* come atto autonomo vincolante ai sensi dell'Art. 28.

Tra le sezioni del *template* che dovranno accuratamente essere compilate dal *Data Manager*, particolare attenzione meritano:

- la **descrizione delle attività di trattamento (istruzioni)**; dovranno infatti essere puntualmente riportati la materia disciplinata e la durata del trattamento, la natura e la finalità del trattamento, il tipo di dati personali e le categorie di interessati;
- le **misure di sicurezza tecniche ed organizzative**, che dovranno essere identificate sulla base degli esiti dell'eventuale *data protection impact assessment*.

Al fine di monitorare l'applicazione e l'efficacia delle misure il *Data Manager* valuterà l'opportunità di definire **(i)** dei *Service Level Agreement* associati a penali nel caso di mancato rispetto degli stessi e **(ii)** le modalità di verifica sul fornitore rispetto all'adozione delle misure contrattualizzate.

Dagli obblighi di cui sopra non sono esclusi i rapporti c.d. "infragruppo", cioè tra le Società del Gruppo FS Italiane, in cui una delle Società si configura come Responsabile del trattamento. In questi casi è possibile utilizzare un *template* di accordo di *data protection* semplificato, disponibile sulla intranet aziendale nella sezione *data protection*⁴⁹.

3.2 Altro Responsabile (o sub-Responsabile)

L'Art. 28 del Regolamento prevede la possibilità da parte del Responsabile, di avvalersi di un altro Responsabile (o sub-Responsabile). Tuttavia, il Responsabile non può avvalersi di altro Responsabile senza la preventiva autorizzazione da parte del Titolare. Pertanto, all'interno dell'accordo di *data protection*, laddove il Titolare lo ritenga opportuno, potrà essere prevista l'autorizzazione per il Responsabile ad avvalersi di uno o più sub-responsabili per l'espletamento dei servizi oggetto del contratto. L'autorizzazione può essere:

- **specifico:** il Titolare valuta di volta in volta se procedere o meno con l'autorizzazione del sub-Responsabile, utilizzando il *template* di autorizzazione presente sulla intranet aziendale nella sezione *Data Protection*;
- **generale:** il Titolare concede sempre al Responsabile la possibilità di avvalersi di sub-responsabili, prevedendo un'autorizzazione generale all'interno dell'accordo di *data protection*.

In considerazione dei rischi legati all'utilizzo dell'autorizzazione generale, tale possibilità andrà preventivamente discussa con il DPO.

Il Responsabile dovrà in ogni caso garantire che il sub-Responsabile fornisca garanzie sufficienti per attuare misure tecniche e organizzative adeguate in modo tale che il trattamento soddisfi i requisiti del Regolamento e garantisca la tutela dei diritti dell'interessato. Una volta autorizzato dal Titolare, il Responsabile formalizzerà un accordo scritto con il sub-Responsabile⁵⁰, imponendo a quest'ultimo gli stessi obblighi

⁴⁹ Nei casi (residuali) in cui la Società del Gruppo FS Italiane effettui trattamenti per conto di un titolare esterno al Gruppo, andranno generalmente utilizzati i *template* proposti dal titolare esterno. In questi casi, è necessario un passaggio con il DPO al fine di verificare i seguenti aspetti: (i) obblighi del Titolare, (ii) tempi per l'esercizio dei diritti degli interessati e di comunicazione di eventuali *data breach*, (iii) misure di sicurezza tecniche ed organizzative richieste.

⁵⁰ L'accordo di *data protection* fra responsabile e sub-responsabile è redatto secondo i *template* del Responsabile; per le Società del Gruppo FS Italiane i *template* disponibili sulla intranet aziendale nella sezione *Data Protection*.



stabiliti nell'accordo di *data protection* con il Titolare. Il Responsabile dei dati rimane pienamente responsabile nei confronti del Titolare per l'adempimento degli obblighi dei sub-responsabili.

Dagli obblighi di cui sopra non sono esclusi i rapporti c.d. "infragruppo", cioè tra le Società del Gruppo FS Italiane, in cui una delle Società si configura come sub-Responsabile del trattamento. In questi casi è tuttavia possibile utilizzare un *template* di accordo di *data protection* semplificato, disponibile sulla intranet aziendale nella sezione *data protection* ⁵¹.

3.3 Contitolari

Ai sensi dell'Art. 26 del Regolamento, allorché due titolari determinano congiuntamente le finalità e i mezzi del trattamento, esse sono contitolari del trattamento. Esse devono, mediante un accordo di *data protection*, determinare in maniera trasparente:

- i ruoli e i rapporti dei contitolari con gli interessati;
- i relativi compiti e le rispettive responsabilità riguardo all'osservanza del Regolamento, con particolare riguardo alle comunicazioni ex artt. 13 e 14 del Regolamento (informativa) e all'esercizio dei diritti dell'interessato;
- il punto di contatto comune per gli interessati (ad es. una casella di posta comune).

Tutti questi aspetti sono disciplinati all'interno del *template* di accordo tra contitolari pubblicato sulla intranet aziendale nella sezione *Data Protection*, che dovranno essere opportunamente compilati a cura del *Data Manager*, con il supporto del DPO.

In alcuni casi particolari, è ammessa la possibilità di utilizzare *template* proposti dalla terza parte. In questi casi, il *Data Manager* dovrà interessare preventivamente il DPO per valutare se i *template* proposti presentano tutti gli elementi previsti obbligatoriamente.

L'accordo di *data protection* dovrà essere stipulato contestualmente al contratto /altro atto di natura negoziale come parte integrante dello stesso e dovrà prevedere la sottoscrizione da parte di soggetto esplicitamente procurato per la firma degli accordi di *data protection*. In alcuni casi particolari è possibile la sottoscrizione di un accordo di *data protection* come atto autonomo vincolante ai sensi dell'Art. 26.

Tra le sezioni del *template* che dovranno accuratamente essere compilate dal *Data Manager*, particolare attenzione meritano le misure di sicurezza tecniche ed organizzative, che dovranno essere identificate sulla base degli esiti dell'eventuale *data protection impact assessment*.

Dagli obblighi di cui sopra non sono esclusi i rapporti c.d. "infragruppo", cioè tra le Società del Gruppo FS Italiane, in cui una due o più Società del Gruppo si configurano come contitolari.

3.4 Titolari autonomi

Nel caso in cui la terza parte determini in maniera autonoma, ovvero senza ricevere istruzioni in proposito dal Titolare o essere vincolata ad essa da un accordo di contitolarità, le finalità e i mezzi del trattamento, essa ricopre il ruolo di Titolare autonomo. In questo caso il Titolare autonomo è obbligato ad adempiere

⁵¹ Nei casi (residuali) in cui la Società del Gruppo FS Italiane effettui trattamenti per conto di un responsabile esterno al Gruppo, andranno generalmente utilizzati i *template* proposti dal responsabile esterno. In questi casi, è necessario un passaggio con il DPO al fine di verificare i seguenti aspetti: (i) obblighi del Responsabile, (ii) tempi per l'esercizio dei diritti degli interessati e di comunicazione di eventuali *data breach*, (iii) misure di sicurezza tecniche ed organizzative richieste.



puntualmente alle prescrizioni del Regolamento in piena autonomia e sotto la propria esclusiva responsabilità.

Al fine di disciplinare tale rapporto è sufficiente dichiarare la titolarità autonoma delle parti all'interno del contratto/altro atto di natura negoziale, utilizzando una clausola specifica disponibile sulla intranet aziendale nella sezione *Data Protection*.





SEZIONE E

GESTIONE DELLE VIOLAZIONI DI DATI PERSONALI (“DATA BREACH”)



SEZIONE E.....	65
1. LA GESTIONE DELLE VIOLAZIONI DI DATI PERSONALI (“DATA BREACH”).....	67
1.1 PREMessa E DEFINIZIONI.....	67
2. IL PROCESSO DI GESTIONE DEI DATA BREACH.....	69
2.1 FASE 1 – RILEVAZIONE	69
2.2 FASE 2 – IDENTIFICAZIONE	70
2.3 FASE 3 – VALUTAZIONE.....	70
2.4 FASE 4 – GESTIONE E RISPOSTA	71
2.4.1 GESTIONE DEL DATA BREACH – REMEDIATION (BREVE TERMINE).....	71
2.4.2 ATTIVAZIONE DELLE PROCEDURE DI CRISIS MANAGEMENT.....	72
2.4.3 NOTIFICA AL GARANTE E COMUNICAZIONI AGLI INTERESSATI.....	72
NOTIFICA AL GARANTE PER LA PROTEZIONE DEI DATI PERSONALI.....	72
COMUNICAZIONE AGLI INTERESSATI.....	73
2.5 FASE 5 – POST INCIDENT REVIEW (EVENTUALE).....	74
2.5.1 INTEGRAZIONE DATA BREACH REPORT E REMEDIATION PLAN (LUNGO TERMINE)	74
2.5.2 REGISTRO VIOLAZIONI DI DATI PERSONALI E REGISTRO DEI NEAR MISS.....	74
4. MATRICE DI DATA RETENTION.....	87
 INDICE DELLE FIGURE	 88
 INDICE DELLE TABELLE	 88
 GLOSSARIO	 89

1. La gestione delle violazioni di dati personali (*“Data Breach”*)

1.1 Premessa e definizioni

Il Regolamento UE 2016/679 (anche “GDPR”) introduce il concetto di **“violazione dei dati personali”** (nel seguito per *“data breach”*, si fa riferimento esclusivamente a violazioni che riguardino Dati Personali⁵² e non ad altre tipologie di informazioni) ossia la violazione di sicurezza che comporta accidentalmente o in modo illecito⁵³ la distruzione, la perdita, la modifica, l’indisponibilità, la divulgazione non autorizzata o l’accesso ai dati personali trasmessi, conservati o comunque trattati. In particolare, secondo quanto previsto dal WP250 rev.01 – *Working Party 29 – “Guidelines on Personal data breach notification under Regulation 2016/679”*, gli eventi di possibile violazione dei dati personali possono essere suddivisi in tre macro-categorie:

- **“Violazione di confidenzialità”**: in caso di divulgazione dei dati personali e/o accesso agli stessi non autorizzati o accidentali;
- **“Violazione di disponibilità”**: in caso di perdita, accesso o distruzione accidentali o non autorizzati di dati personali⁵⁴;
- **“Violazione di integrità”**: in caso di alterazione non autorizzata o accidentale dei dati personali.

Una violazione può riguardare contemporaneamente la confidenzialità, l’integrità e la disponibilità dei dati personali, nonché qualsiasi combinazione delle stesse.

Il Regolamento specifica, all’Art. 33, che il Titolare **notifica** la violazione all’autorità di controllo competente senza ingiustificato ritardo e, ove possibile, entro 72 ore dal momento in cui ne sia venuto a conoscenza, a

⁵²All’interno del Gruppo FS Italiane, si intende per *data breach* una violazione di sicurezza che comporta, accidentalmente o in modo illecito, le seguenti tipologie di eventi (a titolo esemplificativo e non esaustivo) aventi ad oggetto **“dati personali”**:

- **distruzione di dati personali su supporti digitali o cartacei**, intesa come indisponibilità irreversibile di dati con accertata impossibilità di ripristino degli stessi, conseguente ad eliminazione logica (es. errata cancellazione dei dati nel corso di un intervento manuale o automatizzato) o fisica (es. rottura di dispositivi di memorizzazione informatica, incendio/allagamento locali dove sono archiviati i contratti ed altri documenti dei clienti);
- **perdita di dati personali, conseguente a smarrimento/furto di supporti digitali** (es. *laptop, hard-disk, memory card, smartphone, etc.*) o cartacei (in originale o in copia);
- **accesso non autorizzato o intrusione nei Sistemi IT**, mediante lo sfruttamento di vulnerabilità dei sistemi e delle reti o la compromissione o rilevazione abusiva di credenziali di autenticazione (es. *userid e password*);
- **modifica non autorizzata di dati personali**, derivante ad esempio da un’erronea esecuzione di interventi sui sistemi digitali o cartacei o da interventi intenzionali non autorizzati;
- **diffusione di dati personali a soggetti terzi non autorizzati**, anche non identificati, conseguenti ad esempio alla diffusione verbale, ad invio intenzionale o accidentale di documenti o errata gestione di supporti digitali;
- **indisponibilità dei dati personali temporanea** che abbia, comunque, un impatto significativo sui diritti e sulle libertà delle persone fisiche salvo quelle derivanti dallo svolgimento di programmati interventi di manutenzione.

⁵³ Un trattamento non autorizzato o illecito può includere la divulgazione di dati personali a (o l’accesso da parte di) destinatari non autorizzati a ricevere (o ad accedere a) i dati oppure qualsiasi altra forma di trattamento in violazione del regolamento.

⁵⁴ L’indisponibilità dei dati personali dovuta allo svolgimento di un intervento di manutenzione programmata del sistema non costituisce una “violazione della sicurezza”.



meno che sia improbabile che la violazione dei dati personali presenti un rischio per i diritti e le libertà delle persone fisiche, nel qual caso la notifica non è dovuta. Una notifica effettuata oltre il termine delle 72 ore deve essere corredata dai motivi del ritardo.

Inoltre, a norma dell'art. 34 del Regolamento, quando la violazione dei dati personali potrebbe determinare un rischio elevato per i diritti e le libertà delle persone fisiche, il Titolare **comunica la violazione all'interessato** senza ingiustificato ritardo⁵⁵.

È parimenti obbligo del/i Responsabile/i del trattamento informare il Titolare senza ingiustificato ritardo dopo essere venuto a conoscenza della violazione. Nel caso in cui una Società del Gruppo FS Italiane in qualità di Titolare del trattamento abbia affidato servizi che comportino trattamento di dati personali ad una Terza Parte (anche nelle ipotesi di contratti infragruppo), quest'ultima dovrà segnalare senza ingiustificato ritardo alla Società Titolare del trattamento eventuali casi di *data breach*, secondo quanto previsto dagli artt. 33 e 34 del Regolamento, ed in funzione degli accordi di *data protection* stipulati tra le parti.

Tale obbligo di informativa senza ingiustificato ritardo nei confronti del Titolare ricade anche sulle Società del Gruppo FS Italiane che trattino dati personali di una Terza Parte (anche nelle ipotesi di contratti infragruppo) in qualità di responsabili del trattamento. Qualora fornisca servizi a più titolari del trattamento tutti interessati dal medesimo incidente, il Responsabile del trattamento dovrà segnalare i dettagli dell'incidente a ciascun Titolare del trattamento.

In ipotesi di contitolarità il (con)titolare del trattamento assumerà il comando o sarà responsabile del rispetto degli obblighi di notifica delle violazioni previsti dal regolamento in base a quanto stabilito a tal riguardo dal relativo accordo di *data protection*.

⁵⁵ La comunicazione all'interessato non è richiesta se è soddisfatta una delle seguenti condizioni:

- a) il titolare del trattamento ha messo in atto le misure tecniche e organizzative adeguate di protezione e tali misure erano state applicate ai dati personali oggetto della violazione, in particolare quelle destinate a rendere i dati personali incomprensibili a chiunque non sia autorizzato ad accedervi, quali la cifratura;
- b) il titolare del trattamento ha successivamente adottato misure atte a scongiurare il sopraggiungere di un rischio elevato per i diritti e le libertà degli interessati;
- c) detta comunicazione richiederebbe sforzi sproporzionati. In tal caso, si procede invece a una comunicazione pubblica o a una misura simile, tramite la quale gli interessati sono informati con analoga efficacia.

Nel caso in cui il titolare del trattamento non abbia ancora comunicato all'interessato la violazione dei dati personali, l'autorità di controllo può richiedere, dopo aver valutato la probabilità che la violazione dei dati personali presenti un rischio elevato, che vi provveda o può decidere che una delle summenzionate condizioni è soddisfatta.

Si specifica, infine, che la comunicazione all'interessato deve descrivere con un linguaggio semplice e chiaro la natura della violazione dei dati personali e contiene almeno le informazioni e le misure di cui all'articolo 33, paragrafo 3, lettere b), c) e d).

2. Il processo di gestione dei *data breach*

Il Gruppo FS Italiane ha definito un processo strutturato di *data breach management* con l'obiettivo di gestire le segnalazioni di potenziali violazioni di dati personali e valutare la gravità dell'evento rispetto ai diritti e le libertà degli interessati. Tale valutazione è necessaria al fine di stabilire se procedere o meno con la notifica all'Autorità Garante ed eventualmente agli interessati coinvolti.

Ogni violazione dei dati personali, occorsa all'interno del Gruppo FS Italiane, deve essere gestita in linea con quanto previsto nelle fasi sintetizzate nella Figura 7 e descritte nel seguito del documento.

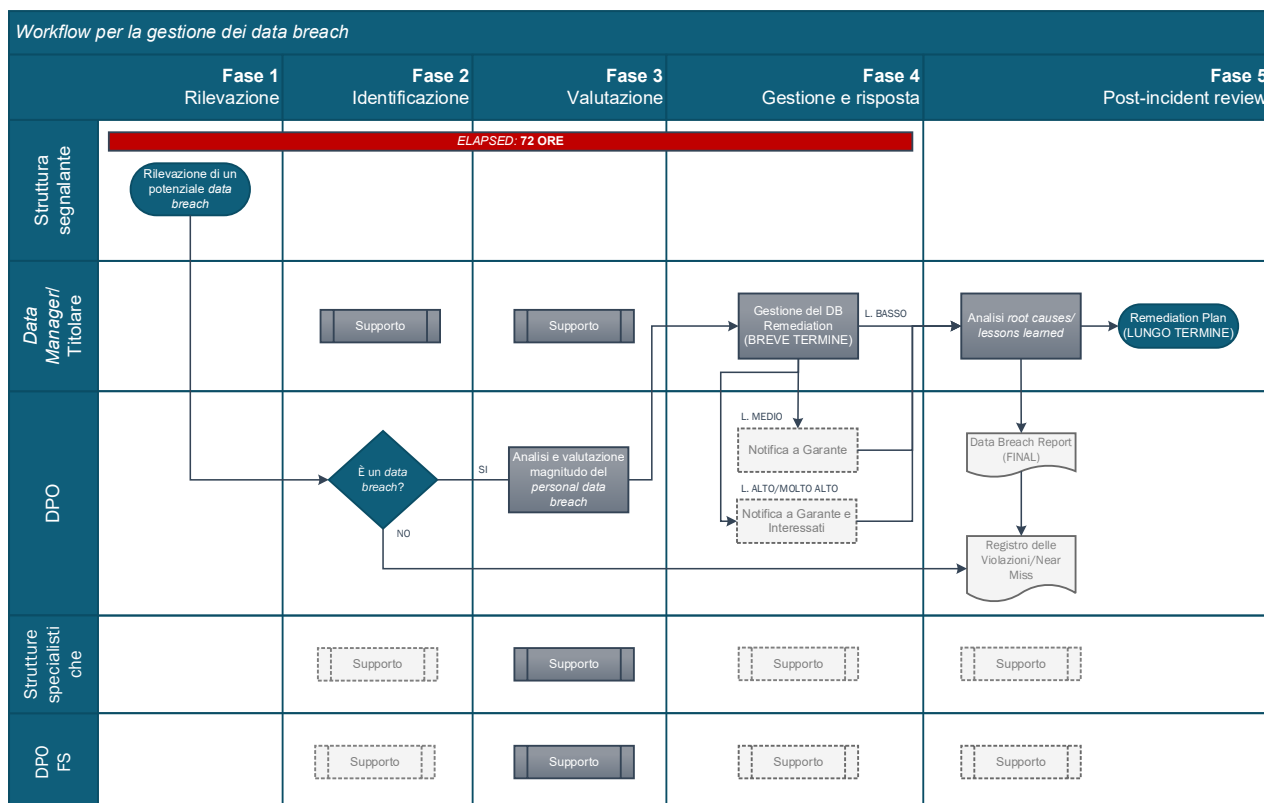


Figura 7 – Workflow per la gestione dei data breach

2.1 Fase 1 – Rilevazione

Qualsiasi struttura organizzativa del Gruppo FS Italiane che rilevi, anche per il tramite di collaboratori esterni, clienti e fornitori, un potenziale *data breach*, è tenuta a dare tempestiva comunicazione al DPO all'indirizzo e-mail personale e/o di struttura oppure utilizzando gli strumenti specifici di cui l'azienda si è dotata (es. gestionale IT). La rilevazione di un potenziale *data breach* può avvenire da parte di:

- terze parti esterne al Gruppo FS Italiane (ad esempio, responsabili del trattamento/contitolari/altri titolari autonomi, interessati, associazioni di categoria, Forze dell'Ordine, Autorità di controllo, etc.);
- strutture organizzative della Società (ad esempio, un dipendente che si rende conto di aver smarrito un faldone);
- soggetto tecnico responsabile dei sistemi informativi;



- sistemi di monitoraggio della sicurezza informatica del Gruppo FS Italiane (in particolare, *Cyber Security* di FS SpA).

Stante il limitato arco temporale a disposizione del DPO per gestire e comunicare l'eventuale *data breach* (72 ore solari dalla ricezione della segnalazione) tutte le strutture organizzative che rilevano un potenziale *data breach* sono tenute a segnalarlo senza ingiustificato ritardo e, possibilmente, entro 2 ore dalla scoperta. Nell'intento di perseguire tale obiettivo, le Società valutano l'adozione di idonei strumenti informatici volti a facilitare le segnalazioni di *data breach*.

2.2 **Fase 2 – Identificazione**

Il DPO valuta la segnalazione ricevuta, interessando tutte le strutture organizzative necessarie alla piena comprensione dell'evento. Possono verificarsi i seguenti casi:

- **L'evento segnalato non si configura come un *data breach*** (cd. falso positivo): il DPO, ove opportuno, aggiorna in tal senso il Registro dei *Near-Miss*⁵⁶.
- **L'evento segnalato si configura come un *data breach* senza violazione della sicurezza informatica** (ad es. furto di un faldone contenente documentazione cartacea, invio accidentale di una e-mail a destinatari non corretti, etc.): il DPO, in collaborazione con le strutture interessate e con il/i *Data Manager* responsabili per il/i trattamenti interessati, raccoglie tutte le informazioni necessarie alla piena comprensione dell'evento.
- **L'evento segnalato si configura come un *data breach* con violazione della sicurezza informatica** (ad es. esfiltrazione di dati a seguito di attacco informatico): *Cyber Security* di FS SpA, mediante il proprio *Computer Security Incident Response Team*, provvede ad attivare le procedure in materia di gestione degli incidenti di sicurezza informatica, aggiornando il DPO e il DPO di FS SpA.

Se l'evento viene classificato come *data breach*, il DPO, con il supporto delle strutture coinvolte, avvia la stesura del *Data Breach Report*⁵⁷ con tutte le informazioni al momento disponibili.

2.3 **Fase 3 – Valutazione**

La Fase 3 è dedicata alla valutazione della gravità del *data breach* in termini di impatto su diritti e libertà degli interessati coinvolti. Sulla base delle informazioni raccolte nella fase precedente, il DPO – se del caso, in funzione della gravità e tipologia della violazione – istituisce un Gruppo di Lavoro composto dalle strutture specialistiche a supporto del/i *Data Manager* coinvolti, generalmente composto dal soggetto tecnico responsabile dei sistemi informativi e *Cyber Security* di FS SpA. A seconda della natura del *data breach* possono anche essere coinvolte le strutture specialistiche necessarie per la piena comprensione dell'evento, incluso il DPO di FS SpA.

⁵⁶ Secondo il modello predisposto dal DPO di FS SpA riportato sulla intranet aziendale nella sezione *Data Protection*.

⁵⁷ Secondo il modello di notifica messo a disposizione dal Garante e disponibile sul sito www.gpdp.it



Il Gruppo di Lavoro così definito valuta la “magnitudo” del *data breach* mediante la “Metodologia di valutazione della gravità di un *data breach*”⁵⁸ disponibile sulla intranet aziendale nella sezione *Data Protection*, stimando il potenziale rischio per i diritti e le libertà delle persone fisiche.⁵⁹

All’esito di questa fase, il livello di gravità del *data breach* potrà essere stimato sulla base di 4 livelli riportati in **Tabella 2**.

Tabella 2 – Livelli di gravità del *data breach*

Livello	Descrizione
Basso	Il dato personale oggetto di <i>data breach</i> è tale per cui gli interessati non incontrano inconvenienti o incontrano inconvenienti poco significativi, che supereranno senza particolari difficoltà (visualizzazione di dati di contatto da parte di soggetti non interessati commercialmente agli stessi dati, tempo trascorso a reinserire informazioni accidentalmente cancellate, altri disagi minori, etc.).
Medio	Gli interessati potrebbero incontrare taluni disagi, che saranno in grado di superare nonostante alcune difficoltà (costi aggiuntivi, rifiuto di accesso ai servizi aziendali, paura, discriminazione lieve, stress, etc.).
Alto	Gli interessati potrebbero incontrare conseguenze significative, che dovrebbero essere in grado di superare anche se con gravi difficoltà (inserimento in <i>black-list</i> , danni alla proprietà, perdita di posti di lavoro, citazione in giudizio, peggioramento delle condizioni di salute, etc.).
Molto Alto	Gli interessati potrebbero incontrare conseguenze significative, o addirittura irreversibili, che difficilmente riescono a superare (difficoltà finanziarie, incapacità lavorativa, disturbi psicologici o fisici a lungo termine, gravi lesioni o morte, etc.).

Il DPO, sulla base delle informazioni raccolte e della valutazione di magnitudo del *data breach*, compila il *Data Breach Report*.

2.4 Fase 4 – Gestione e risposta

In tale fase il Gruppo di Lavoro definisce le *remediation* alla violazione al fine di attenuarne i possibili effetti negativi nel breve termine. In questa fase vengono, inoltre, valutate la necessità di attivazione di eventuali piani di *crisis management* e la necessità di comunicazione verso il Garante/gli interessati.

2.4.1 Gestione del Data Breach – Remediation (breve termine)

Il Gruppo di Lavoro definisce un piano di rimedio volto a gestire ed attenuarne i possibili effetti negativi nel breve termine. Ad esempio, il soggetto tecnico preposto alla gestione dei sistemi informativi attiva apposite misure di *remediation* finalizzate a proteggere gli asset soggetti a violazione, la funzione di Protezione

⁵⁸ La metodologia è basata sulle “*Recommendations for a methodology of the assessment of severity of personal data breaches*”, Dicembre 2013, *European Union Agency for Network and Information Security* (ENISA)

⁵⁹ L’*European Data Protection Board* ha adottato le *Guidelines 01/2021 on Examples regarding Data Breach Notification* che forniscono alcuni esempi di *data breach* e le modalità con cui devono essere gestiti.



Aziendale informa le autorità competenti nel caso di furto di un asset, la funzione di Organizzazione rivede le procedure di archiviazione di alcune tipologie di dati, etc.

L'implementazione delle *remediation* è responsabilità del *Data Manager* interessato dalla violazione, mentre spetta al DPO, nella sua funzione di controllo, monitorarne l'implementazione.

2.4.2 Attivazione delle procedure di crisis management e risk management

Nel caso in cui la violazione determini un impatto rilevante per una o più delle Società del Gruppo FS Italiane, il DPO – sentito il DPO di FS SpA e coordinandosi con lo stesso – attiva, ove definite, eventuali procedure di *crisis management* esistenti all'interno dell'organizzazione. In ogni caso, in presenza di un rilevante impatto reputazionale, il DPO informa prontamente i soggetti tecnici aziendali e di Capogruppo preposti alla gestione delle relazioni esterne e alla comunicazione aziendale.

Inoltre, il DPO – sentito il DPO FS SpA e coordinandosi con lo stesso – sulla base della magnitudo del *data breach*, del numero di interessati coinvolti, delle possibili sanzioni e dei potenziali risvolti reputazionali, informa le strutture di *risk management* affinché siano coinvolte nella valutazione dell'impatto per le Società interessate dal *data breach*.

2.4.3 Notifica al Garante e comunicazioni agli interessati

In base al livello di gravità del *personal data breach*, il DPO – d'intesa con il/i *Data Manager* coinvolti e sentito il DPO di FS SpA e coordinandosi con lo stesso – dovrà, secondo le regole sintetizzate nella **Tabella 3**, procedere con:

- la notifica al Garante per la Protezione dei Dati Personali;
- la comunicazione agli interessati coinvolti.

Tabella 3 - Regole per la notifica a Garante ed interessati

Livello	Notifica al Garante Privacy [ove possibile entro le 72 ore]	Comunicazione agli interessati [senza ingiustificato ritardo]
Basso	NO	NO
Medio	SI	NO
Alto	SI	SI
Molto Alto	SI	SI

Notifica al Garante per la Protezione dei Dati Personali

A norma dell'Art. 33 del Regolamento è prevista la notifica della violazione all'Autorità Garante senza ingiustificato ritardo e, ove possibile, entro 72 ore dal momento in cui il Titolare ne sia venuto a conoscenza, ossia dal momento in cui è ragionevolmente certo che si è verificato un incidente di sicurezza che ha portato



alla compromissione dei dati personali⁶⁰, a meno che sia improbabile che la violazione dei dati personali presenti un rischio per i diritti e le libertà delle persone fisiche.

Previa condivisione del *Data Breach Report* e degli esiti relativi alla valutazione degli impatti con il/i *Data Manager* coinvolti e/o con il rappresentante del Titolare (AD), il DPO – sentito il DPO di FS SpA e coordinandosi con lo stesso – procede alla notifica all’Autorità Garante, attraverso la procedura resa disponibile dal Garante per la Protezione dei Dati personali stesso sul proprio sito web⁶¹ ed inserendo le informazioni richieste. Qualora e nella misura in cui non sia possibile fornire le informazioni contestualmente, le informazioni dovranno essere fornite in fasi successive senza ulteriore ingiustificato ritardo.

Comunicazione agli interessati

Qualora la magnitudo del *data breach* presenti un rischio **alto** o **molto alto** per i diritti e le libertà degli interessati, il DPO – sentito il DPO di FS SpA e coordinandosi con lo stesso – dovrà valutare se ricorre uno dei seguenti casi (ai sensi dell’Art. 34 del Regolamento):

1. sono state adottate preventivamente dal Titolare misure tecniche e organizzative adeguate di protezione e tali misure erano state applicate ai dati personali oggetto della violazione, in particolare quelle destinate a rendere i dati personali incomprensibili a chiunque non sia autorizzato ad accedervi, quali la cifratura;
2. il Titolare ha adottato misure successive alla violazione che garantiscano la riduzione del rischio ad un livello considerato come medio o basso per i diritti e le libertà degli interessati;
3. le misure di cui ai punti 1. e 2. non sono ritenute sufficienti;
4. la comunicazione all’interessato comporta sforzi sproporzionati.

Nei casi 1. e 2. potrà non essere effettuata alcuna comunicazione agli interessati. Nel caso 3., il DPO – sentito il DPO di FS SpA e coordinandosi con lo stesso, darà comunicazione agli interessati senza ingiustificato ritardo tramite e-mail e/o lettera raccomandata.

Nei casi di particolare gravità o che coinvolgano un numero elevato di interessati, il DPO, inoltre, valuterà se sentire i soggetti tecnici aziendali e di Capogruppo preposti alla gestione delle relazioni esterne e alla comunicazione aziendale e informerà il rappresentante del Titolare (AD) e il Consiglio di Amministrazione.

La comunicazione all’interessato viene effettuata fornendo le seguenti informazioni e secondo le seguenti modalità⁶²:

- descrizione con linguaggio semplice e chiaro circa la natura della violazione dei dati personali;
- nome e i dati di contatto del DPO o di altro punto di contatto presso cui ottenere più informazioni;

⁶⁰ Se un soggetto informa il titolare del trattamento di una potenziale violazione o se egli stesso rileva un incidente di sicurezza, il titolare del trattamento può effettuare una breve indagine per stabilire se la violazione si sia effettivamente verificata. Durante il periodo di indagine il titolare del trattamento non può essere considerato “a conoscenza”. Tuttavia, si prevede che l’indagine inizi il più presto possibile e stabilisca con ragionevole certezza se si è verificata una violazione; può quindi seguire un’indagine più dettagliata.

⁶¹ Qualora la procedura on line non sia disponibile, la notifica avverrà via e-mail all’indirizzo garante@gpdp.it

⁶² Il Legislatore Europeo ha indicato le informazioni minimali che devono essere previste nelle notifiche. Qualora e nella misura in cui non sia possibile fornire le informazioni contestualmente, le informazioni possono essere fornite in fasi successive senza ulteriore ingiustificato ritardo.



- probabili conseguenze della violazione dei dati personali;
- descrizione delle misure adottate o di cui si propone l'adozione per porre rimedio alla violazione dei dati personali e anche, se del caso, per attenuarne i possibili effetti negativi.

Nel comunicare una violazione agli interessati si devono utilizzare messaggi dedicati che non devono essere inviati insieme ad altre informazioni, quali aggiornamenti regolari, newsletter o messaggi standard⁶³.

Nel caso 4. il DPO, sentito il DPO di FS SpA e coordinandosi con lo stesso, valuterà una modalità consona per darne comunicazione pubblica in modo tale che gli interessati vengano informati in modo efficace. Nei casi di particolare gravità o che coinvolgano un numero elevato di interessati, il DPO, inoltre, valuterà se sentire i soggetti tecnici aziendali e di Capogruppo preposti alla gestione delle relazioni esterne e alla comunicazione aziendale e informerà il rappresentante del Titolare (AD) e il Consiglio di Amministrazione.

2.5 **Fase 5 – Post Incident Review (eventuale)**

In questa fase (eventuale in considerazione della tipologia e della magnitudo del *data breach*) si concludono le attività di stesura del *Data Breach Report* e di analisi ex post della violazione al fine di comprendere le *root causes*⁶⁴, le *lesson learned*⁶⁵ e le opportunità di miglioramento.

2.5.1 Integrazione Data Breach Report e Remediation Plan (lungo termine)

Le Strutture interessate dalla violazione di sicurezza avviano gli opportuni approfondimenti, al fine di raggiungere la piena consapevolezza sulle cause del *data breach* e individuano le potenziali mitigazioni nel lungo periodo (*Remediation Plan*). Laddove necessario, in funzione dei tempi strettamente necessari per l'analisi, il DPO convoca il Gruppo di Lavoro per la chiusura del *Data Breach Report* integrato con le analisi su *root causes*, *lesson learned* e opportunità di miglioramento.

L'implementazione del *Remediation Plan* è responsabilità del *Data Manager* interessato dalla violazione, mentre spetta al DPO, nella sua funzione di controllo, monitorarne l'implementazione.

Il DPO provvede alla compilazione del Registro delle Violazioni di Dati Personali e alla stesura della versione finale del *Data Breach Report*.

2.5.2 Registro Violazioni di Dati Personali e Registro dei Near Miss

Il Registro delle Violazioni di Dati Personali è il supporto informatico che consente al Titolare di documentare “*qualsiasi violazione dei dati personali, comprese le circostanze a essa relative, le sue conseguenze e i provvedimenti adottati per porvi rimedio.*” (art. 33, par. 5, GDPR)⁶⁶.

⁶³ Esempi di metodi trasparenti di comunicazione sono: la messaggistica diretta (ad esempio messaggi di posta elettronica, SMS, messaggio diretto), banner o notifiche su siti web di primo piano, comunicazioni postali e pubblicità di rilievo sulla stampa.

⁶⁴ *Root Causes*: fattori causali di base dell'incidente.

⁶⁵ *Lesson Learned*: esperienza acquisita dopo l'incidente.

⁶⁶ Le informazioni contenute nel Registro Violazioni sono stabilite dal DPO di FS SpA, secondo il *template* riportato sulla intranet aziendale nella sezione *Data Protection*.



Scopo del Registro è quello di consentire all'Autorità Garante di verificare, in caso di ispezione o richiesta specifica, il rispetto degli adempimenti in capo al Titolare nella gestione delle violazioni dei dati personali e fornire un utile strumento per la mitigazione del *data breach* e il seguimiento delle attività di *remediation*.

La responsabilità della tenuta e dell'aggiornamento del Registro delle Violazioni di Dati Personali è in capo al DPO ed è reso disponibile, in sola consultazione, al DPO di FS SpA.

Il DPO di FS SpA, in considerazione del contenuto dei Registri societari, valuta se proporre eventuali azioni di mitigazione coordinate sulle Società del Gruppo FS Italiane.

Se necessario, il DPO provvede ad aggiornare il Registro sulla base dello stato di avanzamento degli interventi previsti nei *Data Breach Report*.

Oltre al Registro delle Violazioni, ai soli fini gestionali e in ottica di miglioramento continuo dei processi, il Titolare può facoltativamente tenere e aggiornare un registro dei *near-miss*⁶⁷, intesi come tutti gli eventi segnalati come potenziali *data breach* ma rivelatisi falsi positivi.

⁶⁷ Le informazioni contenute nel Registro *Near-Miss* sono stabilite dal DPO di FS SpA, secondo il *template* riportato sulla intranet aziendale nella sezione *Data Protection*.



SEZIONE F

DEFINIZIONE E APPLICAZIONE DEL PERIODO DI CONSERVAZIONE DEI DATI PERSONALI



SEZIONE F	76
1. <u>DEFINIZIONE E APPLICAZIONE DEL PERIODO DI CONSERVAZIONE DEI DATI PERSONALI.....</u>	78
1.1 PREMESSA E DEFINIZIONI.....	78
2. <u>INDIVIDUAZIONE DEL PERIODO O DEL CRITERIO DI CONSERVAZIONE DEL DATO PERSONALE</u>	80
2.1 STEP 1 – DETERMINAZIONE DELLE ESIGENZE “OPERATIVE” DI CONSERVAZIONE	81
2.2 STEP 2 – VERIFICA DI VINCOLI DI CONSERVAZIONE DI NATURA DIVERSA DALLA FINALITÀ DI BUSINESS/OPERATIVA	81
2.2.1 VINCOLI DI NATURA LEGALE E REGOLAMENTARE.....	81
2.2.2 CONSERVAZIONE A FINI DI ARCHIVIAZIONE NEL PUBBLICO INTERESSE, DI RICERCA SCIENTIFICA O STORICA O A FINI STATISTICI.....	82
2.2.3 CONTENZIOSO, AZIONI GIUDIZIARIE, MODELLI ORGANIZZATIVI PER LA PREVENZIONE DI REATI	82
2.3 STEP 3 – VALUTAZIONE DEI RISCHI	83
2.4 STEP 4 – DETERMINAZIONE E ATTUAZIONE DEL PERIODO E/O DEI CRITERI DI CONSERVAZIONE	83
2.5 CASI PARTICOLARI ED ECCEZIONI	84
2.5.1 DOCUMENTAZIONE AZIENDALE RIPORTANTE NOME E COGNOME DEL SOGGETTO FIRMATARIO	84
2.5.2 INTERRUZIONE DEI NORMALI TEMPI DI CONSERVAZIONE.....	84
2.5.3 ESERCIZIO DEL DIRITTO DI CANCELLAZIONE DEI DATI PERSONALI DA PARTE DEGLI INTERESSATI.....	84
3. <u>APPLICAZIONE DEL PERIODO E/O DEL CRITERIO DI CONSERVAZIONE DEL DATO PERSONALE</u>	85
3.1 SUPPORTI CARTACEI.....	85
3.2 SISTEMI INFORMATIVI.....	86
3.2.1 INFORMATICA INDIVIDUALE.....	86
3.2.2 SISTEMI INFORMATIVI.....	86
3.2.3 GESTIONE DELLE TERZE PARTI IN MATERIA DI PERIODI E CRITERI DI CANCELLAZIONE DEI DATI PERSONALI	86
4. <u>MATRICE DI DATA RETENTION.....</u>	87
INDICE DELLE FIGURE	88
INDICE DELLE TABELLE	88
GLOSSARIO	89



1. Definizione e applicazione del periodo di conservazione dei dati personali

1.1 Premessa e definizioni

Uno degli elementi di novità, tra i più delicati introdotti da Regolamento UE 2016/679, è rappresentato dall'obbligo di determinare per ciascun trattamento un **periodo di conservazione** dei dati personali trattati e/o **identificare i criteri** utilizzati per determinare tale periodo. Sulla base di quanto previsto dal Regolamento, l'interessato ha quindi diritto alla cancellazione dei propri dati personali, secondo le logiche di:

- *Deletion By Default*: i dati personali devono essere cancellati una volta esaurite le finalità per le quali sono stati raccolti o trattati. Il Regolamento, con l'Art. 5, Par. 1, e), rafforza infatti il principio di “limitazione della conservazione”, per altro già presente nella normativa precedente, stabilendo che “I dati personali sono: [...] conservati in una forma che consenta l'identificazione degli interessati per un arco di tempo non superiore al conseguimento delle finalità per le quali sono trattati; [...]. Il Regolamento specifica inoltre agli Artt.13, Par. 2 e 14, Par. 2, che il periodo di conservazione è tra le informazioni da fornire all'interessato al momento della raccolta dei dati, al fine di garantire un trattamento corretto e trasparente: “[...] nel momento in cui i dati personali sono ottenuti, il Titolare del trattamento fornisce all'interessato le seguenti ulteriori informazioni necessarie per garantire un trattamento corretto e trasparente: a) il periodo di conservazione dei dati personali oppure, se non è possibile, i criteri utilizzati per determinare tale periodo;”
- *Deletion On Demand*: i dati personali devono essere cancellati quando l'interessato ne faccia richiesta secondo le condizioni stabilite dal regolamento all'Art. 17⁶⁸.

L'Interessato ha inoltre il diritto di richiedere i tempi di conservazione previsti dal Titolare, relativi al trattamento di dati personali a lui riconducibili, oppure, se non è possibile, dei criteri utilizzati per determinare tale periodo. Così l'Art. 15.1 d): “L'interessato ha il diritto di ottenere dal Titolare del trattamento la conferma che sia o meno in corso un trattamento di dati personali che lo riguardano e in tal caso, di ottenere l'accesso ai dati personali e alle seguenti informazioni: [...] quando possibile, il periodo di conservazione dei dati personali previsto oppure, se non è possibile, i criteri utilizzati per determinare tale periodo”

Il principio di “limitazione della conservazione”, inoltre, è strettamente connesso a quello più ampio di “minimizzazione dei dati personali”, relativo allo spazio (i dati acquisiti e trattati sono quelli strettamente necessari per le finalità di business/operative) ma anche al tempo (i dati sono mantenuti per il tempo strettamente necessario al conseguimento delle finalità di business/operative). Tale principio è espresso compiutamente nel Considerando 39 del Regolamento:

“I dati personali dovrebbero essere adeguati, pertinenti e limitati a quanto necessario per le finalità del loro trattamento. Da qui l'obbligo, in particolare, di assicurare che il periodo di conservazione dei dati personali sia limitato al minimo necessario. I dati personali dovrebbero essere trattati solo se la finalità del trattamento non è ragionevolmente conseguibile con altri mezzi. Onde assicurare che i dati personali non siano conservati più a lungo del necessario, il Titolare del trattamento dovrebbe stabilire un termine per la cancellazione o per la verifica periodica. È opportuno adottare tutte le misure ragionevoli affinché i dati personali inesatti siano rettificati o cancellati.”

Si specifica, infine, che nel seguito del documento si parlerà indistintamente di periodo e/o criterio di conservazione dei dati personali, definiti più dettagliatamente come segue:

⁶⁸ Si vedano le linee di indirizzo in materia di gestione delle richieste di esercizio dei diritti da parte degli interessati ([Sezione C](#) del presente documento).



- **Periodo di conservazione:** rappresenta il termine temporale stabilito dal *Data Manager*, che consente, per il trattamento di competenza, l'identificabilità diretta o indiretta dell'interessato. È calcolato dal momento dell'acquisizione del dato personale ed è espresso nelle comuni unità di tempo (ad es. 3 anni, 6 mesi, etc.).
- **Criterio di conservazione:** rappresenta l'evento individuato dal *Data Manager* (ad es. alla ricezione dell'*unsubscribe*, 3 mesi dal termine del rapporto di lavoro, 12 mesi dall'ultimo aggiornamento, 3 anni dalla data di verbalizzazione del comitato, 6 mesi dalla chiusura del procedimento, 15 mesi dalla data del viaggio, 4 settimane dalla ricezione del reclamo etc.) che fa scattare le misure di cancellazione, di anonimizzazione, di eventuale distruzione dei supporti o, in alternativa, determina la conservazione ai fini di archiviazione nel pubblico interesse, di ricerca scientifica o storica o a fini statistici del dato personale (anche tramite pseudonimizzazione).

2. Individuazione del periodo o del criterio di conservazione del dato personale

Il *Data Manager* ha la responsabilità di progettare i trattamenti di dati personali che derivano da esigenze di *business/operative* in modo da garantire nativamente il rispetto dei principi del Regolamento e, nel contesto delle presenti linee guida, circoscrivere e limitare l'utilizzo di dati personali al periodo strettamente necessario per il raggiungimento delle finalità di *business/operative*. Il *Data Manager* è la figura che definisce il periodo o il criterio di conservazione dei dati personali relativo ai trattamenti di propria competenza, compatibilmente con le esigenze di conservazione di natura diversa. Definisce inoltre l'azione da porre in essere al termine del periodo di conservazione (ad esempio cancellazione, anonimizzazione, revisione).

L'individuazione del periodo e/o dei criteri di conservazione dei dati personali passa necessariamente per la valutazione ed il bilanciamento di diversi fattori. Al fine di supportare il processo decisionale, affidato al *Data Manager*, si propone in **Figura 8** e nel seguito del documento un flusso logico suddiviso in diverse fasi e snodi decisionali che suggeriscono il confronto con altre eventuali funzioni organizzative coinvolte.

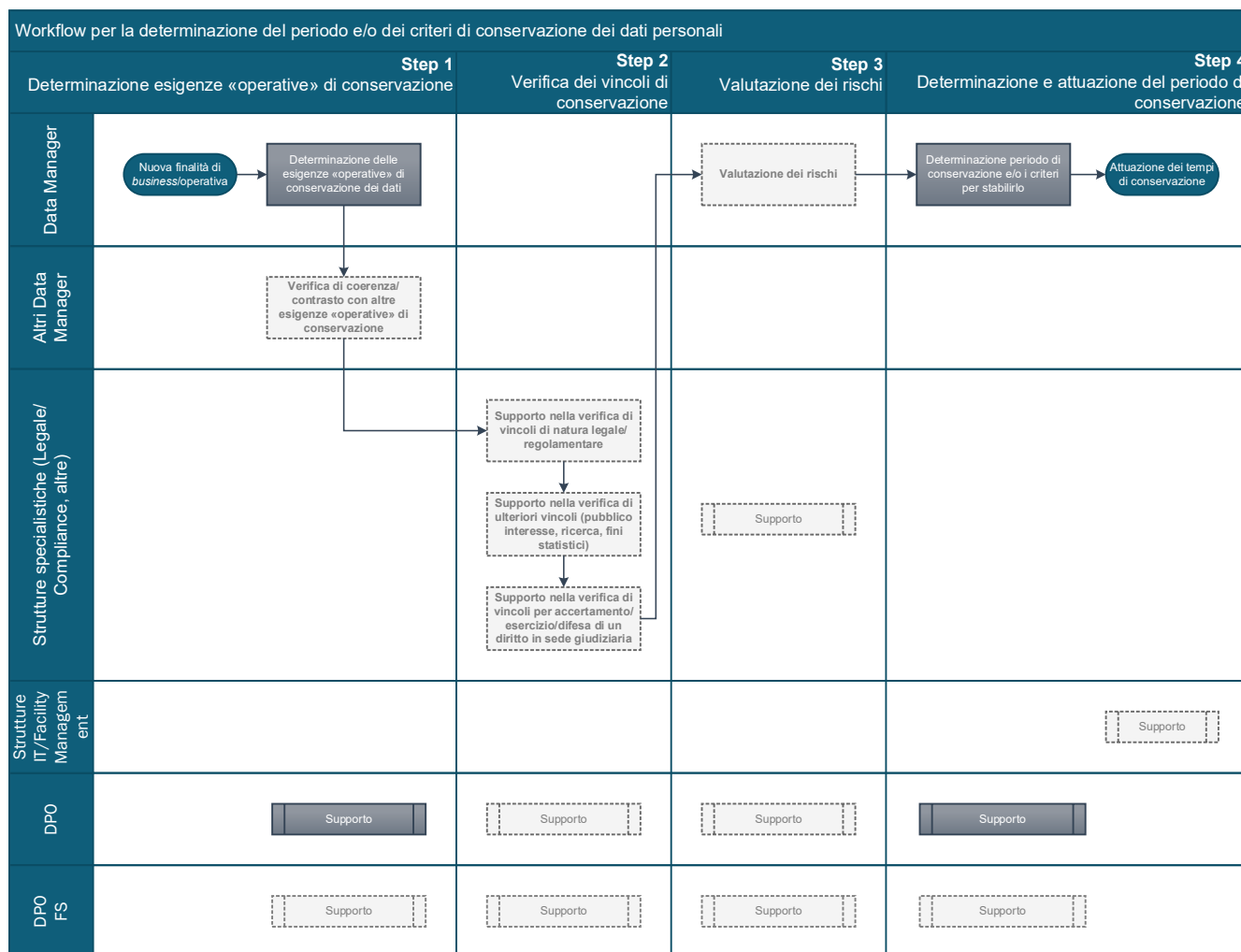


Figura 8 – Workflow per la determinazione del periodo e/o dei criteri di conservazione dei dati personali



2.1 **Step 1** – Determinazione delle esigenze “operative” di conservazione

Il primo *driver* che deve essere considerato nella determinazione del periodo o dei criteri di conservazione è legato all'esigenza di *business*/operativa che richieda un trattamento di dati personali. Il *Data Manager* deve quindi rispondere alla domanda “*qual è il tempo minimo di conservazione del dato personale affinché la mia esigenza di business/operativa possa essere realizzata?*”.

Nel rispondere alla domanda devono sempre essere considerati **(i)** la possibilità di raggiungere il medesimo risultato rendendo l'interessato non più identificabile (**anonimizzazione**), **(ii)** il principio di minimizzazione (**il tempo di conservazione è quello strettamente necessario**).

Solo al fine di esemplificare il concetto si riportano di seguito due possibili situazioni in cui ci si limita a considerare le sole necessità “operative” e non è necessaria la valutazione di vincoli di altra natura che prescrivano periodi diversi di conservazione del dato (ad es. normativi, di tutela, di controllo, analizzati nei paragrafi successivi). Si specifica che i due esempi di seguito devono essere considerati al solo fine di agevolare la lettura del documento e non come indicazione dei tempi di conservazione da applicare in situazioni analoghe.

Esempio #1 – Creazione di una mailing list rivolta ad investitori istituzionali. I dati anagrafici e di contatto sono necessari al fine di informare un gruppo di investitori sulle attività istituzionali di una Società. In questo caso, non potendo stabilire preventivamente quando cesserà l'attività di *mailing*, un criterio espresso come “*2 gg lavorativi dalla ricezione dell'unsubscribe o al termine delle attività istituzionali di comunicazione*” risulterebbe adeguato. Non sono ritenute necessarie verifiche di altra natura.

Esempio #2 – Verbalizzazione delle attività di un Comitato di Progetto. L'attività di verbalizzazione si rende necessaria al fine di condividere i punti di vista e approvare le decisioni assunte in modo collegiale dai membri del Comitato. I dati raccolti nel verbale (nomi, cognomi, dati di contatto, opinioni espresse, azioni attribuite etc.) potrebbero essere mantenuti per la durata del progetto o, in alternativa, fino alla verbalizzazione del successivo Comitato. In questo caso potrebbero non sussistere obblighi di natura diversa e, di conseguenza, un criterio espresso come “*I verbali saranno cancellati dopo 30 gg dalla fine del progetto*” risulterebbe pertanto adeguato.

In molti casi, quindi, il processo di determinazione del periodo e/o dei criteri di conservazione si conclude con la determinazione delle esigenze “operative” di conservazione e devono solo essere stabilite le modalità di attuazione (declinati nello **Step 4 - Determinazione e attuazione del periodo e/o dei criteri di conservazione**).

2.2 **Step 2** – Verifica di vincoli di conservazione di natura diversa dalla finalità di *business*/operativa

Generalmente, il periodo e/o il criterio di conservazione “operativo” deve essere considerato congiuntamente ad esigenze di conservazione di altra natura. Nei paragrafi che seguono sono identificati in via esemplificativa e non esaustiva i principali vincoli che possono portare ad una revisione del periodo e/o del criterio di conservazione.

2.2.1 Vincoli di natura legale e regolamentare

Il *Data Manager*, in fase di progettazione del trattamento e di individuazione del periodo di conservazione dei dati personali, confronta il periodo che ha individuato come necessario per le finalità di *business*/operative



con le prescrizioni normative, ossia dei casi in cui una norma di legge o i provvedimenti delle Authority di riferimento stabiliscano il periodo (generalmente un periodo minimo o massimo) e/o il criterio di conservazione. Di seguito si riportano alcuni esempi.

Esempio #3 – Videosorveglianza. Per quanto attiene i trattamenti di videosorveglianza, il provvedimento del Garante per la Protezione dei Dati Personali n. 1712680, dell'8 aprile 2010, stabilisce tempi di conservazione massimi variabili fra 24h e 7gg in funzione del settore di appartenenza del Titolare e delle finalità del trattamento.

Esempio #4 – Scritture contabili. L'art. 2220 del Codice Civile relativo alla conservazione delle scritture contabili: *“Le scritture devono essere conservate per dieci anni dalla data dell'ultima registrazione. Per lo stesso periodo devono conservarsi le fatture, le lettere e i telegrammi ricevuti e le copie delle fatture, delle lettere e dei telegrammi spediti”* stabilisce l'obbligatorietà di un periodo minimo di conservazione e non esclude tempi maggiori.

Nel caso in cui il periodo individuato per le finalità di *business*/operative sia superiore a quello massimo stabilito normativamente, il *Data Manager* dovrà attenersi a quest'ultimo, riducendo il periodo di conservazione. Al contrario, nel caso in cui il periodo sia inferiore rispetto a quello minimo stabilito normativamente, dovrà estenderlo.

Il *Data Manager*, ove ravvisi esigenze di natura interpretativa, consulta il DPO che, avvalendosi ove necessario del contributo del DPO di FS SpA e delle competenti strutture societarie/di Capogruppo⁶⁹ fornirà il necessario supporto per garantire l'individuazione del periodo e del criterio di conservazione.

I trattamenti per i quali il periodo o il criterio di conservazione è fissato da norme di legge o provvedimenti delle Authority sono progressivamente riportati nella “Matrice di *data retention*” (si veda **Capitolo 4 - Matrice di Data Retention**).

2.2.2 Conservazione a fini di archiviazione nel pubblico interesse, di ricerca scientifica o storica o a fini statistici

Il Regolamento UE 679/2016 (Art. 89) prevede la possibilità di estendere il periodo di conservazione ai fini di archiviazione nel pubblico interesse, di ricerca scientifica o storica o a fini statistici, fatta salva l'attuazione di misure tecniche e organizzative adeguate a tutela dei diritti e delle libertà dell'interessato (ad esempio la pseudonimizzazione).

Nel caso in cui il *Data Manager* ritenga di incorrere in una delle condizioni di cui sopra consulta il DPO che, avvalendosi ove necessario del contributo del DPO di FS SpA, valuta l'effettiva sussistenza di tali condizioni e le misure di sicurezza tecniche ed organizzative adeguate.

2.2.3 Contenzioso, azioni giudiziarie, modelli organizzativi per la prevenzione di reati

In taluni casi, la cancellazione o l'anonimizzazione dei dati personali potrebbero comportare la compromissione della capacità di accertamento/esercizio/difesa dei diritti della Società, ad esempio in caso di precontenzioso e/o contenzioso, oppure potrebbero esporre la Società a rischi di altra natura, ad esempio in caso di ispezioni, indagini o azioni giudiziarie.

⁶⁹ Ad esempio strutture Legali, *Compliance*, Legale Lavoro, Amministrazione, Fiscale, etc.



È inoltre possibile che la cancellazione o l'anonimizzazione dei dati personali possa compromettere sia l'efficacia sia la dimostrabilità nell'applicazione dei modelli organizzativi per la prevenzione dei reati (ad es. il Modello di Organizzazione, Gestione e Controllo ex D.lgs. n. 231/2001, l'*Anti Bribery & Corruption management system* nonché altri modelli di prevenzione dei reati che compongono il Sistema di Controllo Interno e Gestione dei Rischi – SCIGR).

In questi casi, il *workflow* prevede una fase di “valutazione dei rischi” (**Step 3 - Valutazione dei rischi**), descritta nel paragrafo successivo.

2.3 **Step 3 – Valutazione dei rischi**

Nei casi in cui non siano riscontrabili vincoli di natura normativa/regolamentare ma si ritiene sussistano rischi connessi alla compromissione della capacità di accertamento/esercizio/difesa dei diritti della Società oppure connessi all'efficacia/dimostrabilità dell'applicazione dei modelli organizzativi per la prevenzione dei reati, il *Data Manager* consulta il DPO che, valutatane la necessità, coordinerà un processo di valutazione dei rischi con il supporto, ove necessario, del DPO di FS SpA e delle competenti strutture specialistiche societarie/di Capogruppo⁷⁰.

Il processo di valutazione dei rischi consiste:

- a) nella ricerca dello **storico degli eventi riconducibili agli scenari di rischio** (sia interni che esterni al Gruppo) a cui si espone la Società con la cancellazione/anonymizzazione del dato;
- b) nel **bilanciamento dei rischi per la Società rispetto ai rischi per i diritti e le libertà dell'interessato** legati all'estensione/riduzione del periodo di conservazione.

L'analisi andrà conservata dal *Data Manager* a supporto di possibili future verifiche e/o contestazioni attivate dall'Autorità di Controllo e/o dagli interessati.

I trattamenti, per i quali il periodo o i criteri di conservazione sono determinati da un'analisi di rischio, sono progressivamente riportati nella “Matrice di *data retention*” (a cura del DPO di FS SpA).

2.4 **Step 4 – Determinazione e attuazione del periodo e/o dei criteri di conservazione**

Il *Data Manager* provvede ad avviare le necessarie progettualità per l'attuazione e applicazione del periodo e/o dei criteri di conservazione a livello organizzativo e tecnico. In particolare, per i nuovi trattamenti, i tempi e/o i criteri di conservazione devono essere definiti ed attuati sulla base delle regole definite nelle linee di indirizzo per la *data protection by design e by default* ([Sezione A](#) del presente documento).

Il *Data Manager*, provvede infine a monitorare periodicamente il rispetto del periodo e/o dei criteri di conservazione anche al fine di verificare se i tempi di conservazione originariamente individuati siano effettivamente necessari rispetto alle finalità perseguite ed, eventualmente, rivalutare i tempi di conservazione procedendo all'aggiornamento del Registro dei Trattamenti⁷¹.

⁷⁰ Ad esempio strutture Legali, *Compliance*, Legale Lavoro, Amministrazione, Fiscale, etc.

⁷¹ Per maggiori dettagli si vedano le linee di indirizzo in materia di protezione dei dati personali (DdG in materia di modello di gestione per la protezione dei dati personali).



2.5 Casi particolari ed eccezioni

2.5.1 Documentazione aziendale riportante nome e cognome del soggetto firmatario

Qualsiasi documento aziendale riportante anche solo il nome e il cognome di un soggetto firmatario (ad esempio, una scheda di rilevazione esigenza, una Comunicazione Organizzativa, una comunicazione firmata che non contiene ulteriori dati personali, etc.) può essere considerato un trattamento di dati personali.

Tuttavia, se il documento non contiene informazioni personali riguardanti l'interessato o altri soggetti, in considerazione del livello di rischio minimo per i diritti e le libertà delle persone fisiche rappresentato da tale trattamento e, ai fini del presente documento che non intende disciplinare i tempi di conservazione della documentazione aziendale nella sua totalità, per i documenti che non contengano informazioni personali ad eccezione del nome e cognome del soggetto firmatario, prevalgono i tempi e i criteri di conservazione dettati dalle esigenze di *business*/operative (anche se non formalizzati) o da altre disposizioni aziendali.

2.5.2 Interruzione dei normali tempi di conservazione

Nel caso in cui intervengano indagini da parte di Autorità competenti o l'azienda si trovi in una situazione di pre-contenzioso/contenzioso con una terza parte o con il dipendente, nell'ottica di salvaguardare il legittimo interesse della Società, il *Data Manager* può valutare la sospensione dei tempi di conservazione normalmente definiti.

Esempio #5 – Nel caso in cui si verifichi un furto di un asset aziendale, può essere sospesa la cancellazione delle immagini di videosorveglianza fino all'accertamento del reato da parte dell'Autorità Giudiziaria.

Il *Data Manager*, nel caso in cui ravvisi esigenze di natura interpretativa legate all'interruzione dei normali tempi di conservazione, consulta il DPO che, avvalendosi ove necessario del contributo del DPO di FS SpA e delle competenti strutture societarie/di Capogruppo (ad esempio strutture Legali, *Compliance*, Legale Lavoro, Amministrazione, Fiscale, etc.) fornirà il necessario supporto per valutare se è giustificata l'interruzione dei tempi di conservazione.

2.5.3 Esercizio del diritto di cancellazione dei dati personali da parte degli interessati

Nel caso in cui un interessato eserciti il diritto di cancellazione si rinvia integralmente a quanto disciplinato nelle linee di indirizzo per la gestione dei diritti degli Interessati ([Sezione C](#) del presente documento).

In linea generale, ove non vi siano specifici obblighi derivanti da normative di settore che impongano diverse modalità e tempi di conservazione del dato personale, si deve dare seguito all'esercizio del diritto cancellando o anonimizzando i dati, nei tempi e con le modalità previste dalle citate linee guida, anticipando di fatto, per questa specifica posizione soggettiva, il periodo di conservazione originariamente definito per il relativo trattamento.



3. Applicazione del periodo e/o del criterio di conservazione del dato personale

Nel presente Capitolo si forniscono le indicazioni operative per l'attuazione e applicazione del periodo e/o del criterio di conservazione, in funzione del supporto utilizzato per il trattamento (cartaceo/informatico) e nei rapporti con le terze parti.

3.1 Supporti cartacei

Per i trattamenti che prevedono l'utilizzo di supporti cartacei, il *Data Manager* predispone delle apposite istruzioni operative, ove necessario con il supporto del DPO, che dettagliano le modalità di anonimizzazione/cancellazione/distruzione dei dati personali degli interessati al termine del periodo prestabilito.

Le istruzioni operative sono comunicate ad eventuali incaricati del trattamento e strettamente monitorate nel tempo. Nel caso in cui alcuni servizi di *facility management* siano affidati ad un soggetto tecnico responsabile delle attività di trattamento, il *Data Manager* comunica le esigenze di cancellazione/distruzione individuate a tale soggetto, in linea con quanto previsto nei contratti di *service* e nel relativo accordo di *data protection*⁷².

Le istruzioni stabilite dal *Data Manager* sono conservate dal medesimo e presentate in caso di controlli effettuati dall'Autorità di Controllo e/o dalle strutture aziendali preposte, incluso il DPO delle sue attività di controllo.

A mero titolo esemplificativo e non esaustivo, consideriamo di seguito alcune ipotesi operative.

Esempio #6 – Nell'ambito dei processi Risorse Umane, il *Data Manager* responsabile di uno specifico trattamento individua in 5 anni dalla data di presentazione di una domanda il periodo di conservazione dei dati personali contenuti in un modulo cartaceo sottoscritto dal dipendente. Il *Data Manager* stabilisce un *check* trimestrale, da svolgersi nei primi 15 giorni del trimestre, per eliminare la modulistica relativa alle domande presentate più di 5 anni prima. Il *Data Manager* individua come modalità sicura di distruzione il distruggidocumenti presente all'interno della struttura.

Esempio #7 – Nell'ambito dei processi Audit, il *Data Manager* responsabile di uno specifico trattamento individua in 10 anni dalla data di presentazione di un rapporto di Audit il periodo di conservazione dei dati personali contenuti nel documento cartaceo. Il *Data Manager* stabilisce una revisione annuale dei rapporti inviati da almeno 10 anni e valuta quali debbano essere distrutti. Individua come modalità sicura di distruzione il distruggidocumenti presente all'interno della struttura.

Esempio #8 – Nell'ambito dei processi Legale e Contenzioso, il *Data Manager* responsabile di uno specifico trattamento individua in 10 anni dalla data del passaggio in giudicato di una sentenza il periodo di conservazione dei dati personali contenuti nel fascicolo. Il *Data Manager* stabilisce una revisione annuale dei fascicoli definiti da almeno 10 anni e ne individua quelli che, per rilevanza dei contenuti, devono essere

⁷² Si vedano le linee di indirizzo per la gestione delle terze parti ([Sezione D](#) del presente documento)



anonimizzati e non distrutti. Per i restanti fascicoli affida alla struttura competente (ad es. di Ferservizi) la distruzione sicura dei documenti attraverso apposita procedura di smaltimento certificata.

3.2 Sistemi informativi

3.2.1 Informatica individuale

Per i trattamenti che prevedano l'utilizzo di informatica individuale (*laptop/desktop*, etc), il *Data Manager*, ove necessario con il supporto del DPO, predispone delle apposite istruzioni operative che dettagliano le modalità di anonimizzazione o cancellazione dei dati personali degli interessati al termine del periodo prestabilito. Le istruzioni operative sono comunicate ad eventuali incaricati del trattamento e strettamente monitorate nel tempo.

Le istruzioni stabilite dal *Data Manager* sono conservate dal medesimo e presentate in caso di controlli effettuati dall'Autorità di Controllo e/o delle strutture aziendali preposte, incluso il DPO delle sue attività di controllo.

Esempio #9 – Le istruzioni operative possono prevedere la *review* periodica (ad es. annuale) della documentazione conservata in locale e/o su strumenti di *sharing* aziendali e l'individuazione delle modalità di cancellazione (ad es. cancellazione contestuale da *hard disk*, da cestino, da posta elettronica).

3.2.2 Sistemi informativi

Per i trattamenti che prevedano l'utilizzo di sistemi informativi, il *Data Manager* comunica al soggetto tecnico responsabile dei sistemi informativi, in linea con quanto previsto negli eventuali contratti di *service* e nei relativi Accordi di Data Protection, le esigenze di anonimizzazione o cancellazione individuate, seguendo la procedura societaria prevista per la modifica/*upgrade* dei sistemi informativi.

Esempio #10 – Se previsto nelle procedure societarie di ingaggio del soggetto tecnico responsabile dei sistemi IT, il *Data Manager* potrà predisporre un'apposita Scheda di Rilevazione Esigenza (SRE), approvare la Progettazione Definitiva (PD), valutare l'effettiva implementazione dei meccanismi di cancellazione o anonimizzazione individuati.

3.2.3 Gestione delle Terze Parti in materia di periodi e criteri di cancellazione dei dati personali

Nel caso in cui il *Data Manager* si avvalga contrattualmente di una terza parte qualificata come “*Responsabile del trattamento*”⁷³ ai sensi della normativa sulla protezione dei dati personali, si rinvia integralmente a quanto disciplinato nelle linee di indirizzo per la gestione delle terze parti con riferimento alla protezione dei dati personali.

In linea generale, le istruzioni sulle attività di trattamento fornite al Responsabile esterno all'interno dell'accordo di *data protection* (oppure declinate nel capitolato di gara) dovranno essere congruenti con i

⁷³ Soggetto terzo a cui il *Data Manager* affida per intero o parzialmente il trattamento del quale ha la responsabilità organizzativa.



periodi, i criteri e le misure di sicurezza relativi alla conservazione secondo quanto stabilito per il relativo trattamento.

Ove possibile, il Responsabile esterno del trattamento, alla data di scadenza del contratto od entro periodo congruo a partire dalla data di scadenza del contratto condiviso con il Titolare, provvede all'immediata:

- cancellazione/distruzione/anonimizzazione dei dati, certificando al Titolare tali operazioni, a meno che la legislazione non gli impedisca di restituire o distruggere in tutto o in parte tali dati personali. In tal caso, per quanto riguarda i dati personali in questione, il Responsabile dovrà assicurare che ne garantirà la riservatezza e che non procederà più al loro trattamento;
- restituzione di tutti i dati personali relativi al trattamento dei dati e delle relative copie al Titolare.

4. Matrice di Data Retention

Al fine di garantire adeguate sinergie ed uniformità nella definizione dei periodi e dei criteri di conservazione su trattamenti riconducibili a ambiti/processi analoghi all'interno della stessa Società o di diverse Società del Gruppo, il DPO di FS SpA, nel suo ruolo di indirizzo e coordinamento, provvede alla pubblicazione e all'aggiornamento sulla intranet aziendale della c.d. Matrice di *Data Retention*, che fornisce, in maniera indicativa, non vincolante e non esaustiva⁷⁴, i periodi di conservazione suggeriti convenzionalmente in funzione delle macro-categorie di trattamento. Ad integrazione della Matrice di *Data Retention* di Gruppo, se ritenuto opportuno, i DPO delle Società controllate, coordinandosi con il DPO di FS SpA, possono provvedere alla predisposizione di una Matrice di Data Retention societaria.

La Matrice di *Data Retention* è aggiornata sulla base delle indicazioni dell'Autorità Garante per la Protezione dei Dati Personali o di altre Autorità, nazionali e/o europee, sulla base di *best practice* di sistema dell'esperienza maturata all'interno del Gruppo FS Italiane secondo i criteri stabiliti nel presente documento e, più in generale, nel *Framework* di *Data Protection*. La matrice riporta almeno i seguenti campi: **(i)** processi aziendali di riferimento, **(ii)** termine di conservazione suggerito; **(iii)** tipologie di interessati; **(iv)** eventuale requisito/riferimento normativo.

⁷⁴ Il *Data Manager* valuta l'applicabilità delle indicazioni fornite nella matrice ai trattamenti di propria competenza. Nel caso in cui emergessero sostanziali differenze fra il periodo di conservazione applicato al trattamento e le indicazioni fornite nella matrice, può rivolgersi al DPO per proporre le necessarie variazioni. Quest'ultimo interpella il DPO di FS SpA per l'eventuale modifica/integrazione della matrice di Gruppo.



INDICE DELLE FIGURE

▪ FIGURA 1 - LIVELLI DI APPLICAZIONE “DATA PROTECTION BY DEFAULT E BY DESIGN”.....	9
▪ FIGURA 2 – PROGETTAZIONE SECONDO LE REGOLE DI DATA PROTECTION BY DESIGN E BY DEFAULT	11
▪ FIGURA 3 – WORKFLOW PER L’IDENTIFICAZIONE DEI TRATTAMENTI A POTENZIALE RISCHIO ELEVATO ED EVENTUALE DPIA	26
▪ FIGURA 4 – COMPONENTI DEL RISCHIO.....	34
▪ FIGURA 5 – WORKFLOW PER LA GESTIONE DELLE RICHIESTE DI ESERCIZIO DEI DIRITTI DA PARTE DEGLI INTERESSATI.....	47
▪ FIGURA 6 – WORKFLOW PER L’IDENTIFICAZIONE DEL RUOLO DATA PROTECTION DELLA TERZA PARTE	59
▪ FIGURA 7 – WORKFLOW PER LA GESTIONE DEI DATA BREACH	69
▪ FIGURA 8 – WORKFLOW PER LA DETERMINAZIONE DEL PERIODO E/O DEI CRITERI DI CONSERVAZIONE DEI DATI PERSONALI	80

INDICE DELLE TABELLE

TABELLA 1 – CRITERI PER LA DETERMINAZIONE DEI TRATTAMENTI A RISCHIO ELEVATO.....	30
TABELLA 2 – LIVELLI DI GRAVITÀ DEL DATA BREACH.....	71
TABELLA 3 - REGOLE PER LA NOTIFICA A GARANTE ED INTERESSATI.....	72



GLOSSARIO

Oggetto	Definizione
Dato(i) Personale(i) / Interessato	Qualsiasi informazione riguardante una persona fisica identificata o identificabile (“Interessato”); si considera identificabile la persona fisica che può essere identificata, direttamente o indirettamente, con particolare riferimento a un identificativo come il nome, un numero di identificazione, dati relativi all’ubicazione, un identificativo online o a uno o più elementi caratteristici della sua identità fisica, fisiologica, genetica, psichica, economica, culturale o sociale.
Categorie particolari di dati personali	Dati personali che rivelino l’origine razziale o etnica, le opinioni politiche, le convinzioni religiose o filosofiche, o l’appartenenza sindacale, nonché trattare dati genetici, dati biometrici intesi a identificare in modo univoco una persona fisica, dati relativi alla salute o alla vita sessuale o all’orientamento sessuale della persona.
Trattamento	Qualsiasi operazione o insieme di operazioni, compiute con o senza l’ausilio di processi automatizzati e applicate a dati personali o insiemi di dati personali, come la raccolta, la registrazione, l’organizzazione, la strutturazione, la conservazione, l’adattamento o la modifica, l’estrazione, la consultazione, l’uso, la comunicazione mediante trasmissione, diffusione o qualsiasi altra forma di messa a disposizione, il raffronto o l’interconnessione, la limitazione, la cancellazione o la distruzione.
Registro dei trattamenti	Ogni titolare del trattamento tiene un registro delle attività di trattamento svolte sotto la propria responsabilità. Tale registro contiene tutte le informazioni di cui all’Art. 30 del Regolamento UE 2016/679.
Pseudonimizzazione	Il trattamento che comporta che i dati personali non possano più essere attribuiti a un interessato specifico senza l’utilizzo di informazioni aggiuntive, a condizione che tali informazioni aggiuntive siano conservate separatamente e soggette a misure tecniche e organizzative intese a garantire che tali dati personali non siano riconducibili ad una persona fisica identificata o identificabile.
Data Breach o Violazione dei Dati Personali	All’interno del Gruppo FS Italiane, si intende per <i>data breach</i> una violazione di sicurezza che comporta, accidentalmente o in modo illecito, le seguenti tipologie di eventi (a titolo esemplificativo e non esaustivo) aventi ad oggetto “ dati personali ”: ▪ distruzione di dati personali su supporti digitali o cartacei, intesa come indisponibilità irreversibile di dati con accertata impossibilità di ripristino degli stessi, conseguente ad eliminazione logica (es. errata cancellazione dei dati nel corso di un intervento manuale o automatizzato) o fisica (es. rottura di dispositivi di memorizzazione informatica, incendio/allagamento locali dove sono archiviati i contratti ed altri documenti dei clienti); ▪ perdita di dati personali, conseguente a smarrimento/furto di supporti digitali (es. <i>laptop</i>, <i>hard-disk</i>, <i>memory card</i>) o cartacei (in originale o in copia);



Oggetto	Definizione
	▪ accesso non autorizzato o intrusione nei Sistemi IT, mediante lo sfruttamento di vulnerabilità dei sistemi e delle reti o la compromissione o rilevazione abusiva di credenziali di autenticazione (es. <i>userid</i> e <i>password</i>); ▪ modifica non autorizzata di dati personali, derivante ad esempio da un'erronea esecuzione di interventi sui sistemi digitali o cartacei o da interventi intenzionali non autorizzati; ▪ diffusione di dati personali a soggetti terzi non autorizzati, anche non identificati, conseguenti ad esempio alla diffusione verbale, ad invio intenzionale o accidentale di documenti o errata gestione di supporti digitali.
Data Manager	Figura individuata con la DdG in materia di “Modello di Gestione per la Protezione dei Dati Personali” cui si rimanda integralmente per la definizione e la descrizione di ruoli e responsabilità.
DPO	Figura individuata con la DdG in materia di “Modello di Gestione per la Protezione dei Dati Personali” cui si rimanda integralmente per la definizione e la descrizione di ruoli e responsabilità. Si specifica, infine, che all'interno del presente <i>framework</i>, in accordo con il modello organizzativo di tipo “distribuito” per la <i>data protection</i> e laddove non diversamente specificato, con “<i>Data Protection Officer</i>” (o “DPO”) si fa esclusivo riferimento al DPO della singola Società.
DPO di FS SpA	Figura individuata con la DdG in materia di “Modello di Gestione per la Protezione dei Dati Personali” cui si rimanda integralmente per la definizione e la descrizione di ruoli e responsabilità.
Template	Lo schema-tipo predisposto dal DPO di FS SpA reso disponibile sull'intranet aziendale che individua lo standard di riferimento per le Società del Gruppo.
Terza Parte	Fornitore di beni e/o servizi o partner commerciale/industriale o altro soggetto terzo, persone fisica o giuridica – incluse Società appartenenti al Gruppo FS Italiane – che, nell'esecuzione di un contratto con la Società Titolare, effettua un trattamento di dati personali o ha accesso a dati personali di quest'ultima.
 Titolare del trattamento	La persona fisica o giuridica, l'autorità pubblica, il servizio o altro organismo che, singolarmente o insieme ad altri, determina le finalità e i mezzi del trattamento di dati personali; quando le finalità e i mezzi di tale trattamento sono determinati dal diritto dell'Unione o degli Stati membri, il titolare del trattamento o i criteri specifici applicabili alla sua designazione possono essere stabiliti dal diritto dell'Unione o degli Stati membri.
Registro delle Violazioni di Dati Personali	Il supporto informatico che consente al Titolare di documentare “ <i>qualsiasi violazione dei dati personali, comprese le circostanze a essa relative, le sue conseguenze e i provvedimenti adottati per porvi rimedio.</i> ” (Art. 33, Par. 5, GDPR).
Responsabile del trattamento	La persona fisica o giuridica, l'autorità pubblica, il servizio o altro organismo che tratta dati personali per conto del Titolare del trattamento.